DOCUMENTO DE ARQUITECTURA DE SOLUCIÓN

Plataforma digital sobre Microsoft Azure

Arquitectura de banca por internet

Arquitectura de banca digital sobre Azure, diseñada para ofrecer consultas y operaciones financieras seguras, escalables y trazables, garantizando la integridad de los datos, la disponibilidad de los servicios y la integración controlada con el Core bancario.

AUTOR
Henry Suntaxi

ALCANCE
Web SPA · App móvil

PLATAFORMA
Microsoft Azure

MERCADO
Ecuador

Contenido

Secciones principales, decisiones arquitectónicas y anexos.

1 **Resumen ejecutivo** 4

2 **Alcance** 5

3 **Visión general y principios de arquitectura** 6

3.1 Capas de la arquitectura 6

3.2 Patrones utilizados 7

4 **Modelo C4, nivel 1: Contexto** 9

4.1 Las personas 11

4.2 El sistema y sus conexiones 11

5 **Modelo C4, nivel 2: Contenedores** 13

5.1 Descripción de los contenedores 15

5.2 Flujos principales entre contenedores 16

5.3 Clientes frecuentes y precarga de caché 16

6 **Modelo C4, nivel 3: Componentes** 18

6.1 Servicio Transferencias y Pagos 18

6.2 BFF y autenticación 21

6.3 Servicios Históricos y Movimientos 23

6.4 Servicio de Onboarding 26

6.5 Servicios de Auditoría y Notificaciones 28

6.6 SPA (Frontend Web) 30

6.7 Aplicación móvil 32

7 **Diagramas de secuencia y flujos** 35

7.1 Consulta del histórico de movimientos 35

7.2 Transferencia entre cuentas del mismo banco 37

7.3 Transferencia a otro banco 39

7.4 Secuencia del resultado incierto 41

7.5 Onboarding con rostro y primer ingreso con biometría 43

8 **Alta disponibilidad, recuperación ante desastres y rendimiento** 45

8.1 Diagrama de infraestructura 45

8.2 Qué protege contra qué 47

8.3 Alta disponibilidad por componente 47

8.4 Recuperación ante desastres 48

8.5 Baja latencia 49
8.6 Conectividad con el Core y los sistemas externos 50

9 Monitoreo, operación y auto-healing 51
9.1 Observabilidad 51
9.2 Indicadores y objetivos de nivel de servicio 51
9.3 Alertas y respuesta 52
9.4 Auto-healing 53
9.5 Runbooks y gestión de incidentes 53

10 Manejo de costos 54
10.1 Enfoque 54
10.2 Gobierno del gasto (FinOps) 54
10.3 Estimación mensual de referencia 54

11 Normativa y estándares 57

12 Matriz de cobertura de requisitos 59

13 Cuadro de decisiones arquitectónicas 61
13.1 Resumen de decisiones 61
13.2 Decisiones estructurales: justificaciones y alternativas 62

A Glosario 67

B Referencias consultadas 71
B.1 Marco legal y regulatorio de Ecuador 71
B.2 Estándares y especificaciones técnicas 71
B.3 Documentación de Azure y arquitectura en la nube 72
B.4 Libros y artículos sobre patrones de arquitectura 72
B.5 Referencias adicionales de las decisiones 72

C Registro de decisiones (ADR) 74

D Decisiones complementarias 86

E Estándares técnicos y evidencias de cumplimiento 89
E.1 Estándares internacionales de apoyo 89
E.2 Evidencias de cumplimiento y validación 89

SECCIÓN 1

Resumen ejecutivo

Este documento describe la arquitectura propuesta para una plataforma de banca por internet de una entidad financiera en Ecuador, que permitirá a los clientes consultar el histórico de sus movimientos y realizar transferencias y pagos, tanto entre cuentas propias como hacia cuentas de otros bancos, a través de una aplicación web (SPA) y una aplicación móvil.

La solución se apoya en cinco decisiones clave, que el resto del documento detalla y justifica:

- **Azure, microservicios y un BFF por canal.** La plataforma corre en AKS, detrás de Front Door y API Management, con un BFF para la web y otro para la app móvil (D1, D3, D4, D5).
- **Consultas desacopladas del Core.** Los históricos se leen de un modelo propio sincronizado con el Core y de Redis, de modo que las consultas no aumentan la carga transaccional (D17, D18).
- **Transferencias seguras.** Las internas se ejecutan de forma atómica en el Core; las interbancarias usan una Saga orquestada con idempotencia y Transactional Outbox (D14, D15, D16).
- **Auditoría inmutable y operación observable.** La evidencia se guarda en almacenamiento WORM y la plataforma se monitorea con objetivos de servicio, alertas y auto-healing (D19, sección 9).
- **Continuidad y costo definidos.** Warm standby en una segunda región con RTO de hasta una hora y RPO de hasta cinco minutos, con una estimación de referencia cercana a 19 900 dólares mensuales (D22, sección 10.3).

¿Qué incluye este documento?

- **Diagramas de arquitectura en Draw.io:** diagrama de contexto (C1), diagrama de contenedores (C2), ocho diagramas de componentes (C3), cinco diagramas de secuencia y un diagrama de infraestructura para alta disponibilidad (HA) y recuperación ante desastres (DR).
- **Decisiones arquitectónicas (ADR):** 39 decisiones, cada una con las alternativas evaluadas y al menos dos justificaciones. La sección 13 resume las 21 estructurales; su registro completo está en el Anexo C y las 18 complementarias, en el Anexo D.
- **Seguridad y cumplimiento normativo:** lineamientos de seguridad, consideraciones regulatorias aplicables al sector financiero ecuatoriano, estimación de costos, excelencia operativa y estrategia de monitoreo.
- **Matriz de cobertura de requisitos:** relación entre los requisitos del enunciado y los componentes, diagramas o secciones del documento que evidencian cómo se abordan.
- **Anexos:** glosario (A), referencias (B), registro de decisiones (C), decisiones complementarias (D) y estándares técnicos con evidencias de cumplimiento (E).

SECCIÓN 2

Alcance

Dentro del alcance

La solución contempla las capacidades necesarias para operar la plataforma de banca por internet, incluyendo la consulta del histórico de movimientos, las transferencias y los pagos entre cuentas propias e interbancarias. También abarca la autenticación de usuarios, el proceso de onboarding con reconocimiento facial, las notificaciones, la auditoría de operaciones y la gestión de caché para clientes frecuentes. Se incluyen, además, el diseño de la infraestructura en la nube, la seguridad, el monitoreo, la estimación de costos y los aspectos operativos necesarios para garantizar la disponibilidad, la trazabilidad y la continuidad del servicio.

Definición de pagos: para efectos de este diseño, un pago es el abono de una cuenta del cliente a un producto de crédito o a un tercero. Los pagos reutilizan los dos flujos de transferencia, sin componentes nuevos:

Tipo de pago	Cómo se ejecuta	Alcance
Pago de productos propios (tarjeta o préstamo del mismo banco)	Operación atómica en el Core, como una transferencia interna.	Incluido
Pago a terceros en otros bancos (persona o empresa con cuenta en otro banco)	Transferencia interbancaria por el SPI, de cuenta a cuenta, con un concepto de pago.	Incluido
Pago de tarjetas o préstamos de otros bancos	Nueva estrategia del servicio de Transferencias y Pagos.	Fuera del alcance

El pago directo a productos de crédito de otras entidades queda fuera del alcance. La arquitectura lo admite como una nueva estrategia del servicio de Transferencias y Pagos (D34), cuando el área de Pagos del banco confirme el mecanismo.

Fuera del alcance

No se contempla el desarrollo ni la modificación de los sistemas de contabilidad, tarjetas o canales presenciales. Tampoco se incluye la implementación de la lógica interna del Core bancario ni del sistema complementario. Estos componentes se consideran sistemas existentes, con los que la plataforma deberá integrarse mediante interfaces y mecanismos de comunicación definidos, respetando sus responsabilidades y capacidades actuales.

SECCIÓN 3

Visión general y principios de arquitectura

3.1 Capas de la arquitectura

La arquitectura se organiza en capas con responsabilidades claramente definidas, separando los canales digitales, las capacidades de negocio, la integración con los sistemas existentes y la gestión de los datos. Este enfoque permite evolucionar los componentes de forma controlada, reducir el acoplamiento entre sistemas y mantener la seguridad, la trazabilidad y la integridad de las operaciones financieras.

3.1.1 Principios de arquitectura

La solución se fundamenta en los siguientes principios:

1. **Separación de responsabilidades:** cada capa y componente debe tener una función claramente definida, evitando la duplicación de responsabilidades y las dependencias innecesarias.
2. **Autonomía de los servicios y propiedad de los datos:** cada servicio debe gestionar los datos correspondientes a su dominio y exponerlos mediante contratos explícitos, evitando el acceso directo a las bases de datos de otros servicios.
3. **Integridad transaccional:** las operaciones financieras deben contemplar controles de consistencia, idempotencia, trazabilidad y conciliación. Los mecanismos de consistencia se definirán según el tipo de operación y los sistemas involucrados.
4. **Desacoplamiento del Core:** las consultas históricas podrán atenderse mediante una réplica de lectura controlada, mientras que las operaciones financieras deberán ejecutarse a través de mecanismos de integración explícitos con el Core, respetando sus reglas de negocio y controles transaccionales.
5. **Seguridad desde el diseño:** la autenticación, autorización, protección de datos, gestión de secretos y auditoría deben formar parte del diseño de cada componente, no incorporarse únicamente como controles posteriores.
6. **Resiliencia y observabilidad:** los servicios deben incorporar mecanismos de manejo de errores, tiempos de espera, reintentos controlados, monitoreo y alertas, evitando que una falla aislada afecte innecesariamente a toda la plataforma.
7. **Evolución incremental:** la arquitectura debe permitir incorporar nuevas capacidades y modernizar las existentes de manera progresiva, minimizando el impacto sobre los sistemas críticos y las operaciones del banco.

3.1.2 Consideraciones sobre la propiedad de los datos

El Core se mantiene como fuente de verdad para los datos y operaciones que corresponden a su dominio. Sin embargo, esto no implica que deba ser el propietario de todos los datos generados por la plataforma digital.

Por ejemplo, el servicio de transferencias puede administrar el estado operativo de una solicitud, su seguimiento y los resultados de la orquestación, mientras que el Core conserva la autoridad sobre los saldos y los registros contables, conforme al modelo de operación del banco.

Esta distinción debe quedar explícita en los contratos de integración, las reglas de consistencia y los procesos de conciliación. Asimismo, la réplica de lectura debe tratarse como una proyección de los datos del Core, considerando los posibles retrasos de sincronización y evitando utilizarla como mecanismo de autorización definitiva para ejecutar operaciones financieras.

La definición de estas responsabilidades permite mantener la integridad de las operaciones, reducir el acoplamiento entre los canales digitales y los sistemas existentes, y facilitar la evolución de la arquitectura sin comprometer la continuidad operativa.

3.2 Patrones utilizados

La arquitectura de la plataforma de banca digital incorpora patrones de diseño, integración, persistencia y resiliencia que permiten reducir el acoplamiento entre componentes, proteger las operaciones financieras y facilitar la evolución de los servicios.

Patrón	Dónde se utiliza	Problema que resuelve
BFF (Backend for Frontend)	BFF Web y BFF Móvil	Adapta las APIs a las necesidades de cada canal digital, evitando que los clientes gestionen directamente la complejidad de los servicios de negocio. Permite aplicar controles específicos para cada canal.
API Gateway	Azure API Management	Centraliza la exposición de APIs y la aplicación de políticas de seguridad, cuotas, limitación de solicitudes, versionado y control de acceso. No sustituye la autorización que deben ejecutar los servicios de negocio.
CQRS (Command Query Responsibility Segregation)	Consulta de históricos y movimientos frente a operaciones de escritura	Separa los modelos de lectura y escritura para optimizar las consultas. La lectura puede apoyarse en una réplica del Core, mientras que las operaciones financieras se procesan mediante los mecanismos transaccionales autorizados.
Cache-Aside	Redis para información de consulta frecuente y no crítica	Reduce la latencia y la carga sobre los sistemas de origen. Requiere políticas de expiración e invalidación, así como controles para evitar que información desactualizada se utilice en decisiones financieras críticas.
Saga orquestada	Transferencias interbancarias y procesos de onboarding que involucren varios sistemas	Coordina una operación distribuida mediante pasos, estados persistentes y acciones de recuperación o compensación. Evita depender de una única transacción distribuida entre sistemas independientes.
Strategy	Selección de algoritmos de transferencia, reglas de procesamiento y fuentes de datos alternativas	Encapsula comportamientos intercambiables detrás de contratos comunes, evitando la dispersión de condicionales y facilitando la incorporación de nuevas estrategias.
Transactional Outbox	Servicios que persisten cambios de negocio y publican eventos	Evita la inconsistencia entre la persistencia de un cambio y la publicación de su evento. El cambio y el evento se registran en una misma transacción local, y un proceso posterior realiza la publicación.
Idempotent Consumer / Idempotency Key	APIs de transferencias y consumidores de eventos	Permite identificar solicitudes repetidas y procesar reintentos de forma segura, reduciendo el riesgo de duplicar operaciones o efectos de negocio. Requiere persistencia de claves, control de concurrencia y reglas de retención.

Patrón	Dónde se utiliza	Problema que resuelve
Circuit Breaker, Retry y Timeout	Integraciones con el Core, sistemas complementarios, SPI y proveedores externos	Limita la propagación de fallas y controla el tiempo de espera y los intentos de comunicación. Los reintentos deben ser limitados y seguros para el tipo de operación.
Anti-Corruption Layer (ACL)	Adaptadores de integración con el Core, sistemas complementarios y SPI	Protege el modelo de dominio de la solución frente a los contratos, estructuras y particularidades de los sistemas externos, evitando que sus cambios se propaguen a los servicios digitales.
Publish-Subscribe / Event Notification	Azure Service Bus y servicios productores y consumidores de eventos	Desacopla productores y consumidores, permitiendo distribuir eventos de forma asíncrona y facilitar la incorporación de nuevas capacidades sin modificar directamente a los productores.
CDC (Change Data Capture)	Sincronizador de datos del Core hacia la réplica de lectura y los mecanismos de actualización de caché que correspondan	Captura los cambios de datos para mantener actualizadas las proyecciones de lectura, reduciendo la necesidad de consultas adicionales al Core. Requiere controlar el orden, la recuperación y el retraso de sincronización.
Dead-Letter Queue (DLQ)	Colas y suscripciones de Azure Service Bus	Aísla los mensajes que no pueden procesarse después de los intentos permitidos, permitiendo su diagnóstico y reprocesamiento controlado sin bloquear indefinidamente el flujo principal.
Fallback	Proveedores de notificaciones y consultas que admitan una fuente alternativa válida	Permite utilizar una alternativa cuando falla el mecanismo principal. La alternativa debe mantener las garantías de seguridad y consistencia requeridas por el caso de uso.

SECCIÓN 4

Modelo C4, nivel 1: Contexto

El diagrama de contexto (C1) presenta una visión general de la plataforma de Banca por Internet y su relación con los usuarios y los sistemas externos. Está dirigido principalmente a personas de negocio, responsables de producto, arquitectos y otros interesados que necesitan comprender el alcance de la solución sin entrar en sus detalles internos de implementación.

La plataforma permite a los clientes acceder a los servicios bancarios digitales para consultar históricos y movimientos, realizar transferencias entre cuentas propias y hacia otras instituciones financieras, y utilizar funcionalidades complementarias como el onboarding digital y las notificaciones.

El diagrama identifica los principales actores, las relaciones con los sistemas externos y los límites de responsabilidad de la solución. Los componentes internos, las tecnologías y los mecanismos técnicos de integración se describen en los niveles C2 y C3.

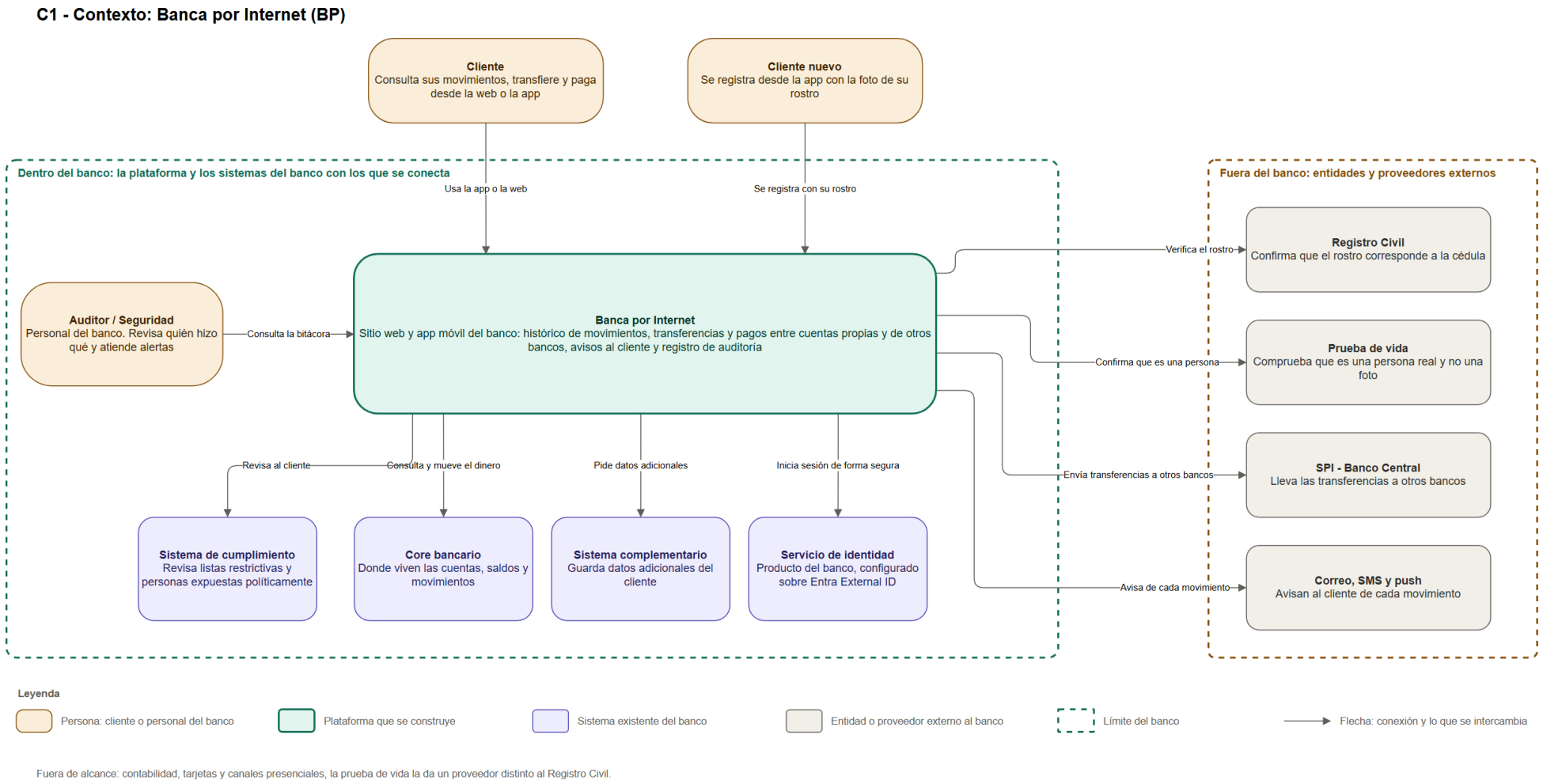


FIGURA 1 C1 – Diagrama de contexto de la Banca por Internet.

4.1 Las personas

El diagrama identifica a los principales actores que interactúan con la plataforma, así como sus responsabilidades dentro de los procesos digitales.

Actor	Qué hace
Cliente	Accede a la banca web o a la aplicación móvil para consultar sus movimientos, realizar transferencias y efectuar pagos de acuerdo con los servicios habilitados para sus cuentas.
Cliente nuevo	Inicia el proceso de registro digital desde la aplicación móvil y completa las validaciones de identidad requeridas, que pueden incluir verificación facial y prueba de vida. Una vez aprobados los controles de registro y cumplidos los requisitos del banco, puede incorporarse como cliente.
Auditor o responsable de Seguridad	Consulta los registros de auditoría para verificar quién realizó una operación, cuándo ocurrió y cuál fue su resultado. Revisa alertas y evidencias de seguridad mediante permisos de consulta, sin modificar los registros de auditoría protegidos.

4.2 El sistema y sus conexiones

La **Banca por Internet** comprende el canal web y la aplicación móvil del banco. La plataforma permite a los clientes acceder a los servicios digitales y se integra con ocho sistemas para consultar información, gestionar la identidad, procesar transferencias interbancarias y enviar notificaciones.

Las siguientes descripciones representan las relaciones funcionales de alto nivel. Los protocolos, las interfaces y la ruta técnica de cada integración deberán detallarse en los diagramas C2, C3 y de secuencia.

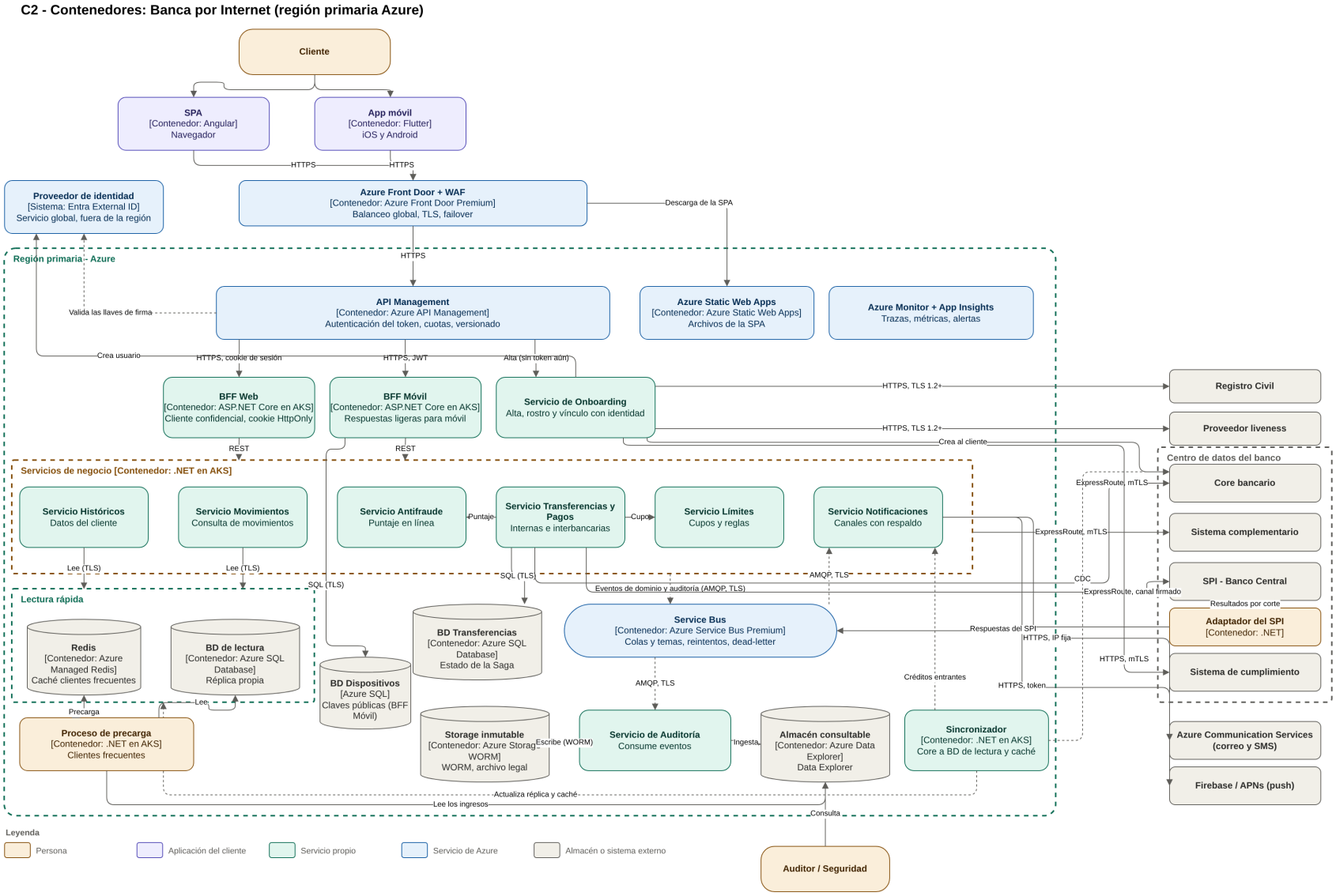
Sistema	Para qué se usa	Qué intercambian
Core bancario	Mantiene las cuentas, los saldos y los movimientos, y ejecuta las operaciones financieras que corresponden a su dominio.	Solicitudes de consulta y de operaciones financieras, junto con los datos y resultados necesarios para conocer su procesamiento y estado.
Sistema complementario	Proporciona información adicional del cliente que no se gestiona directamente en el Core, de acuerdo con las responsabilidades definidas para ese sistema.	Solicitudes de consulta y datos complementarios del cliente, conforme a los permisos y contratos de integración.
Sistema de cumplimiento	Revisa listas restrictivas y personas expuestas políticamente (PEP) del cliente nuevo, antes de crear su cuenta.	Datos de identificación del cliente nuevo y el resultado de la revisión.
Servicio de identidad	Gestiona la autenticación y los mecanismos de acceso de los clientes a los canales digitales.	Solicitudes de autenticación y validación, junto con tokens, atributos o resultados de identidad, según el protocolo implementado.
Registro Civil	Permite validar información de identidad mediante los servicios disponibles y autorizados para la institución, cuando existe una integración habilitada.	Datos de identificación y solicitudes de validación autorizadas, junto con los resultados de la consulta, de acuerdo con el servicio contratado.

Sistema	Para qué se usa	Qué intercambian
Servicio de prueba de vida	Evalúa si la captura biométrica corresponde a una persona real presente durante el proceso de registro, según las capacidades del proveedor.	Evidencias biométricas necesarias para la evaluación y el resultado de la prueba, de acuerdo con el servicio contratado y los controles de protección de datos.
Sistema de Pagos Interbancarios (SPI) del Banco Central del Ecuador	Canaliza transferencias interbancarias a través de las instituciones financieras participantes, conforme a los procedimientos del sistema.	Órdenes o mensajes de pago, referencias de operación y estados o resultados de procesamiento, según la interfaz y el mecanismo de integración utilizados por el banco.
Servicios de correo, SMS y notificaciones push	Envían comunicaciones al cliente relacionadas con movimientos, transferencias, alertas y otros eventos que requieren notificación.	Destinatarios, contenido autorizado y metadatos de envío. Según el canal y el proveedor, pueden recibirse estados de aceptación, entrega o error.

SECCIÓN 5

Modelo C4, nivel 2: Contenedores

> **Decisiones relacionadas:** D1, D2, D3, D4, D6, D13.



Los servicios que modifican datos publican sus eventos y su auditoría con Transactional Outbox; los de consulta publican directamente con reintento y se concilian con los registros de API Management; los inicios de sesión de Entra External ID se exportan al Servicio de Auditoría. Cada llamada externa usa Circuit Breaker, reintento y timeout (Polly o políticas de APIM). Redis se llena con Cache-Aside y el Sincronizador lo invalida. Transferencias y Pagos cubre ambos tipos de operación. El tráfico hacia el Core y el SPI viaja por ExpressRoute y los servicios de datos se publican solo con Private Endpoints (ver la Figura 16).

FIGURA 2 C2 Contenedores de la Banca por Internet

5.1 Descripción de los contenedores

El diagrama de contenedores (C2) muestra las aplicaciones y los almacenes de datos que forman la plataforma dentro de la región primaria, junto con los sistemas externos con los que se integra. Cada contenedor se identifica con la notación [Contenedor: tecnología]. La tabla resume su responsabilidad y la forma en que se comunica.

Contenedor [tecnología]	Responsabilidad	Comunicación
SPA [Contenedor: Angular]	Interfaz web del cliente. No almacena tokens: la sesión la mantiene el BFF Web mediante una cookie HttpOnly.	HTTPS hacia Azure Front Door; los archivos estáticos se descargan de Azure Static Web Apps.
App móvil [Contenedor: Flutter]	Interfaz móvil del cliente. Autenticación con Authorization Code y PKCE, y llave biométrica atada al dispositivo.	HTTPS con JWT hacia Azure Front Door y API Management.
Azure Front Door + WAF [Contenedor: servicio global de Azure]	Punto de entrada único: TLS, balanceo, filtrado de tráfico malicioso y conmutación hacia la región secundaria.	HTTPS hacia API Management y hacia Static Web Apps.
API Management [Contenedor: Azure API Management]	Validación de tokens, cuotas, versionado y publicación de las APIs de los BFF.	Ruta web: aplica WAF y límites de tasa sobre la cookie de sesión, sin validar token. Ruta móvil: valida el JWT. Consulta las llaves de firma de Entra External ID.
BFF Web y BFF Móvil [Contenedor: .NET en AKS]	Adaptan y agregan las respuestas de cada canal; el BFF Web actúa como cliente confidencial y el BFF Móvil verifica la prueba de posesión del dispositivo.	REST hacia los servicios de negocio; HTTPS hacia Entra External ID; SQL con TLS hacia la BD Dispositivos.
Servicios de negocio [Contenedor: .NET en AKS]	Transferencias y Pagos, Históricos, Movimientos, Antifraude, Límites, Notificaciones, Onboarding y Auditoría. Cada servicio es dueño de sus datos.	REST entre servicios; AMQP con Service Bus para eventos; SQL con TLS hacia sus bases.
Sincronizador [Contenedor: .NET en AKS]	Lleva los cambios del Core a la base de lectura y a la caché, e invalida las claves afectadas.	Lectura de eventos, API o CDC del Core; escritura en la base de lectura y en Redis.
Redis [Contenedor: Azure Managed Redis]	Caché de lectura de los clientes frecuentes (patrón Cache-Aside). Se puede reconstruir desde la base de lectura. Un proceso de precarga programado la llena cada madrugada con los clientes frecuentes.	TLS desde los servicios de consulta y desde el Sincronizador.
Bases de datos [Contenedor: Azure SQL Database]	Base de lectura (réplica propia), base de Transferencias (estado de la Saga y Outbox) y BD Dispositivos (claves públicas del BFF Móvil).	SQL con TLS desde el servicio propietario de cada base.
Service Bus [Contenedor: Azure Service Bus Premium]	Mensajería de eventos de dominio y de auditoría, reintentos y Dead-Letter Queue.	AMQP con TLS, con publicación mediante Transactional Outbox.
Auditoría [Contenedor: Storage WORM y Data Explorer]	Almacén inmutable de evidencia y almacén consultable para auditores y seguridad.	Escritura WORM desde el Servicio de Auditoría; consulta desde Data Explorer.

Contenedor [tecnología]	Responsabilidad	Comunicación
Entra External ID [Sistema: identidad]	Autenticación, MFA y emisión de tokens OAuth 2.0 / OpenID Connect.	HTTPS con SPA, app móvil, BFF y API Management.
Core, sistema complementario, SPI y otros [Sistemas externos]	Core bancario, sistema complementario, sistema de cumplimiento, SPI del Banco Central con su adaptador en el centro de datos, Registro Civil, proveedor de prueba de vida, ACS y Firebase/APNs.	Red privada con mTLS hacia Core y SPI; HTTPS con IP fija hacia los proveedores externos (ver 8.6).

5.2 Flujos principales entre contenedores

- **Consulta de movimientos:** el canal llama a Front Door, API Management y el BFF; el servicio de Movimientos responde desde Redis y, si no encuentra el dato, desde la base de lectura. El Core solo participa cuando el rango consultado queda fuera de la ventana de la réplica.
- **Transferencia interna:** el BFF invoca al servicio de Transferencias y Pagos, que consulta Antifraude y Límites y ejecuta una operación atómica en el Core con una clave de idempotencia.
- **Transferencia interbancaria:** el mismo servicio inicia una Saga con estado persistente, envía la orden al SPI y registra el resultado; los eventos de dominio se publican en Service Bus mediante Outbox.
- **Onboarding:** el alta entra por Front Door y API Management sin pasar por el BFF, porque aún no hay sesión; el servicio de Onboarding valida la identidad en el Registro Civil, la prueba de vida con el proveedor, la debida diligencia, crea el cliente en el Core y crea el usuario en Entra External ID.
- **Auditoría y notificaciones:** los servicios publican eventos en Service Bus; el Servicio de Auditoría los escribe en Storage WORM y Data Explorer, y el servicio de Notificaciones envía correo, SMS y push.

5.3 Clientes frecuentes y precarga de caché

Para efectos de este diseño, un cliente frecuente es el que inicia sesión al menos ocho veces en los últimos treinta días; el proceso de precarga obtiene este dato de la auditoría (Data Explorer), donde queda registrado cada ingreso. Este grupo, que se estima entre el 20 % y el 30 % de los clientes activos, concentra la mayor parte de las consultas y justifica mantener su información en Redis. El detalle se muestra en la Figura 6.

- **Precarga (cache warming):** un proceso programado carga cada madrugada en Redis el perfil y los últimos movimientos de los clientes frecuentes; los saldos se cargan al iniciar sesión, porque su TTL de cinco minutos vence antes del primer ingreso; además, el inicio de sesión de cualquier cliente dispara una carga anticipada de su información antes de que abra la pantalla de movimientos.
- **Invalidación:** cuando el Sincronizador recibe un cambio del Core, actualiza la base de lectura e invalida o reescribe las claves de las cuentas afectadas. Cada clave tiene además un TTL de cinco minutos para saldos y de quince minutos para el perfil.
- **Quién escribe en Redis:** el servicio de consulta lee Redis y, si el dato no está, lo lee de la base de lectura y lo guarda (Cache-Aside). El Sincronizador invalida o reescribe las claves de las cuentas afectadas y el proceso de precarga escribe los datos de los clientes frecuentes. Si Redis no responde, los servicios leen la base de lectura y la caché se reconstruye de forma gradual.
- **Organización de las claves:** los movimientos se guardan por páginas con claves por cursor (ancladas a un movimiento o a una fecha), no por número de página. Una transacción nueva solo invalida la primera página y las páginas antiguas no cambian, por lo que un cliente con muchas transacciones sigue benefi-

ciándose de la caché. Las cuentas de muy alta actividad no cachean la primera página o agrupan las invalidaciones en intervalos de pocos segundos.

SECCIÓN 6

Modelo C4, nivel 3: Componentes

6.1 Servicio Transferencias y Pagos

Descripción

El servicio centraliza el procesamiento de transferencias mediante un flujo común que incluye idempotencia, validaciones, límites transaccionales y controles antifraude. La estrategia de ejecución se selecciona según el tipo de transferencia.

- **Transferencias internas:** se coordina la operación con el Core bancario, buscando garantizar su ejecución atómica y obtener el resultado definitivo según las capacidades del sistema.
- **Transferencias interbancarias:** se coordina el procesamiento con el sistema de pagos correspondiente. Se gestionan los estados de la operación, los rechazos y las posibles reversas mediante asientos compensatorios, conservando la trazabilidad de la transacción original.

La implementación de la coordinación, las compensaciones y los mecanismos de recuperación se ajusta a las interfaces y capacidades de los sistemas involucrados.

Patrones y seguridad: Strategy por tipo de transferencia, Saga orquestada para las interbancarias, Transactional Outbox, Idempotency Key, Anti-Corruption Layer y Circuit Breaker. La entrada es HTTPS con JWT y validación de claims y nivel de autenticación; Antifraude y Límites se invocan por REST sobre HTTPS con Managed Identity; el Core y el SPI, por la red privada con mTLS; la mensajería, por AMQP sobre TLS; y Azure SQL, por conectividad privada y cifrada.

Consideraciones de diseño

Las transferencias internas e interbancarias deben distinguir claramente los estados de solicitud, procesamiento, aceptación y finalización. Ante resultados inciertos, el servicio deberá verificar el estado de la operación antes de reintentarla, evitando débitos duplicados.

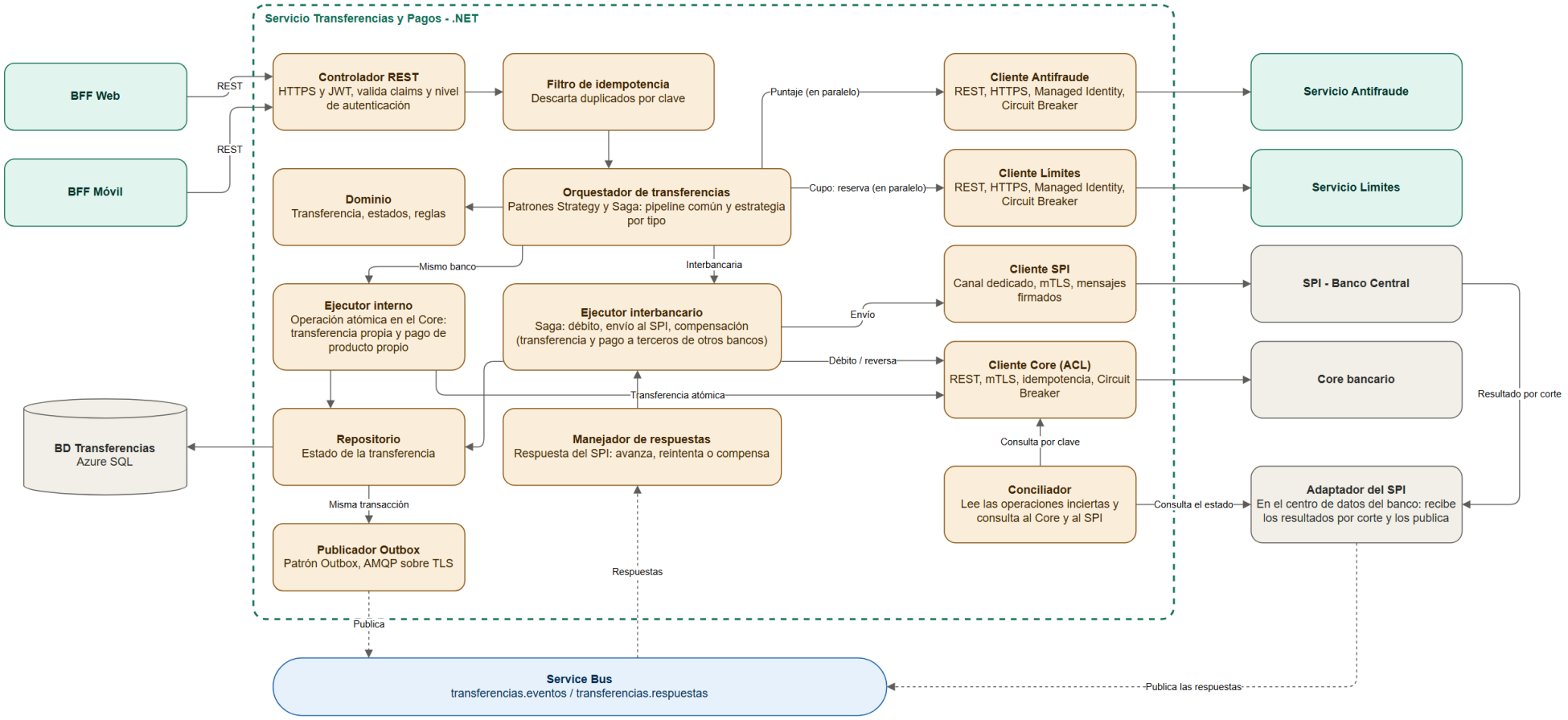
Las compensaciones financieras se ejecutarán mediante operaciones registradas y trazables; nunca se eliminará la transacción original.

- **Pagos:** el pago de un producto propio usa el Ejecutor interno (operación atómica en el Core) y el pago a un tercero de otro banco usa el Ejecutor interbancario (Saga por el SPI). Ambos comparten el filtro de idempotencia, el antifraude y los límites.
- **Límites y antifraude en paralelo:** ambas consultas se ejecutan al mismo tiempo. Límites reserva el cupo con una actualización condicional atómica; la reserva se confirma cuando el débito se aplica y se libera si el antifraude o el Core rechazan, o si la operación se reversa. Cada reserva vence a los 15 minutos: si el servicio cae antes de confirmarla, el Conciliador la libera, y si encuentra un débito aplicado con la reserva vencida, la confirma y genera una alerta. Así, dos transferencias simultáneas no pueden superar el cupo y ninguna reserva queda retenida.
- **Conciliador:** cuando una operación queda con resultado incierto, el Conciliador consulta el Core con la misma clave de idempotencia hasta conocer el resultado (sección 7.4). También libera las reservas de cupo vencidas.

- **Adaptador del SPI:** el SPI no publica en el Service Bus del banco. Un adaptador, desplegado en el centro de datos del banco, recibe los resultados por corte, los valida y los publica de forma idempotente en transferencias.respuestas. El Conciliador también consulta al SPI por su intermedio.

> **Decisiones relacionadas:** **D14**, **D15**, **D16**, **D20**, **D21**, **D33**, **D34**, **D35**.

C3 - Componentes: Servicio Transferencias y Pagos



Mismo banco: una sola operación atómica en el Core (o todo o nada), respuesta final inmediata, sin compensación. **Interbancaria:** Saga con atomicidad local en cada tramo; si el SPI rechaza, se compensa con un asiento de reversa (no se borra el original). En ambos casos se registra el estado, se publica el evento y se concilia periódicamente contra el Core y el SPI. **Límites:** reserva el cupo con una actualización condicional atómica; la reserva se confirma al completarse el débito y se libera si el antifraude o el Core rechazan, o si la operación se reversa. Dos transferencias simultáneas no pueden superar el cupo.

FIGURA 3 C3 Servicio Transferencias y Pagos

6.2 BFF y autenticación

Descripción

La arquitectura separa la gestión de sesiones del canal web y la autenticación de la aplicación móvil, utilizando Microsoft Entra External ID como proveedor de identidad propuesto.

- **BFF Web:** gestiona la sesión y mantiene los tokens en el servidor. Entrega al navegador una cookie de sesión con atributos HttpOnly, Secure y SameSite, y administra la renovación de tokens cuando corresponda.
- **BFF Móvil:** expone respuestas adaptadas a la aplicación, con paginación y campos necesarios. La aplicación móvil obtiene los tokens mediante el navegador del sistema utilizando OAuth 2.0 / OpenID Connect con Authorization Code y PKCE. El BFF valida los tokens recibidos sin almacenarlos y guarda en su propia base (BD Dispositivos, Azure SQL replicada con grupo de conmutación por error) la clave pública de cada dispositivo enrolado.
- **Proveedor de identidad:** autentica a los usuarios y emite los tokens según los flujos y permisos configurados.

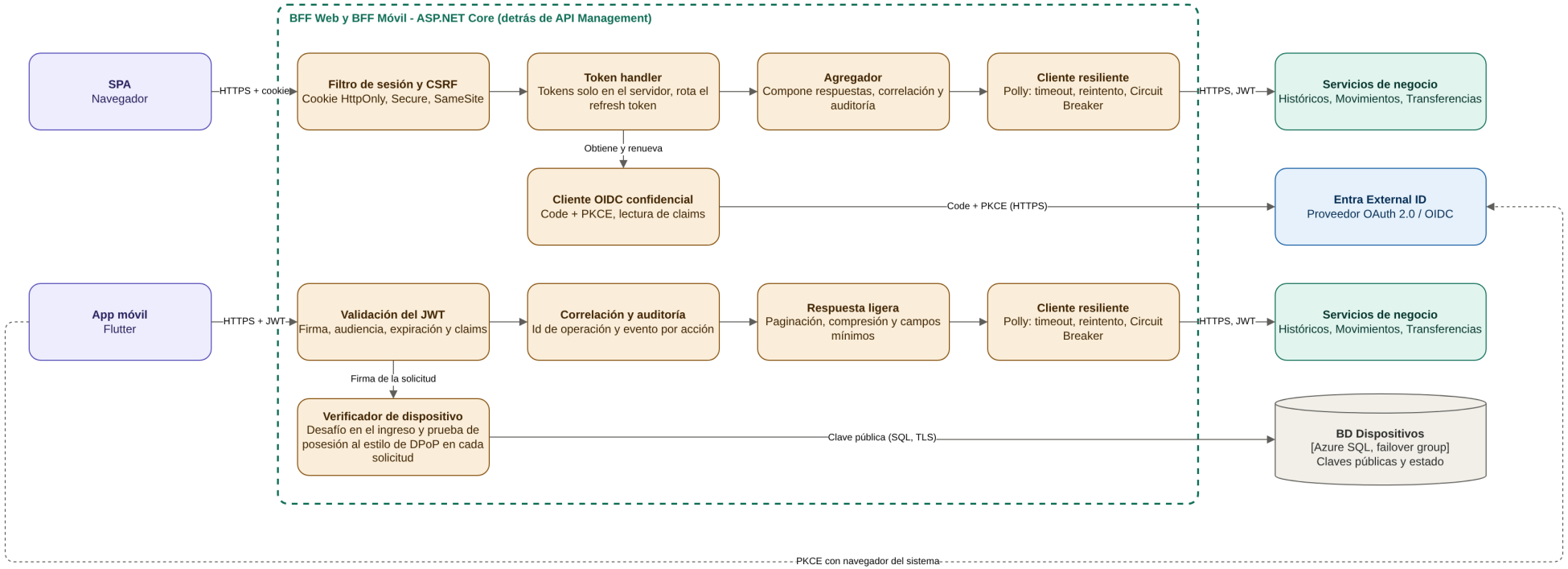
Patrones: BFF, Aggregator y Circuit Breaker. La comunicación es HTTPS, con OAuth 2.0 / OpenID Connect y validación de JWT.

Seguridad

- Los servicios validan el JWT que les reenvía el BFF, como defensa en profundidad.
- El BFF Web protege la sesión mediante cookies seguras y controles contra CSRF.
- **Prueba de posesión:** cada solicitud de la app al BFF Móvil lleva una prueba firmada con la llave del dispositivo, al estilo de DPoP (RFC 9449). La verifica el propio BFF contra la clave registrada: Entra External ID emite tokens normales y no los liga a la llave, por eso el BFF rechaza cualquier solicitud sin esa firma. Un access token o un refresh token robado no sirve sin el dispositivo.
- **API Management en cada ruta:** la web envía una cookie de sesión, por lo que API Management solo aplica WAF y límites de tasa y el BFF Web valida la sesión; el BFF obtiene el token y lo reenvía como JWT a los servicios. En la ruta móvil, API Management valida el JWT antes del BFF Móvil.
- **Confirmación de transferencias en la web:** el canal web no tiene llave del dispositivo. Cada transferencia exige un segundo factor por transacción: un step-up de MFA en Entra External ID o la aprobación desde la app vinculada, con el monto y la cuenta destino a la vista. El BFF Web solo envía la orden a Transferencias si el token incluye ese nivel de autenticación reciente.

> **Decisiones relacionadas:** D5, D7, D8, D9, D36.

C3 - Componentes: BFF Web y BFF Móvil (autenticación OAuth 2.0 con Authorization Code + PKCE)



Web (BFF como cliente confidencial): el navegador nunca ve los tokens; el BFF los guarda y entrega una cookie HttpOnly. API Management aplica WAF y cuotas sobre la cookie y el BFF Web valida la sesión. **Móvil (cliente público):** la app obtiene el token con Authorization Code + PKCE usando el navegador del sistema. API Management valida el JWT y el BFF lo revalida. El BFF Móvil exige además un desafío firmado por la llave del dispositivo en cada ingreso y en cada transferencia, y una prueba de posesión al estilo de DPoP en cada solicitud, verificada por el propio BFF: un token robado no sirve sin el dispositivo. En la web, cada transferencia exige un segundo factor (step-up de MFA). **Ambos:** el BFF reenvía el JWT a los servicios y cada acción emite un evento de auditoría. Se evitan los flujos Implicit y Password por estar desaconsejados por el estándar.

FIGURA 4 C3 BFF Web y BFF Móvil con autenticación OAuth 2.0

6.3 Servicios Históricos y Movimientos

Descripción

Los servicios permiten consultar históricos y movimientos mediante un modelo orientado a lectura, con caché para optimizar las consultas frecuentes.

- **Autorización:** se valida que la cuenta consultada pertenezca al cliente autenticado y que tenga permisos para acceder a la información.
- **Caché:** se consulta primero Redis mediante el patrón Cache-Aside. Si no existe información disponible, se obtiene desde la fuente correspondiente.
- **Selector de fuente:** utiliza una estrategia configurable para determinar el origen de los datos según el rango de fechas y el tipo de consulta.
- **Fuentes de información:** se contempla una réplica de lectura para históricos. El Core solo se consulta cuando el rango pedido queda fuera de la ventana de la réplica y para validar saldos al autorizar operaciones; el sistema complementario aporta el perfil y los detalles específicos de movimientos.
- **Sincronización:** un Servicio de Sincronización de Datos mantiene actualizada la información de lectura. La actualización o invalidación de la caché se realizará según el mecanismo de sincronización definido.

La disponibilidad de históricos de aproximadamente 13 meses y la distribución de consultas entre las fuentes se consideran criterios propuestos, sujetos a validación técnica.

Patrones y seguridad: CQRS, Cache-Aside, Strategy para elegir la fuente, Anti-Corruption Layer y Circuit Breaker. La entrada es HTTPS con JWT y autorización por objeto (la cuenta debe pertenecer al cliente); la réplica y Redis se acceden con TLS por conectividad privada, y el Core y el sistema complementario, por la red privada con mTLS.

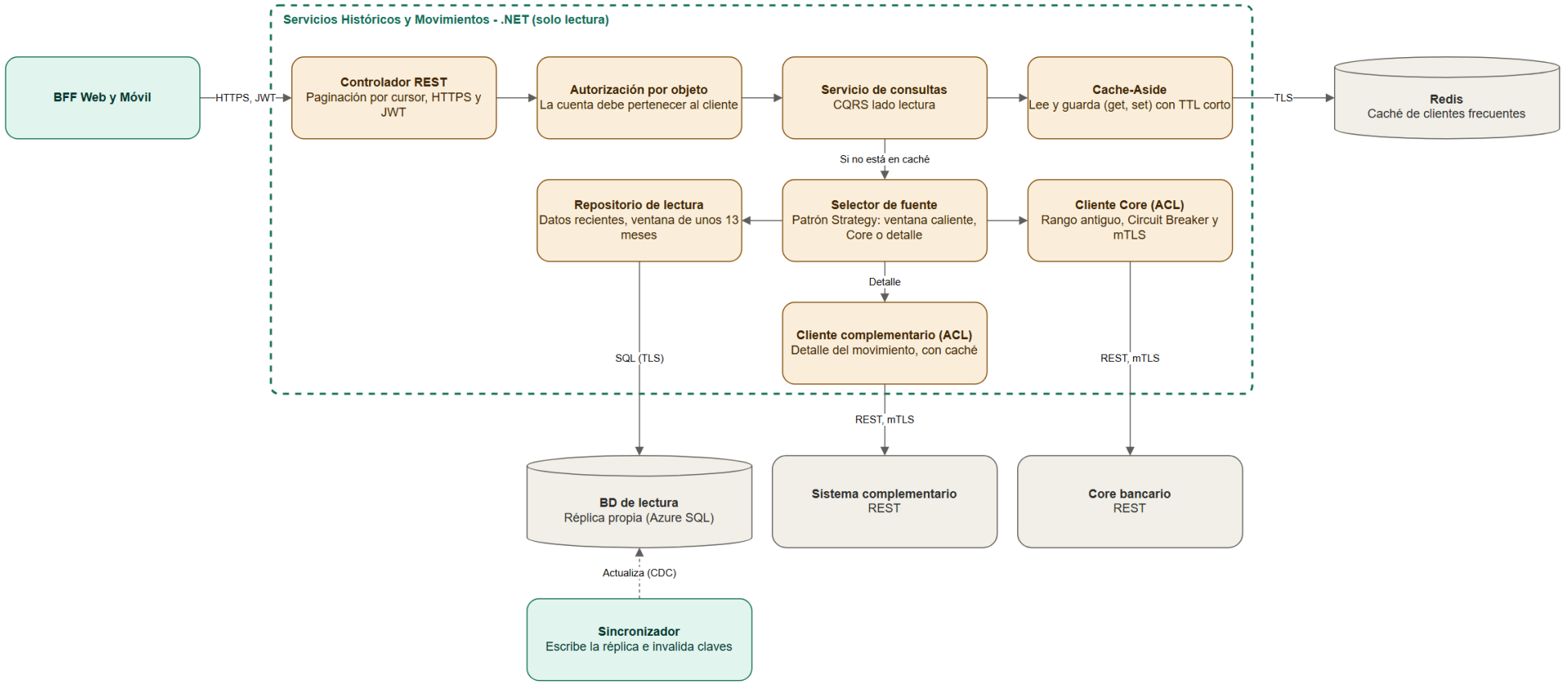
- **Perfil del cliente:** el servicio Históricos compone el perfil con dos fuentes: los datos maestros, productos y saldos, que provienen del Core a través de la base de lectura, y los datos complementarios (preferencias, contactos, beneficiarios y límites personalizados), que provienen del sistema complementario. El perfil compuesto se guarda en Redis con un TTL de quince minutos y se invalida cuando cambia cualquiera de las dos fuentes.
- **Frontera de los servicios:** Históricos atiende el perfil y los saldos del cliente, y Movimientos atiende los movimientos paginados y su detalle. Comparten la base de lectura y la caché, pero se despliegan y escalan por separado porque su carga es distinta.

> **Decisiones relacionadas:** D17, D18, D32.

6.3.1 Componentes de la precarga y la invalidación

La Figura 6 muestra los componentes que implementan la política de la sección 5.3. El servicio de consulta lee primero Redis y, si el dato no está, lo toma de la base de lectura y lo guarda (Cache-Aside). Cada madrugada, el proceso de precarga identifica a los clientes con ocho o más ingresos en treinta días a partir de la auditoría en Data Explorer y carga su perfil y sus últimos movimientos; al iniciar sesión se precargan los saldos. El Sincronizador invalida o reescribe las claves afectadas cuando el Core informa un cambio.

C3 - Componentes: Servicios Históricos y Movimientos (CQRS lado lectura + Cache-Aside)



Patrones: CQRS (la lectura usa un modelo propio y no el transaccional), Cache-Aside, Strategy (selecciona la fuente), Anti-Corruption Layer y Circuit Breaker.

FIGURA 5 C3 Servicios Históricos y Movimientos

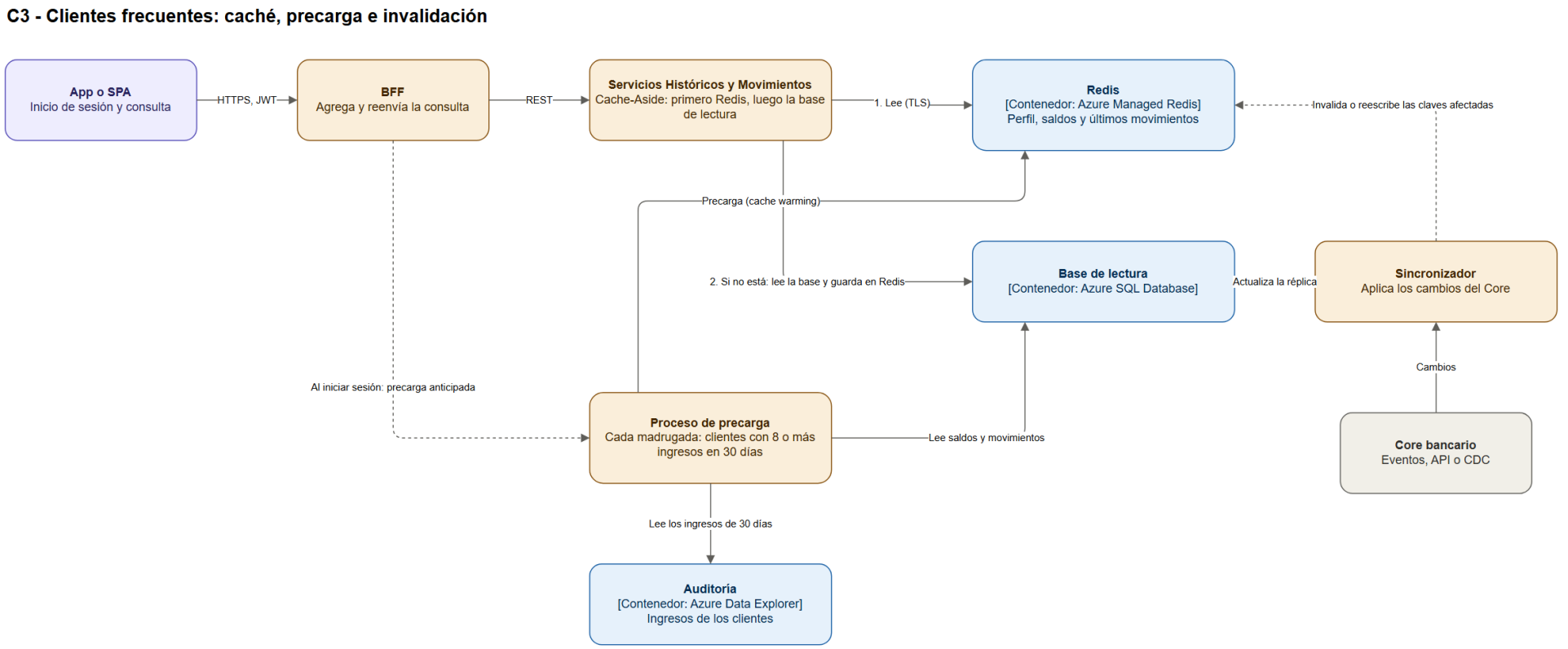


FIGURA 6 C3 Clientes frecuentes: caché, precarga e invalidación

6.4 Servicio de Onboarding

Descripción

El servicio coordina el proceso de registro de nuevos clientes mediante una secuencia de validaciones y pasos controlados por un orquestador. El flujo contempla la captura de datos y documento de identidad, la verificación de identidad, la prueba de vida, la creación de la identidad digital y el enrolamiento del dispositivo.

Si ocurre un fallo, el proceso registra el estado y aplica las acciones de recuperación correspondientes. Las compensaciones dependerán del paso ejecutado y de las capacidades de los sistemas involucrados.

- **Integración con proveedores:** los adaptadores del servicio de verificación de identidad y de prueba de vida se aíslan mediante una capa anticorrupción, facilitando el cambio de proveedor.
- **Gestión de identidad:** se contempla la integración con Microsoft Entra External ID para crear la identidad digital y configurar los mecanismos de autenticación requeridos.
- **Repositorio de estado:** registra los intentos, resultados y evidencias mínimas necesarias para la trazabilidad del proceso.

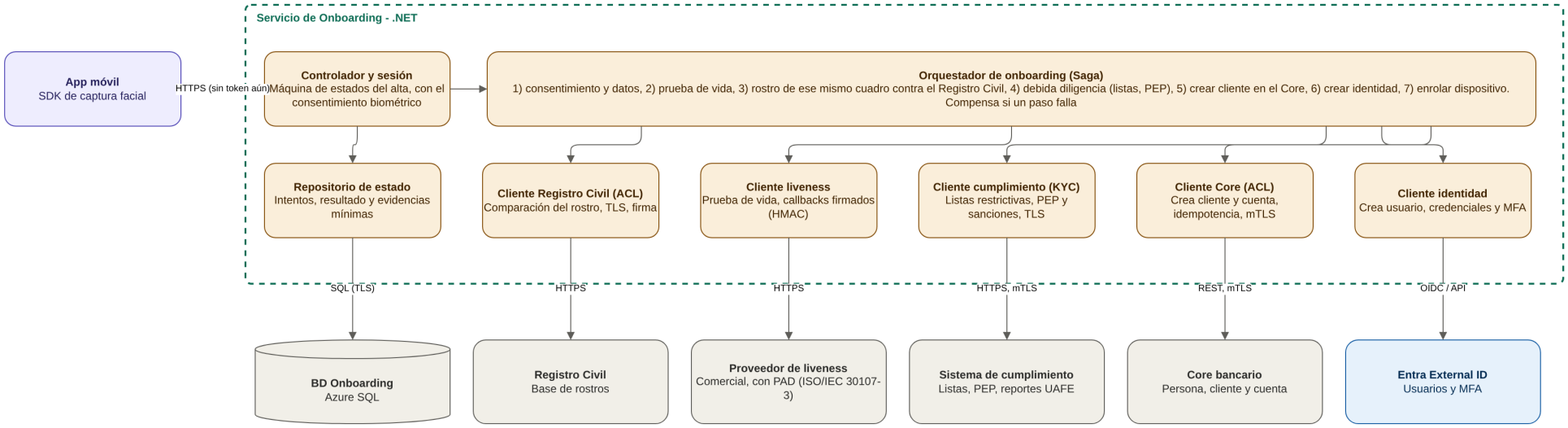
Patrones y seguridad: Saga orquestada con máquina de estados y Anti-Corruption Layer hacia los proveedores. El endpoint de registro usa HTTPS, límite de tasa y atestación del dispositivo; los callbacks del proveedor se validan con firma (HMAC); las imágenes y evidencias biométricas se cifran, se minimizan y se eliminan según la política de conservación.

La verificación documental, la comparación facial y la prueba de vida son controles diferenciados y siguen esta secuencia: consentimiento para el tratamiento de datos biométricos, prueba de vida, comparación de ese mismo cuadro con el Registro Civil, debida diligencia y creación del cliente.

- **Proveedor de verificación facial y prueba de vida:** se adopta una solución comercial especializada, en lugar de un desarrollo propio, que cuente con detección de ataques de presentación evaluada según ISO/IEC 30107-3 (por ejemplo, niveles 1 y 2 de iBeta), SDK para Flutter, soporte en Latinoamérica y precio por verificación. La preselección incluye FaceTec, Veridas, Facephi, Jumio, Onfido y Azure AI Face. El servicio de Onboarding accede al proveedor a través de un adaptador (Strategy), de modo que cambiarlo no afecta al resto del flujo.
- **Debida diligencia (KYC):** antes de crear el cliente, el servicio consulta el sistema de cumplimiento del banco para verificar listas restrictivas, personas expuestas políticamente (PEP) y sanciones. Si hay coincidencia, el trámite pasa a revisión manual y no se crea la cuenta. Los reportes que exige la UAFE los emite el área de Cumplimiento a partir de los eventos de auditoría del trámite.
- **Creación del cliente en el Core:** una vez aprobada la debida diligencia, el servicio invoca la API del Core para crear la persona, el cliente y la cuenta inicial con una clave de idempotencia igual al identificador del trámite. El Core es dueño del número de cliente; Onboarding conserva solo el estado del trámite y las evidencias cifradas.
- **Estados del trámite:** Consentimiento otorgado, Prueba de vida superada, Identidad verificada con el mismo cuadro, Debida diligencia aprobada, Cliente creado en el Core, Credenciales creadas (contraseña y MFA) y Activo; además, Rechazado y En revisión manual.

> **Decisiones relacionadas:** D10.

C3 - Componentes: Servicio de Onboarding (reconocimiento facial y alta de identidad)



Flujo: el cliente acepta el tratamiento de sus datos biométricos y captura su cédula. El proveedor de liveness confirma que es una persona real y entrega un cuadro certificado; el orquestador compara ese mismo cuadro con el Registro Civil, realiza la debida diligencia (listas y PEP), crea el cliente en el Core y crea la identidad en Entra External ID, donde el cliente define su contraseña (primer factor). Al terminar, la app genera una llave en el dispositivo (Keychain o Keystore), protegida por huella o rostro, y registra su clave pública en el BFF Móvil (segundo factor). **Seguridad:** endpoint de onboarding limitado por tasa y protegido con atestación del dispositivo, no se guardan imágenes más tiempo del necesario (protección de datos personales), y cada paso queda en auditoría. **Supuestos de diseño:** el proveedor de liveness es una solución comercial con detección de ataques de presentación certificada, detrás de un adaptador; el Core crea la persona, el cliente y la cuenta con una clave de idempotencia igual al identificador del trámite, y el sistema de cumplimiento del banco entrega el resultado de listas restrictivas y PEP.

FIGURA 7 C3 Servicio de Onboarding

6.5 Servicios de Auditoría y Notificaciones

Descripción

La arquitectura contempla dos consumidores independientes de eventos publicados en Azure Service Bus, cada uno con su propia suscripción.

- **Servicio de Auditoría:** consume los eventos de forma idempotente, normaliza su estructura y enmascara datos sensibles. Los registros se almacenan en Azure Storage con políticas de inmutabilidad para conservar evidencias y en Azure Data Explorer para facilitar consultas e investigaciones.
- **Servicio de Notificaciones:** consume los eventos, genera mensajes mediante plantillas y considera las preferencias del cliente. Un selector de canal determina el medio de envío y permite aplicar alternativas cuando un proveedor no está disponible. Se contemplan correo electrónico, SMS y notificaciones push mediante los proveedores correspondientes.

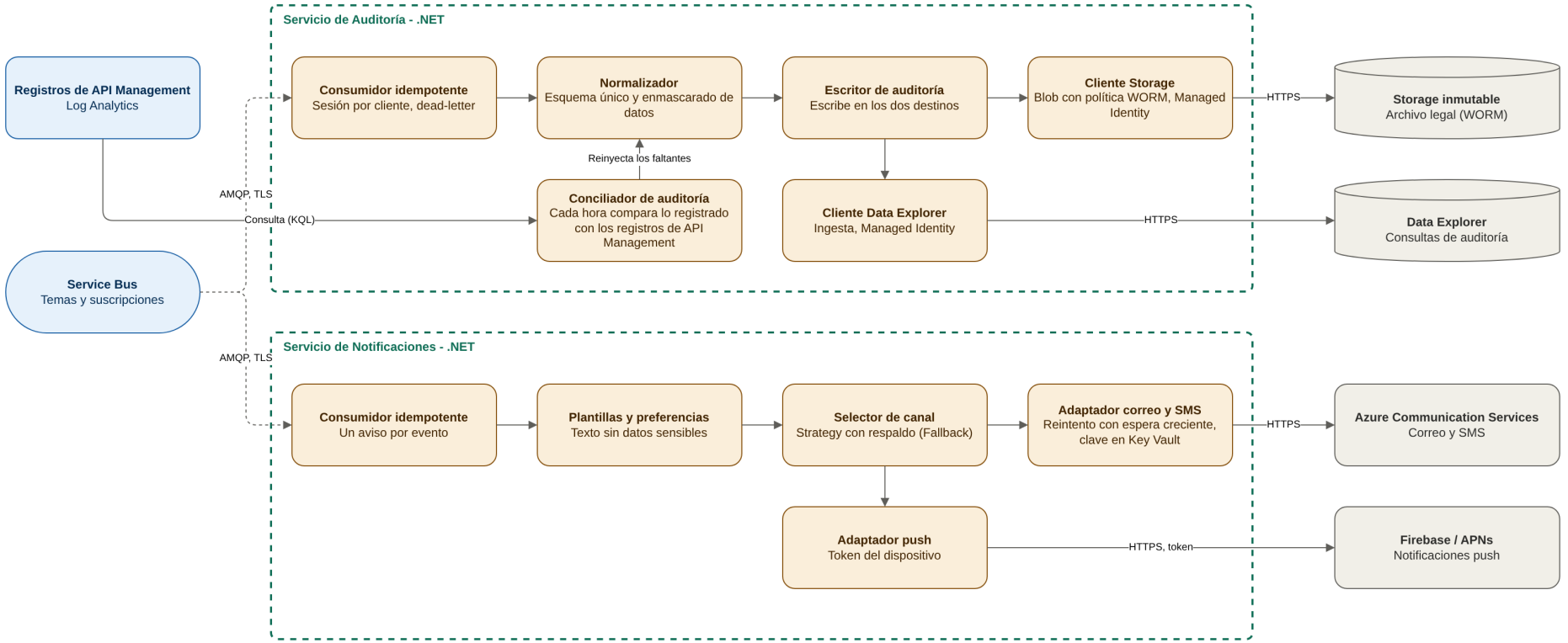
Patrones y seguridad: Publish-Subscribe, Idempotent Consumer, Dead-Letter Queue, Strategy con Fallback para el canal y reintentos con espera creciente. La mensajería es AMQP sobre TLS, el acceso a Azure usa Managed Identity, las credenciales de los proveedores viven en Key Vault y ninguna notificación incluye datos financieros o personales sensibles.

La entrega de una notificación no constituye confirmación de que una operación financiera se haya completado.

- **Garantía de la auditoría:** los servicios que modifican datos (Transferencias y Pagos, Límites y Onboarding) escriben sus eventos de auditoría con Transactional Outbox, en la misma transacción que su operación. Los servicios de consulta (Históricos y Movimientos) no tienen transacción de escritura ni base propia: publican el evento directamente en Service Bus, con reintento y un búfer local, sin sumar una escritura a la consulta. Un proceso horario concilia esos eventos por identificador de correlación contra los registros de API Management, por donde pasan todas las solicitudes, y reconstruye los que falten. Los registros de inicio de sesión de Entra External ID se exportan al servicio de Auditoría y se concilian de la misma forma.

> **Decisiones relacionadas:** D13, D19, D26.

C3 - Componentes: Servicios de Auditoría y de Notificaciones (consumidores de eventos)



Auditoría: registra todas las acciones del cliente (login, consultas, transferencias) a partir de los eventos de BFF, servicios e identidad. Storage con política WORM es el archivo legal no modificable; Data Explorer permite investigar. Los mensajes con error van a dead-letter y generan alerta. **Notificaciones:** mínimo dos canales; si uno falla, el selector usa el otro. También avisa los créditos entrantes detectados por el CDC. Ningún aviso incluye datos sensibles. **Conciliación:** los servicios de consulta publican sin Outbox; cada hora el conciliador compara los eventos con los registros de API Management y reinyecta los faltantes como registros reconstruidos.

FIGURA 8 C3 Servicios de Auditoría y Notificaciones

6.6 SPA (Frontend Web)

Descripción

La aplicación web se implementará como una SPA con Angular, organizada en componentes de interfaz, gestión de estado mediante NgRx cuando sea necesario, servicios de comunicación con el BFF, interceptores HTTP, guards de navegación, módulos con carga diferida, formularios reactivos y telemetría.

Patrones y seguridad: componentes standalone con módulos de carga diferida, estado centralizado con NgRx (solo datos no sensibles), servicios de datos tipados hacia el BFF, interceptores HTTP (CSRF, correlación, errores y reintento seguro) y guardas de ruta por sesión y nivel de autenticación. La SPA habla solo con el BFF Web por HTTPS con cookie HttpOnly.

Justificación tecnológica

Se propone Angular por su estructura definida, integración con TypeScript, inyección de dependencias y herramientas de pruebas, características que favorecen la mantenibilidad y el trabajo en equipos grandes. React fue considerado como alternativa por su flexibilidad, aunque requiere definir más decisiones de arquitectura y herramientas complementarias.

Seguridad

La SPA no almacenará tokens de acceso ni de renovación; la gestión de sesión estará a cargo del BFF mediante cookies configuradas con HttpOnly, Secure y SameSite. Se aplicarán políticas de seguridad de contenido (CSP), protección contra ataques XSS, auditoría de dependencias y análisis de vulnerabilidades en el pipeline de CI/CD. Trusted Types, nonces y Subresource Integrity se utilizarán cuando sean compatibles con la implementación y las dependencias.

> **Decisiones relacionadas:** D12, D30, D37.

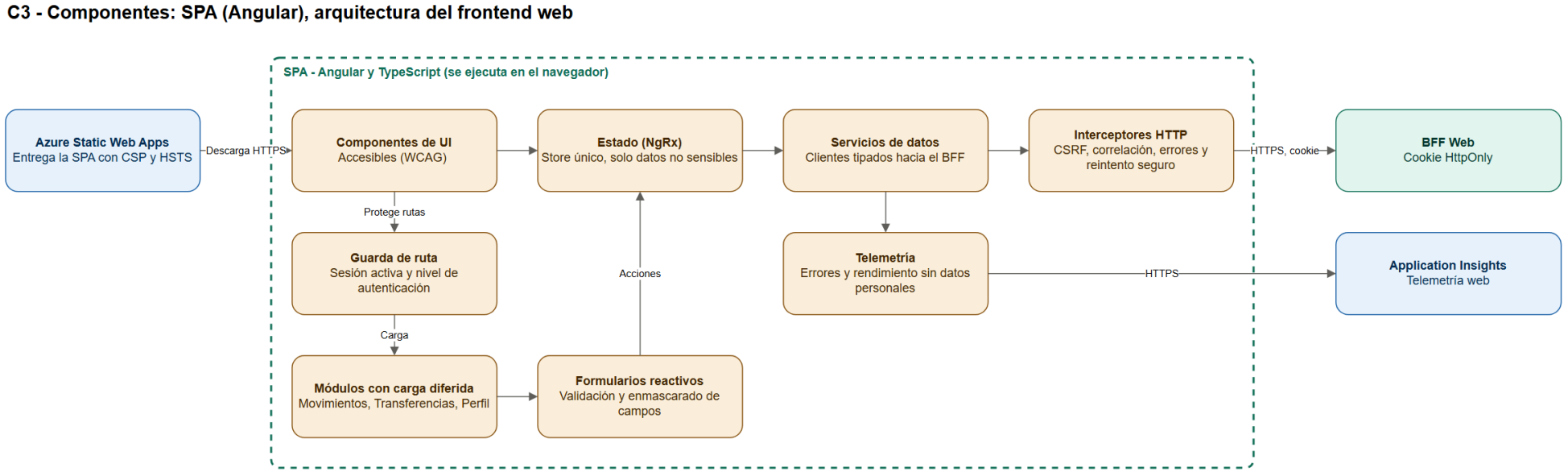


FIGURA 9 C3 SPA Angular

6.7 Aplicación móvil

Descripción

La aplicación móvil se desarrollará con Flutter y se organizará en capas de presentación, casos de uso y acceso a datos, siguiendo los principios de Clean Architecture y utilizando BLoC para la gestión de estado.

Se contemplan componentes para autenticación, onboarding, consultas, transferencias, notificaciones push y controles de seguridad del dispositivo.

Patrones y seguridad: Clean Architecture con BLoC por pantalla, casos de uso y Repository con caché local cifrada; cliente HTTP con interceptores, certificate pinning y prueba de posesión al estilo de DPoP; autenticación con AppAuth (Code + PKCE). La app habla solo con el BFF Móvil por HTTPS con JWT.

Comparación de frameworks multiplataforma

Criterio	Flutter	React Native	Kotlin Multiplatform
Código compartido	Lógica e interfaz	Lógica e interfaz, con integración nativa cuando se requiere	Principalmente lógica de negocio; la interfaz puede ser nativa
Interfaz	Renderizado mediante su propio motor	Componentes nativos	Interfaz nativa o multiplataforma según la solución
Rendimiento	Alto, con compilación nativa en producción	Bueno, según la implementación	Alto, con integración nativa
Seguridad móvil	Plugins para biometría y almacenamiento seguro	Bibliotecas disponibles para controles equivalentes	Integración directa con APIs nativas
Comunidad	Amplia y en crecimiento	Amplia comunidad JavaScript	Más especializada en Kotlin
Curva de aprendizaje	Requiere conocer Dart	Menor si el equipo domina JavaScript o React	Requiere conocimientos de Kotlin y plataformas móviles
Consideraciones	Dependencia del motor de renderizado y sus herramientas	Dependencia de bibliotecas y compatibilidad entre versiones	Mayor participación de desarrollo específico por plataforma

También se consideró .NET MAUI, que se descarta porque Flutter cubre los requisitos con una sola base de código.

Justificación tecnológica

Se adopta Flutter por la posibilidad de compartir la interfaz y la lógica entre Android e iOS, mantener una experiencia visual consistente y estructurar el código mediante componentes reutilizables (D11).

Seguridad móvil

- **Autenticación:** OAuth 2.0 / OpenID Connect con Authorization Code y PKCE.
- **Almacenamiento:** tokens y datos sensibles en Keychain o Keystore mediante mecanismos seguros de la plataforma.

- **Integridad del dispositivo:** detección de root o jailbreak y atestación del dispositivo.
- **Comunicación:** HTTPS y validación de certificados; certificate pinning en la app móvil, con certificados de respaldo para su renovación.
- **Protección de la aplicación:** ofuscación cuando corresponda, gestión segura de secretos y análisis de vulnerabilidades.
- **Pantallas sensibles:** aplicar controles de privacidad frente a capturas de pantalla cuando la plataforma lo permita y los requisitos lo justifiquen.
- **Biometría:** utilizar los mecanismos nativos para desbloqueo local, sin sustituir los controles de autenticación y autorización del servidor.

> **Decisiones relacionadas:** D9, D11, D37.

C3 - Componentes: App móvil (Flutter), arquitectura por capas y seguridad del dispositivo

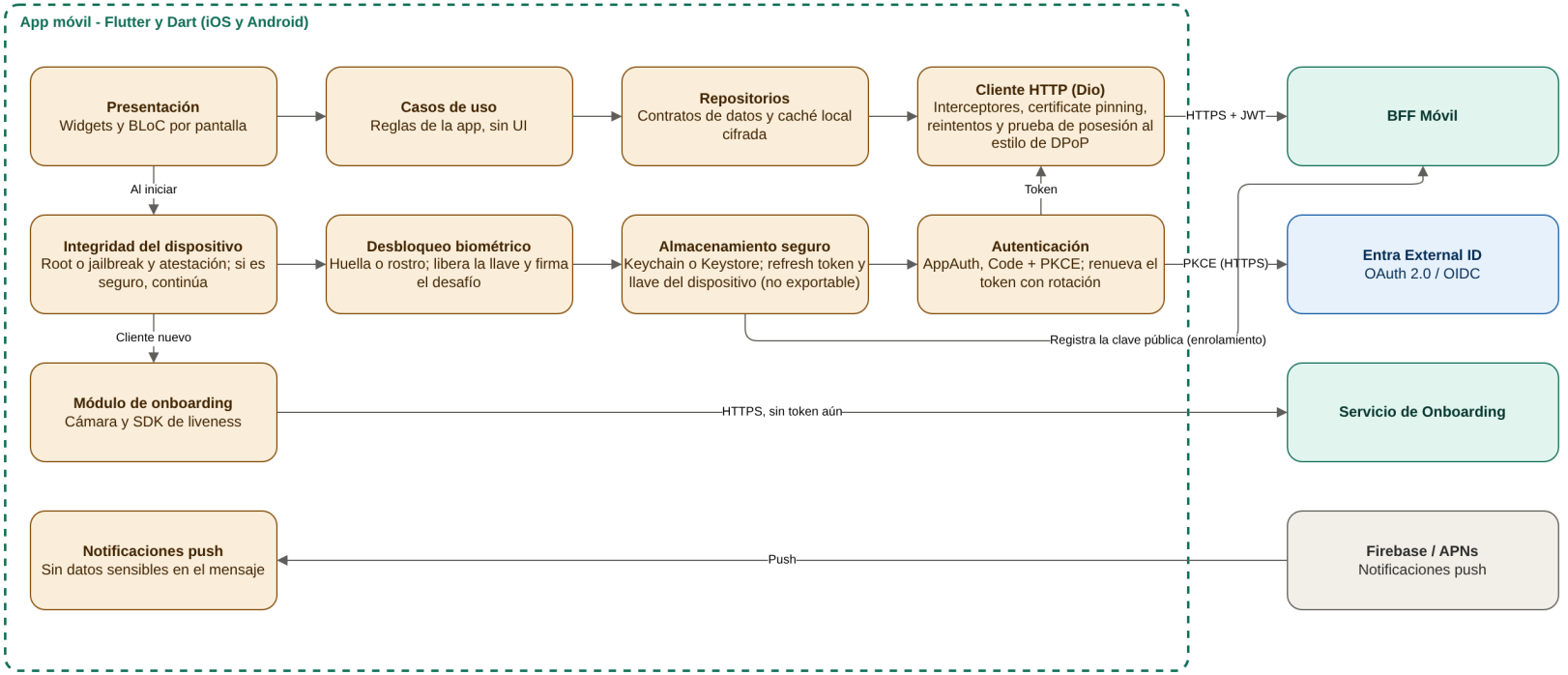


FIGURA 10 C3 Aplicación móvil Flutter

SECCIÓN 7

Diagramas de secuencia y flujos

7.1 Consulta del histórico de movimientos

Descripción del flujo

1. **Autorización:** el servicio valida que la cuenta consultada pertenezca al cliente autenticado antes de acceder a la información.
2. **Consulta de caché:** busca los movimientos en Redis. Si existen datos vigentes, los devuelve directamente.
3. **Consulta de réplica:** si no hay datos en caché, consulta la réplica de lectura para el período disponible y almacena el resultado en Redis con un TTL definido.
4. **Consulta al Core:** si el rango solicitado no está disponible en la réplica, consulta el Core mediante el mecanismo de integración disponible, aplicando controles de resiliencia.
5. **Respuesta:** devuelve los movimientos e indica la fecha y hora de actualización de la información cuando exista posibilidad de retraso en la réplica.
6. **Auditoría:** publica el evento directamente en Service Bus, con reintento y sin bloquear la respuesta. La conciliación con los registros de API Management asegura que ninguna consulta quede sin registrar (sección 6.5).

> **Decisiones relacionadas:** D17, D18, D32.

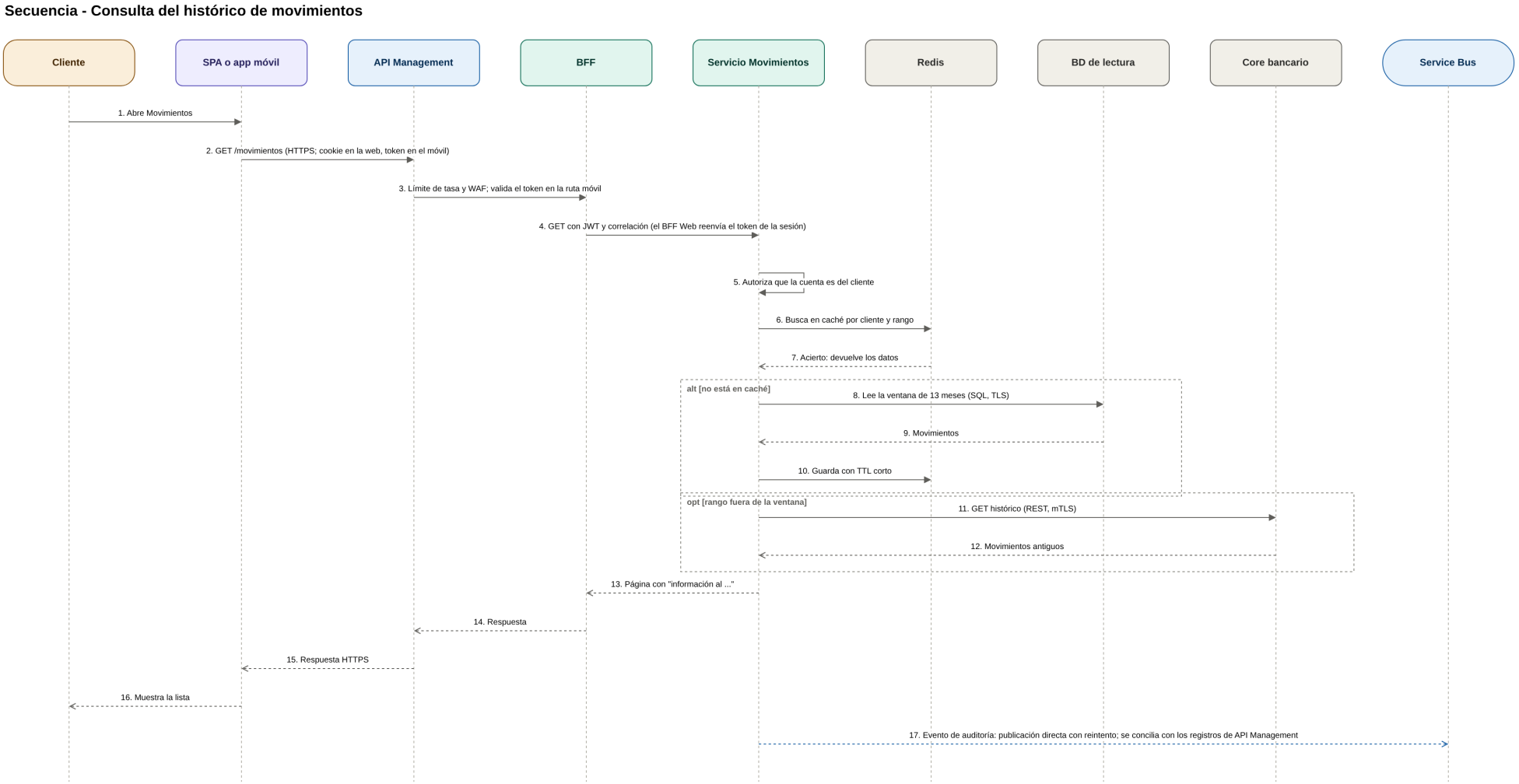


FIGURA 11 Secuencia de la consulta del histórico de movimientos

7.2 Transferencia entre cuentas del mismo banco

Descripción del flujo

1. **Recepción de la solicitud:** el servicio recibe la transferencia con una clave de idempotencia para evitar duplicados ante reintentos o solicitudes repetidas.
2. **Validaciones:** verifica la identidad, los permisos sobre las cuentas, los datos de la transferencia y los límites transaccionales, y consulta los controles antifraude. También verifica la autorización reforzada: en la app, la firma del desafío con la llave del dispositivo; en la web, el segundo factor por transacción (sección 6.2).
3. **Ejecución:** solicita al Core bancario la transferencia entre las cuentas. Se espera que el débito y el crédito se ejecuten como una única operación atómica, sujeto a las capacidades confirmadas del Core.
4. **Confirmación:** devuelve el resultado de la operación y genera el comprobante cuando el Core confirma su ejecución.
5. **Eventos posteriores:** publica los eventos necesarios para auditoría y notificaciones mediante procesamiento asíncrono, sin comprometer la trazabilidad de la operación.

Consideraciones

- La clave de idempotencia debe asociarse al resultado de la solicitud para evitar ejecuciones duplicadas.
- Si ocurre un tiempo de espera o se pierde la conexión con el Core, el servicio debe verificar el resultado antes de reintentar la operación.
- La transferencia solo se presentará como completada cuando exista confirmación de su ejecución.
- La atomicidad del débito y crédito, el soporte de idempotencia y el mecanismo de consulta del resultado deberán validarse con el equipo responsable del Core.

> **Decisiones relacionadas:** D9, D15, D16, D20, D21.

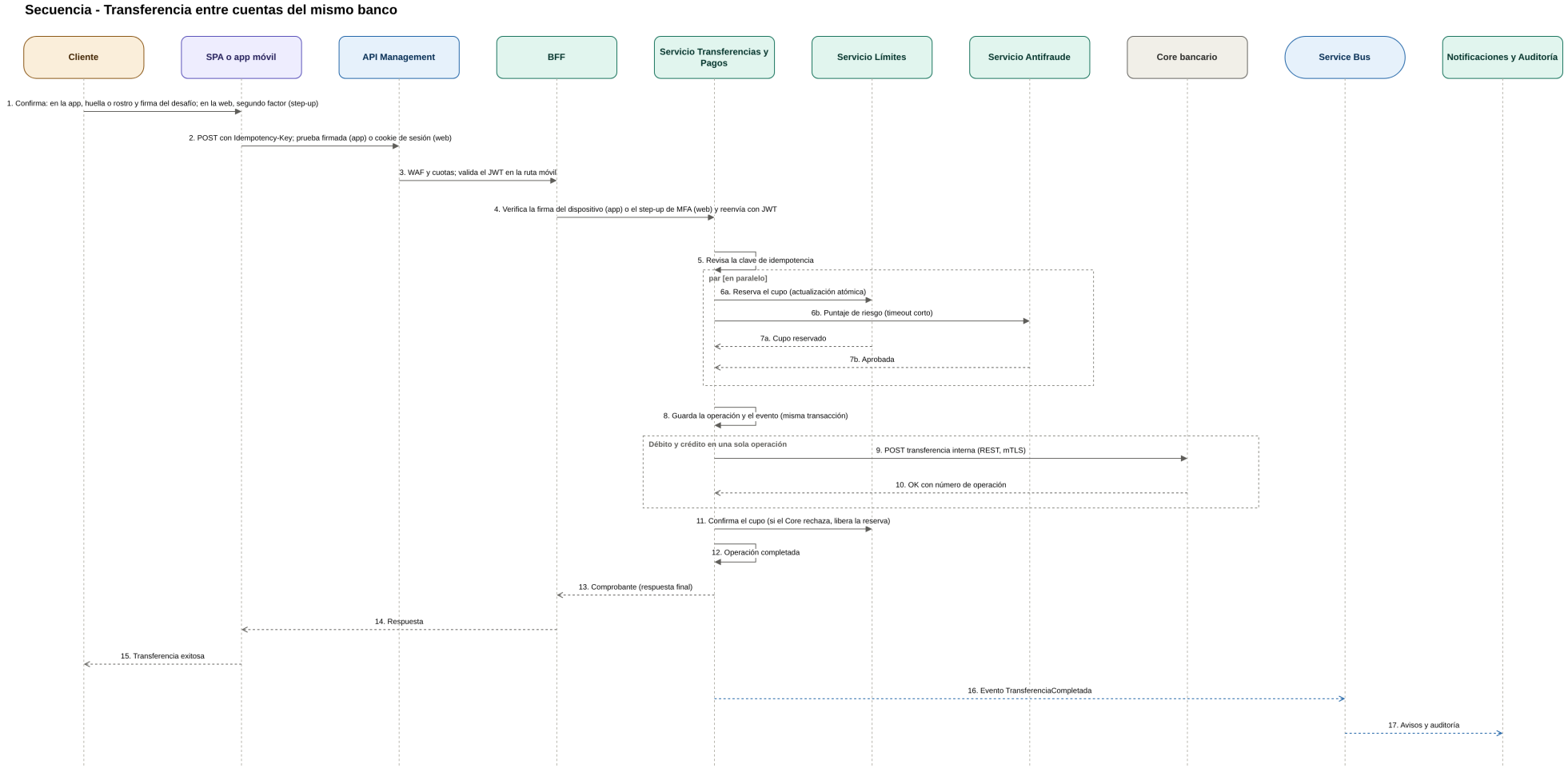


FIGURA 12 Secuencia de la transferencia interna

7.3 Transferencia a otro banco

El flujo de transferencia interbancaria contempla los siguientes pasos:

1. **Validación y débito:** el servicio valida la identidad, la autorización reforzada del cliente (firma del dispositivo en la app o segundo factor por transacción en la web, sección 6.2), los permisos sobre la cuenta de origen, los límites y las reglas antifraude. Una vez aprobada la operación, solicita el débito al Core y registra el estado de la transferencia.
2. **Envío al SPI:** se genera y envía la instrucción de transferencia mediante el componente autorizado, aplicando los mecanismos de autenticación, integridad y trazabilidad definidos para la integración.
3. **Respuesta al cliente:** mientras se espera la confirmación del SPI, la operación se presenta como **En proceso**, con una referencia que permita consultar su estado.
4. **Procesamiento asíncrono:** cuando el adaptador del SPI publica el resultado del corte en Service Bus, el Manejador de respuestas actualiza el estado de la transferencia. Si es aceptada, se completa la Saga; si es rechazada, se gestiona la reversa mediante un asiento compensatorio en el Core, conservando el registro original, y se libera el cupo.
5. **Auditoría y notificaciones:** cada cambio de estado genera un evento para los servicios de auditoría y notificaciones, con mecanismos que eviten duplicidades y permitan recuperar eventos fallidos.
6. **Conciliación:** un proceso periódico contrasta las operaciones registradas en la Saga con la información del Core y del SPI, identificando diferencias y operaciones pendientes de resolución.

Consideraciones: los tiempos de respuesta y liquidación dependen de las reglas operativas del SPI. Ante un timeout o una respuesta incierta, se debe consultar el estado de la operación antes de reenviar la instrucción o ejecutar una reversa, evitando débitos o transferencias duplicadas. El mecanismo de confirmación, la idempotencia, las reversas y la conciliación deben validarse con las interfaces y reglas disponibles del Core y del SPI.

> **Decisiones relacionadas:** D14, D16, D20, D21.

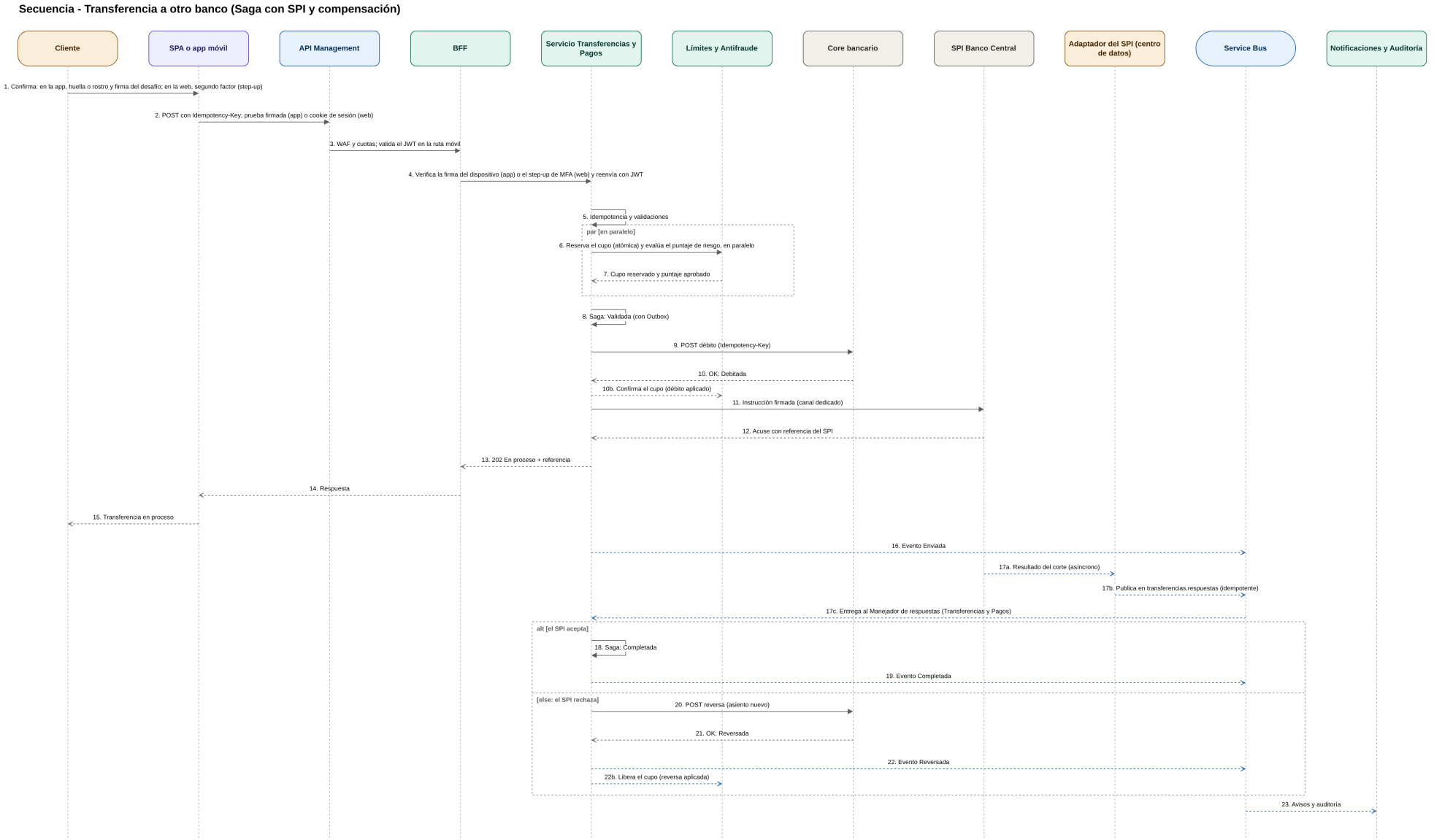


FIGURA 13 Secuencia de la transferencia interbancaria

7.4 Secuencia del resultado incierto

Cuando el Core no responde dentro del tiempo de espera de cinco segundos, la operación no se trata como una falla. No se sabe si el débito se aplicó, por lo que reintentar con otra clave podría duplicarlo.

- **Estado incierto:** la Saga registra el resultado como incierto y el cliente recibe una respuesta 202 de transferencia en verificación con su número de referencia.
- **Conciliación:** cada 30 segundos y hasta 10 minutos, el Conciliador consulta al Core y al SPI con la misma clave de idempotencia. Si el débito existe, la Saga continúa con el envío al SPI. Si el Core confirma que no lo registró, la operación se cancela, se libera el cupo y se avisa al cliente, sin reintentar el débito, porque su intención pudo haber cambiado.
- **Débito tardío:** antes de cancelar, el Conciliador pide al Core que anule la clave de idempotencia, de modo que una solicitud original retrasada sea rechazada. Si el Core no admite la anulación y aparece un débito posterior a la cancelación, el Conciliador lo reversa con un asiento compensatorio y avisa al cliente.
- **Escalamiento:** si pasan 10 minutos sin resultado, la operación pasa a revisión manual, se alerta a Operaciones y todo queda registrado en auditoría.
- **Aviso al cliente:** al conocerse el resultado final se publican los eventos de la transferencia y el servicio de Notificaciones avisa al cliente.

> **Decisiones relacionadas:** D15, D16, D20, D21, D35.

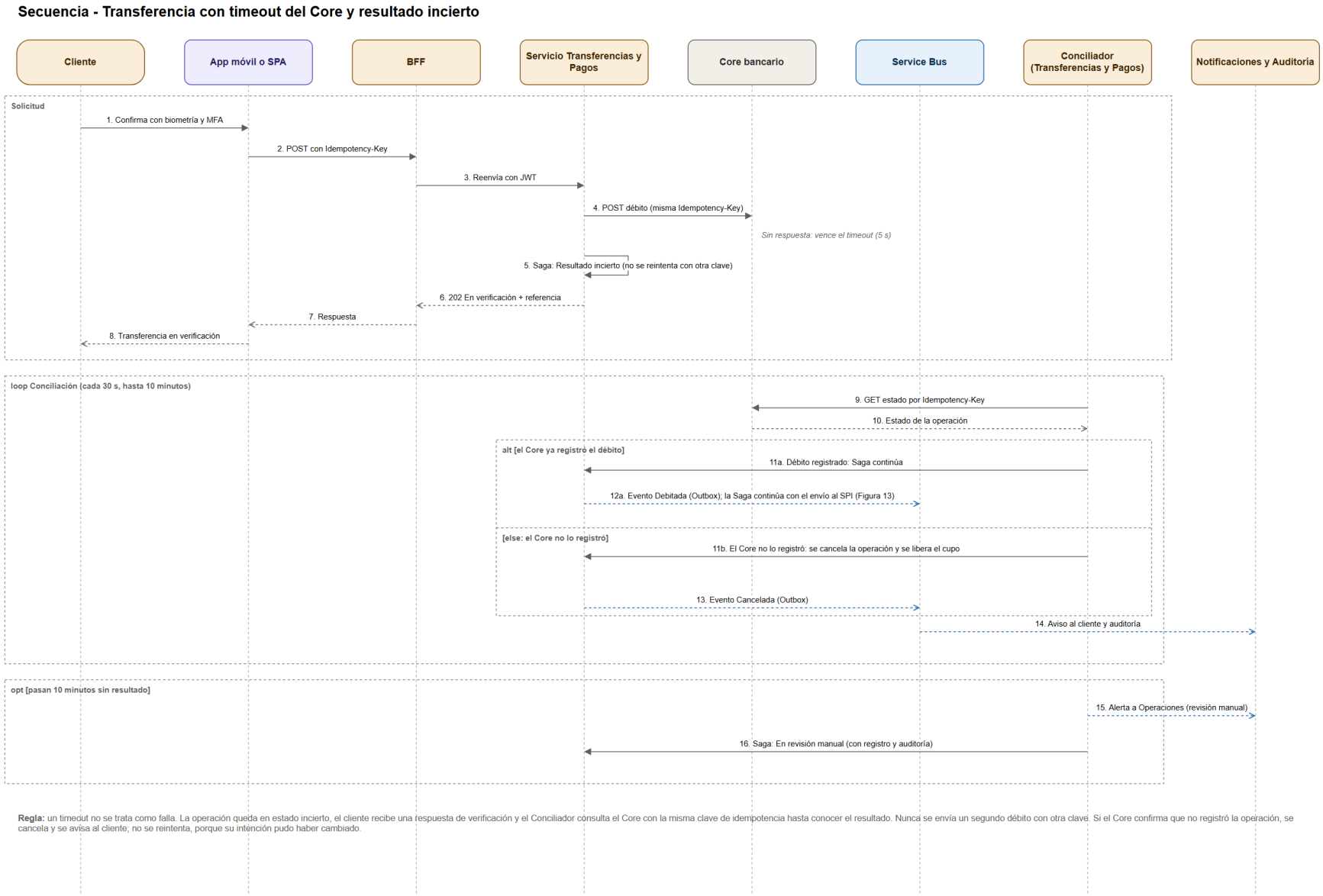


FIGURA 14 Secuencia de la transferencia con timeout del Core y resultado incierto

7.5 Onboarding con rostro y primer ingreso con biometría

El flujo de onboarding digital y primer ingreso contempla los siguientes pasos:

1. **Validación de identidad:** tras el consentimiento para el tratamiento de datos biométricos, se ejecuta la prueba de vida para comprobar que hay una persona presente y se compara ese mismo cuadro con el Registro Civil, según las interfaces disponibles.
2. **Creación de identidad:** una vez superadas las validaciones, se crea la identidad del cliente en Microsoft Entra External ID. El cliente define su usuario (su correo electrónico) y una contraseña como primer factor, y se configura el MFA definido para la plataforma (código por correo o SMS). En la web, el cliente ingresa con usuario, contraseña y MFA; en la app, con la biometría que desbloquea la llave del dispositivo.
3. **Enrolamiento del dispositivo:** la aplicación móvil genera una llave criptográfica protegida por los mecanismos de seguridad del dispositivo y registra su clave pública en el BFF Móvil. La biometría local permite autorizar el uso de la llave, sin enviar los datos biométricos al servidor.
4. **Primer ingreso:** el cliente se autentica mediante OpenID Connect, utilizando Authorization Code Flow con PKCE. Los tokens se gestionan conforme a las políticas de seguridad definidas para la aplicación.
5. **Ingresos posteriores:** la biometría local desbloquea la llave del dispositivo, la app firma el desafío del BFF Móvil y obtiene una sesión ligada al dispositivo. Durante la sesión, la llave firma la prueba de posesión de cada solicitud sin pedir de nuevo la biometría, con una validez acotada (por ejemplo, cinco minutos de inactividad); cada transferencia vuelve a pedirla.

Vinculación del dispositivo: al enrolarse, la app genera una llave no exportable en el Keychain o el Keystore, protegida por biometría, y registra su clave pública en el BFF Móvil, que la guarda en la BD Dispositivos. En cada ingreso y en cada transferencia, el BFF envía un desafío que la app firma tras el desbloqueo biométrico, y cada solicitud lleva además una prueba de posesión al estilo de DPoP. Así, ni un access token ni un refresh token robado sirven sin el dispositivo: Entra External ID podría emitir un token nuevo, pero el BFF lo rechaza sin la firma de la llave registrada. Para cambiar de teléfono, el cliente revoca el dispositivo anterior, se autentica con contraseña y MFA y enrola el nuevo; para montos altos se repite la prueba de vida. La recuperación de acceso y el MFA se gestionan en Entra External ID.

> **Decisiones relacionadas:** D8, D9, D10.

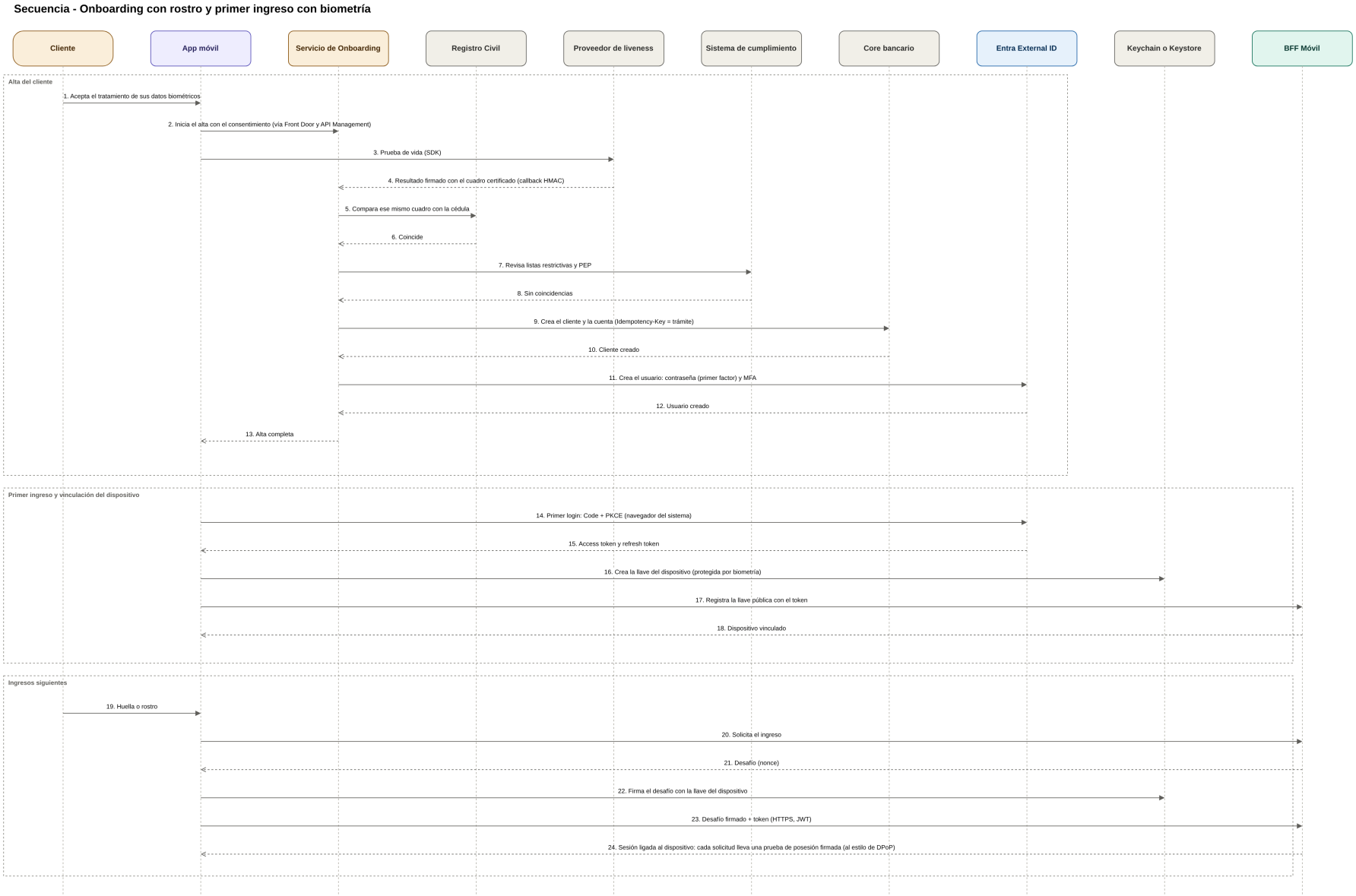


FIGURA 15 Secuencia del onboarding y del primer ingreso

SECCIÓN 8

Alta disponibilidad, recuperación ante desastres y rendimiento

8.1 Diagrama de infraestructura

La región primaria proporciona alta disponibilidad mediante zonas de disponibilidad, cuando los servicios y niveles contratados lo permiten. La región secundaria opera bajo una estrategia *warm standby*, con infraestructura desplegada y capacidad reducida, preparada para asumir la operación ante una falla regional.

Los datos y servicios se recuperan mediante los mecanismos de replicación y continuidad específicos de cada componente. Azure Front Door redirige el tráfico hacia la región secundaria cuando se cumplen las condiciones de conmutación configuradas. La recuperación completa requiere coordinar la activación de las aplicaciones, las bases de datos, la mensajería y los demás servicios necesarios para operar.

Infraestructura: HA dentro de la región y DR en warm standby

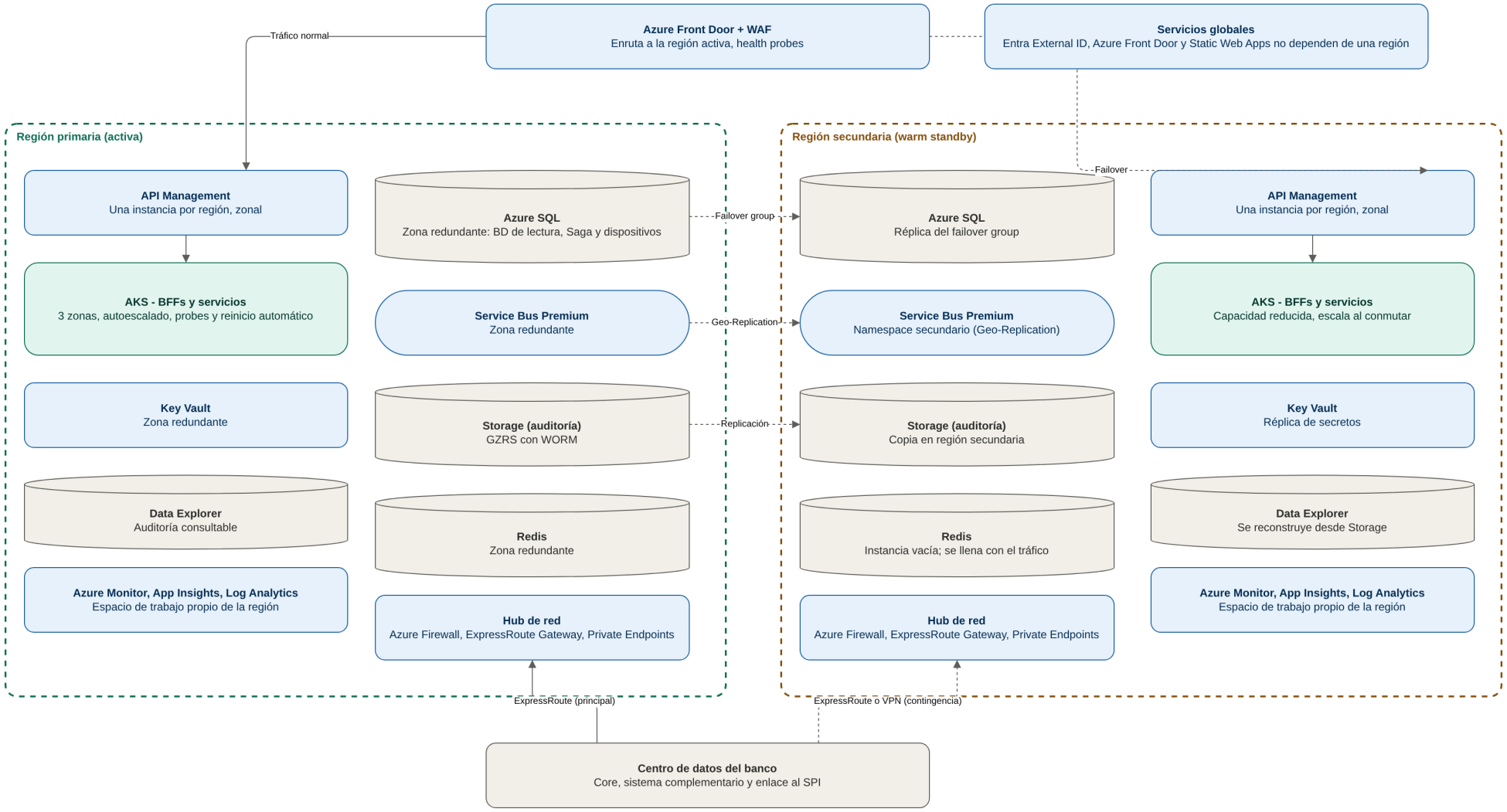


FIGURA 16 Infraestructura de alta disponibilidad y recuperación ante desastres

8.2 Qué protege contra qué

Falla	Mecanismo	Efecto
Un pod deja de responder	Probes de disponibilidad y de vida (*readiness* y *liveness*)	Se retira temporalmente del tráfico o se reinicia cuando corresponde.
Un nodo se cae	Reprogramación de pods y autoescalado de nodos	Los pods pueden ejecutarse en nodos disponibles, siempre que exista capacidad suficiente.
Una zona de disponibilidad se cae	Despliegue multizona, distribución de pods y capacidad redundante	El servicio puede continuar en las zonas restantes si la capacidad disponible es suficiente.
Un proveedor externo se degrada	*Timeouts*, Circuit Breaker, reintentos controlados y *fallback*	Se limita el impacto de la falla sobre los demás componentes.
Se pierde un mensaje o llega duplicado	Transactional Outbox, consumidores idempotentes, reintentos y Dead-Letter Queue (DLQ)	Se reduce el riesgo de pérdida y duplicación, y se facilita la recuperación y el reprocesamiento.
Falla una región completa	Región secundaria en *warm standby*, mecanismos de recuperación por componente y Azure Front Door	Se recupera la operación en la región secundaria mediante un procedimiento coordinado de contingencia.
Corrupción de datos o error humano	Restauración a un punto en el tiempo, respaldos recuperables e inmutables cuando aplique	Permite recuperar información hasta un punto anterior, según la disponibilidad y retención de los respaldos.
Ataque de denegación de servicio	Azure Front Door, WAF, protección DDoS aplicable y límites de tasa	Ayuda a filtrar tráfico malicioso y reducir el impacto del ataque sobre la plataforma.

8.3 Alta disponibilidad por componente

Componente	Estrategia de alta disponibilidad
AKS	Despliegue en zonas de disponibilidad cuando estén soportadas, distribución de nodos y pods, probes de salud y autoescalado.
API Management	Una instancia por región, con redundancia de zona (se define al crear la instancia). Las dos instancias mantienen la misma configuración (APIs, políticas y productos) mediante infraestructura como código y APIOps, con un único repositorio y el mismo pipeline de despliegue hacia ambas regiones.
Azure SQL	Redundancia zonal cuando esté disponible, respaldos y grupo de conmutación por error (failover group) hacia la región secundaria, sujeto a compatibilidad y configuración. Incluye la BD Dispositivos del BFF Móvil.
Azure Service Bus Premium	Redundancia zonal y Geo-Replication hacia la región secundaria. Geo-Replication copia mensajes y metadatos de forma asíncrona; los mensajes que no alcanzan a replicarse se vuelven a publicar desde el Transactional Outbox (Azure SQL) y los consumidores son idempotentes. Requiere el nivel Premium, no se combina con Geo-Disaster Recovery y tiene limitaciones propias (mensajes grandes y espacios de nombres con particiones). El diseño usa un espacio de nombres Premium sin particiones y mensajes pequeños.

Componente	Estrategia de alta disponibilidad
Redis	Alta disponibilidad según el servicio y nivel seleccionado. La caché deberá poder reconstruirse a partir de las fuentes autoritativas.
Azure Storage	Redundancia entre zonas y regiones mediante GZRS cuando sea compatible con los requisitos y la región seleccionada.
Azure Key Vault	Disponibilidad administrada según las capacidades regionales del servicio. Se validará su comportamiento durante la recuperación regional y el acceso a secretos y claves.
Azure Front Door	Servicio global con comprobaciones de salud (*health probes*), múltiples orígenes y reglas de prioridad para redirigir el tráfico ante una falla.

La disponibilidad efectiva de cada componente dependerá de la región, el nivel contratado, las configuraciones habilitadas y las dependencias existentes entre servicios.

8.4 Recuperación ante desastres

- **Estrategia:** *warm standby*, con una región primaria activa y una región secundaria desplegada con capacidad reducida.
- **Objetivos propuestos:** RTO de hasta 1 hora y RPO de hasta 5 minutos.
- **Conmutación regional:**
  1. Detectar la falla mediante los mecanismos de monitoreo y salud configurados.
  2. Decidir la activación de la región secundaria conforme al procedimiento de contingencia.
  3. Ejecutar la recuperación de Azure SQL, Service Bus y los demás componentes mediante sus mecanismos específicos.
  4. Verificar la disponibilidad de aplicaciones, dependencias, datos y mensajería.
  5. Redirigir el tráfico mediante Azure Front Door cuando la región secundaria esté preparada para operar.
  6. Ejecutar pruebas funcionales y sintéticas, verificar la integridad de las operaciones y comunicar el estado del servicio.
- **Regreso a la región primaria:** se realizará de forma planificada, previa validación de la sincronización de datos, la consistencia de los servicios y la disponibilidad de la infraestructura.
- **Ensayos:** realizar simulacros al menos dos veces al año, medir el RTO y el RPO reales, registrar los resultados y corregir las brechas identificadas.
- **Respaldos:** configurar restauración a un punto en el tiempo en Azure SQL, copias geográficamente redundantes cuando corresponda, respaldos inmutables según los requisitos y pruebas periódicas de restauración.

El RPO de cinco minutos se diseña para cumplirse en todo el sistema y se verifica en los simulacros semestrales, aunque cada componente replica de forma distinta. Azure SQL replica en pocos segundos mediante el grupo de conmutación por error. Service Bus conserva los mensajes con Geo-Replication, y lo que no alcanza a replicarse se vuelve a publicar desde el Outbox, que reside en Azure SQL. La evidencia de auditoría

se vuelve a escribir en Storage desde el Outbox, que conserva los mensajes ya publicados durante 24 horas, porque la replicación geográfica de Storage puede tardar más de cinco minutos. Redis no cuenta porque se reconstruye. Los simulacros semestrales miden el RTO y el RPO reales.

- **Operaciones en verificación durante una conmutación:** el estado de la Saga está en Azure SQL, que se replica en la región secundaria, y el Outbox vuelve a publicar los eventos pendientes. Al activarse la región secundaria, el Conciliador consulta al Core con la misma clave de idempotencia y la operación se resuelve sin duplicarse.
- **Datos personales y LOPDP:** todas las regiones candidatas están fuera de Ecuador. Por tanto, el tratamiento en la región primaria y la replicación a la secundaria constituyen transferencias internacionales de datos personales. Para ambas se documentan la base legal, las garantías aplicables y los países de destino con el área de Protección de Datos. Se aplica cifrado en reposo con llaves administradas por el banco en Key Vault, y se replica solo la información necesaria para operar y recuperar el servicio.

8.5 Baja latencia

La optimización de latencia se aborda en cada tramo de la arquitectura:

Tramo	Medida
Borde	Azure Front Door para enrutar las solicitudes y distribuir el contenido estático de la SPA mediante caché.
Región	Seleccionar la región de menor latencia medida desde Ecuador, considerando también la conectividad con el Core, los sistemas externos y los requisitos legales de tratamiento de datos.
Lecturas	Utilizar Redis y una réplica de lectura para consultas históricas, indicando la frescura de los datos y recurriendo a la fuente autoritativa cuando corresponda.
Escrituras	Mantener síncronas las validaciones indispensables para autorizar operaciones financieras. Procesar auditoría y notificaciones de forma asíncrona cuando las reglas de negocio lo permitan.
Red	Utilizar HTTP/2 cuando sea compatible, reutilización de conexiones, compresión y conectividad privada cuando aporte beneficios medibles.
Respuestas	Utilizar BFF para agregar y reducir respuestas, junto con paginación por cursor en consultas que devuelvan grandes volúmenes de datos.
Protección	Configurar *timeouts*, Circuit Breaker y reintentos controlados para evitar que la lentitud de un proveedor afecte al resto de la plataforma.

Objetivos de rendimiento: consultas con latencia p95 inferior a 300 ms y transferencias internas con latencia p95 inferior a 800 ms. Los valores se verifican con pruebas de carga representativas y se monitorean como indicadores de servicio (sección 9), considerando la latencia del Core y de los sistemas dependientes.

- **Presupuesto de latencia:** las consultas a Antifraude y a Límites se ejecutan en paralelo, de modo que sus tiempos no se suman. El presupuesto de 800 ms de una transferencia interna se reparte entre el enlace con el Core, la evaluación antifraude y la operación atómica, y se verifica con pruebas de carga medidas desde Ecuador.

Selección de la región de Azure: se propone Brazil South como región primaria y South Central US como secundaria. La decisión se confirma al comparar las regiones candidatas en latencia medida (hacia el cliente y hacia el Core), servicios disponibles, estrategia de recuperación, costo y ubicación de los datos (ver D2). Las mediciones se repiten con la plataforma operando desde la región secundaria, para confirmar que los objetivos de rendimiento se mantienen durante una contingencia.

8.6 Conectividad con el Core y los sistemas externos

La plataforma se conecta al centro de datos del banco, donde residen el Core, el sistema complementario y el enlace al SPI. Para este diseño se asume que el banco ya mantiene el acceso al SPI desde su centro de datos; la plataforma lo alcanza a través de esa red y no se conecta de forma directa al Banco Central.

Elemento	Decisión de diseño
Enlace al centro de datos	Circuito Azure ExpressRoute como enlace principal hacia la región primaria, y VPN sitio a sitio como respaldo. Un segundo circuito, o su equivalente, conecta el centro de datos con la región secundaria.
Red	Topología hub-and-spoke. La red central (hub) aloja Azure Firewall Premium, la puerta de enlace de ExpressRoute y las zonas DNS privadas; las redes de aplicación (spoke) alojan AKS y los datos. La región secundaria replica esta topología y se conecta por peering global.
Servicios de datos	Azure SQL, Service Bus, Redis, Storage y Key Vault se publican únicamente mediante Private Endpoints, sin acceso público.
Entrada pública	Azure Front Door es el único origen autorizado ante API Management, mediante la etiqueta de servicio de Front Door y la validación del identificador de Front Door.
Salida a Internet	La salida pasa por Azure Firewall con una lista de FQDN permitidos (Registro Civil, proveedor de prueba de vida, ACS, Firebase/APNs) y una NAT Gateway para entregar IP fijas a los proveedores.
Core y SPI	Tráfico por el enlace privado, con mTLS entre los servicios y el Core. Las llamadas al SPI se firman y se originan desde el centro de datos o desde la IP autorizada por el Banco Central.

> **Decisiones relacionadas:** D2, D22, D29, D31.

SECCIÓN 9

Monitoreo, operación y auto-healing

Esta sección define cómo se observa, se opera y se recupera la plataforma. La operación se apoya en la observabilidad (métricas, registros y trazas), en objetivos de servicio medibles, en alertas con responsables y en procedimientos documentados.

9.1 Observabilidad

- **Métricas, registros y trazas:** los servicios se instrumentan con OpenTelemetry y envían su telemetría a Application Insights y a un espacio de trabajo de Log Analytics. Cada solicitud lleva un identificador de correlación que atraviesa Front Door, API Management, el BFF, los servicios, Service Bus y las llamadas a sistemas externos.
- **Ubicación en las regiones:** Azure Monitor es un servicio regional. Cada región tiene su propio espacio de trabajo de Log Analytics y su Application Insights, de modo que la región secundaria no depende de la primaria para observar su operación. Azure Managed Grafana, desplegado con redundancia de zona, consolida ambos espacios en los tableros.
- **Tableros:** uno ejecutivo (disponibilidad y transacciones por canal), uno operativo por servicio (latencia, errores, saturación) y uno de dependencias (Core, SPI, proveedores, colas).
- **Pruebas sintéticas:** Application Insights ejecuta cada minuto pruebas de disponibilidad sobre el inicio de sesión y la consulta de saldo desde regiones de Azure distintas, y valida la ruta completa por Front Door.

9.2 Indicadores y objetivos de nivel de servicio

Los objetivos de nivel de servicio (SLO) se miden mensualmente sobre los indicadores (SLI) de la tabla. La consumición del presupuesto de error se revisa cada semana y detiene los despliegues no urgentes cuando se agota.

Servicio	Indicador (SLI)	Objetivo (SLO)
Plataforma (login y consulta)	Proporción de solicitudes exitosas medida en Front Door	99,95 % mensual
Consulta de movimientos	Latencia p95 en el BFF	Inferior a 300 ms
Transferencia interna	Latencia p95 y proporción de éxito	Inferior a 800 ms y 99,9 %
Transferencia interbancaria	Operaciones con estado final en el plazo del ciclo del SPI	99,5 % dentro del siguiente corte
Frescura de la réplica	Retraso del Sincronizador respecto del Core	Inferior a 60 s en el percentil 95
Mensajería	Antigüedad del mensaje más antiguo y mensajes en Dead-Letter Queue	Inferior a 30 s y cero mensajes sin atender por más de una hora

Servicio	Indicador (SLI)	Objetivo (SLO)
Onboarding	Trámites completados sin error técnico	98 %

- **Disponibilidad compuesta:** el objetivo de 99,95 % se mide sobre la plataforma y excluye las caídas del Core, del SPI y de Entra External ID, que se miden y se reportan por separado. La disponibilidad de una transferencia es el producto de la de cada eslabón: 99,95 % de la plataforma, 99,9 % del Core y 99,99 % de Entra dan cerca de 99,84 %. Por eso, ante una dependencia caída, la plataforma responde con un estado claro (en verificación o no disponible) y no con un error.

9.3 Alertas y respuesta

Alerta	Condición	Severidad	Destinatario
Indisponibilidad de la plataforma	Pruebas sintéticas fallidas en dos regiones durante tres minutos	Crítica	Guardia de operaciones y líder de plataforma
Degradación de latencia	p95 de consulta o transferencia sobre el objetivo durante diez minutos	Alta	Guardia del equipo del servicio
Core o SPI no responde	Circuit Breaker abierto o tasa de error superior al 5 %	Crítica	Guardia de operaciones y soporte del Core
Mensajes en Dead-Letter Queue	Cualquier mensaje con más de quince minutos sin atender	Alta	Equipo del servicio propietario
Retraso de la réplica	Retraso superior a cinco minutos	Alta	Equipo de Históricos
Saturación de AKS	CPU o memoria de nodos superior al 80 % durante diez minutos	Media	Equipo de plataforma
Fraude o ataque	Patrones de intentos de acceso o de transferencias definidos por Seguridad	Crítica	Seguridad de la información (ver D39)
Certificado o secreto por vencer	Vencimiento en menos de treinta días	Media	Equipo de plataforma
Auditoría incompleta	La conciliación horaria encuentra eventos faltantes frente a los registros de API Management	Alta	Equipo de Auditoría y Seguridad de la información
Reservas de cupo vencidas	Más de diez reservas vencidas en una hora, o una reserva vencida con débito aplicado	Alta	Equipo de Transferencias y Pagos

Las alertas se envían mediante grupos de acciones de Azure Monitor a la herramienta de guardia, con escalamiento al siguiente nivel si no hay reconocimiento en quince minutos.

9.4 Auto-healing

El auto-healing es la capacidad de la plataforma de detectar una falla y corregirla sin intervención humana. Se implementa en cuatro niveles:

- **Contenedor:** las sondas de vida (liveness) reinician el pod que deja de responder; las sondas de disponibilidad (readiness) lo retiran del tráfico mientras se recupera.
- **Capacidad:** el escalador horizontal de pods (HPA) y el autoescalador de nodos ajustan la capacidad según la carga; los Pod Disruption Budgets garantizan que haya réplicas durante mantenimientos.
- **Nodo y zona:** la reparación automática de nodos de AKS reemplaza los que fallan, y la distribución de pods entre zonas mantiene el servicio si una zona se cae.
- **Dependencia y región:** el Circuit Breaker y los reintentos con espera exponencial aíslan las fallas de proveedores; Front Door retira los orígenes que fallan sus sondas de salud y conmuta a la región secundaria.

Las correcciones que no se resuelven solas se ejecutan mediante runbooks automatizados (por ejemplo, reprocesar mensajes de la Dead-Letter Queue o reiniciar el Sincronizador), disparados desde las alertas con aprobación humana cuando afectan operaciones financieras.

9.5 Runbooks y gestión de incidentes

Cada escenario crítico tiene un runbook con diagnóstico, acciones, responsables y criterios de escalamiento: indisponibilidad del Core, indisponibilidad del SPI, crecimiento de la Dead-Letter Queue, retraso de la réplica, falla de Entra External ID, conmutación regional, certificado por vencer e incidente de seguridad. Los incidentes se clasifican por severidad, se comunican al banco según el tiempo de respuesta acordado y se cierran con un análisis posterior sin culpables (post-mortem) que genera acciones correctivas con responsable y fecha. Los runbooks se ejercitan en los simulacros de recuperación descritos en 8.4.

> **Decisiones relacionadas:** D22, D39.

SECCIÓN 10

Manejo de costos

10.1 Enfoque

La gestión de costos se basa en tres principios: ajustar la capacidad a la demanda mediante autoescalado, contratar compromisos de consumo (reservas) para cargas estables y optimizar el almacenamiento según la frecuencia de acceso y los requisitos de conservación.

Esta sección incluye una estimación mensual de referencia (subsección 10.3) con precios de lista de Azure y supuestos explícitos. La estimación se actualiza con Azure Pricing Calculator cuando se disponga de volúmenes reales de usuarios y transacciones.

10.2 Gobierno del gasto (FinOps)

Se establecerán las siguientes medidas de control:

1. **Etiquetado:** definir etiquetas obligatorias para identificar producto, entorno, centro de costos y responsable del recurso.
2. **Presupuestos y alertas:** configurar presupuestos por suscripción o ámbito de gestión, con alertas al alcanzar el 50 %, 80 % y 100 % del presupuesto definido.
3. **Revisión mensual:** analizar el gasto mediante Azure Cost Management y las recomendaciones de Azure Advisor, identificando desviaciones y oportunidades de optimización.
4. **Entornos no productivos:** apagar o reducir recursos de desarrollo y pruebas fuera del horario de uso, cuando no afecte a procesos programados ni a las necesidades del equipo.
5. **Políticas de gobierno:** utilizar Azure Policy para exigir etiquetas, restringir regiones y controlar los SKU permitidos conforme a los estándares de arquitectura.
6. **Seguimiento de consumo:** establecer indicadores de costo por transacción, usuario activo y volumen de datos cuando exista información suficiente para calcularlos.
7. **Control de cambios:** revisar el impacto económico de nuevas funcionalidades, cambios de capacidad y ampliaciones de retención antes de su implementación.

Las alertas presupuestarias permiten detectar desviaciones, pero no detienen automáticamente el consumo. Cualquier acción automatizada para reducir recursos deberá contar con controles que eviten afectar la disponibilidad y las operaciones financieras.

10.3 Estimación mensual de referencia

La estimación usa los precios de lista de la API pública de precios de Azure (Azure Retail Prices) consultados el 23 de octubre de 2026, en dólares estadounidenses, sin impuestos ni descuentos, con 730 horas por mes. La región primaria es Brazil South y la secundaria es South Central US; los precios de cada región se tomaron por separado.

- **Supuestos de carga:** 150 000 clientes activos al mes, 90 millones de llamadas mensuales a API Management, 3 TB de salida por Front Door, 2 TB por Azure Firewall, 2 TB de evidencia de auditoría en el primer año y 600 GB mensuales de telemetría en la región primaria.

- **Supuestos de dimensionamiento:** región primaria con 12 nodos D4s v5 en AKS, 8 vCore de Azure SQL de propósito general con redundancia de zona, 2 unidades de Service Bus Premium, 2 unidades de API Management Standard v2 y una instancia de Azure Managed Redis B5. La región secundaria opera en warm standby con la mitad de los nodos de AKS.

Componente	Región primaria (USD/mes)	Región secundaria (USD/mes)
AKS (nodos D4s v5)	2 681	1 007
API Management Standard v2	1 625	500
Azure SQL (8 vCore)	2 702	1 067
Service Bus Premium (2 unidades)	1 354	1 354
Azure Managed Redis B5	162	126
Front Door Premium (base y salida)	578	—
Azure Firewall Premium	1 310	1 278
Puerta de enlace de ExpressRoute (ErGw1AZ)	264	264
Storage de auditoría (RA-GZRS, 2 TB)	220	—
Log Analytics y Application Insights	2 760	690
Total	**13 656**	**6 286**

El total mensual de referencia es de 19 942 dólares, es decir, cerca de 239 000 dólares al año. Con una reserva de uno o tres años de las máquinas virtuales de AKS (1 654 y 1 059 dólares mensuales por los 12 nodos, frente a 2 681 con pago por uso), el costo de la región primaria baja entre 1 027 y 1 622 dólares al mes.

- **No incluido:** Microsoft Entra External ID (se factura por usuario activo mensual; con 150 000 usuarios es una partida de pocos miles de dólares al mes, a confirmar con la calculadora), mensajes SMS y correo de Azure Communication Services, Microsoft Sentinel y Defender for Cloud (se facturan por volumen de datos ingeridos y se dimensionan con Seguridad), Azure Data Explorer (de cientos a pocos miles de dólares al mes según el tamaño del clúster), Key Vault y Static Web Apps (cada uno por debajo de 100 dólares al mes), circuitos de ExpressRoute y VPN del proveedor de telecomunicaciones, transferencia de datos entre regiones, entornos de desarrollo y pruebas, licencias de terceros (proveedor de prueba de vida, antifraude), personal y soporte.
- **Sensibilidad:** los componentes que más peso tienen son la telemetría, AKS y Azure SQL. Reducir el muestreo de trazas a la mitad ahorra cerca de 1 380 dólares al mes en la región primaria; el tamaño de AKS y de Azure SQL se ajusta con las pruebas de carga descritas en 8.5.
- **Si el banco pide reducir el costo:** el orden de recorte es el muestreo y la retención de telemetría (hasta 1 400 dólares al mes), las reservas de AKS a tres años (hasta 1 600) y el tamaño de los entornos no pro-

ductivos. Los dos primeros ahorros suman cerca de 3 000 dólares (15 %); llegar a 30 % exige reducir capacidad o alcance, y la región secundaria y la auditoría no se recortan.

> **Decisiones relacionadas:** D1, D4, D18.

SECCIÓN 11

Normativa y estándares

Esta sección identifica el marco legal, regulatorio y técnico considerado en el diseño de la plataforma de Banca por Internet y describe cómo la arquitectura contribuye a su cumplimiento. Los estándares técnicos de apoyo y las evidencias de cumplimiento están en el Anexo E.

Marco legal y regulatorio de Ecuador

Norma	Qué regula	Cómo lo cubre la arquitectura	Estado
Ley Orgánica de Protección de Datos Personales (LOPDP), publicada en el Registro Oficial Suplemento No. 459 del 26 de mayo de 2021	Derechos de los titulares, principios y bases de legitimación del tratamiento, obligaciones de responsables y encargados, seguridad y transferencias de datos personales.	Minimización de datos, control de acceso, cifrado en tránsito y reposo, auditoría, gestión de retención y eliminación, y evaluación de la ubicación y transferencia de los datos.	Norma considerada en el diseño. Sus requisitos se aplican por tratamiento de datos.
Reglamento General de la LOPDP, expedido mediante Decreto Ejecutivo No. 904 y publicado en el Registro Oficial Suplemento No. 435 del 13 de noviembre de 2023	Desarrolla las disposiciones para la aplicación de la LOPDP.	Privacidad desde el diseño, gestión de riesgos, medidas de seguridad y controles para el tratamiento de datos personales.	Norma considerada en el diseño. Sus obligaciones se aplican junto con la normativa secundaria vigente.
Normativa secundaria de la Superintendencia de Protección de Datos Personales (SPDP)	Desarrolla requisitos y procedimientos relacionados con protección de datos, transferencias nacionales e internacionales, gestión de riesgos y otros aspectos del tratamiento.	Incorporar controles de privacidad, evaluación de riesgos, trazabilidad, gestión de transferencias y procedimientos de atención de derechos de los titulares.	Normativa considerada en el diseño. Las resoluciones y disposiciones vigentes se aplican a cada tratamiento, incluidos los datos biométricos y las transferencias internacionales.
Código Orgánico Monetario y Financiero (COMF)	Establece el marco general del sistema financiero, las competencias de los organismos de control y las disposiciones aplicables a las entidades financieras.	Incorporar los requisitos regulatorios aplicables en los procesos, controles de seguridad, continuidad operativa y gestión de riesgos de la plataforma.	Marco legal considerado en el diseño. Las obligaciones concretas aplicables al banco las determinan Jurídico y Cumplimiento.
Codificación de las Normas de la Superintendencia de Bancos, incluida la normativa de control de riesgo operativo y seguridad de canales electrónicos	Establece disposiciones de control relacionadas con riesgo operativo, seguridad de la información, canales electrónicos, continuidad del negocio y gestión de incidentes, según los capítulos aplicables.	Autenticación reforzada, control de acceso, monitoreo, registros de auditoría, gestión de incidentes, protección de transacciones, continuidad y pruebas de recuperación.	Norma considerada en el diseño. Se aplica la versión vigente de los capítulos y artículos pertinentes y se conservan las evidencias requeridas por el organismo de control.

Norma	Qué regula	Cómo lo cubre la arquitectura	Estado
Circulares y disposiciones de la Superintendencia de Bancos sobre canales electrónicos	Pueden establecer requisitos de comunicación, revisión de seguridad, documentación o autorización relacionados con la habilitación de canales, según su contenido y vigencia.	Preparar la documentación técnica y de seguridad, realizar evaluaciones de vulnerabilidades y pruebas de seguridad, y mantener evidencias de los controles implementados.	Disposiciones consideradas en el diseño. Se atienden las circulares vigentes y se preparan los entregables previos a la puesta en producción.
Normativa del Banco Central del Ecuador (BCE) para el Sistema de Pagos Interbancarios (SPI)	Regula los aspectos operativos y técnicos aplicables a los participantes, instrucciones de pago, procesos de intercambio y liquidación correspondientes.	Integrar las transferencias mediante el componente autorizado, validar los formatos y mecanismos de comunicación exigidos, controlar los estados de las operaciones y mantener trazabilidad y conciliación.	Normativa considerada en el diseño. La integración cumple los requisitos de participación, conectividad, seguridad, horarios, cortes, formatos y procedimientos vigentes del BCE.
Normativa de prevención de lavado de activos y financiamiento de delitos aplicable a la entidad, incluida la emitida por la UAFE y los organismos de control competentes	Establece obligaciones de debida diligencia, monitoreo, detección y reporte de operaciones, conforme al régimen aplicable a la entidad.	Proporcionar trazabilidad de las transacciones y capacidades de monitoreo que permitan integrar las reglas y alertas definidas por Cumplimiento.	Normativa considerada en el diseño. Las obligaciones, los reportes y los plazos de conservación siguen el régimen aplicable al banco.

Consideraciones específicas de protección de datos:

- Los datos biométricos utilizados para identificación o autenticación requieren una evaluación específica de su tratamiento, finalidad, base de legitimación, protección y conservación.
- Las transferencias internacionales de datos deberán evaluarse conforme a la LOPDP, su Reglamento y la normativa secundaria vigente de la SPDP.
- Se realiza una evaluación de impacto relativa a la protección de datos personales cuando los riesgos y las condiciones del tratamiento así lo requieren.
- Los plazos de conservación, eliminación y atención de derechos deberán definirse según las obligaciones legales y regulatorias aplicables, evitando establecer períodos arbitrarios en la arquitectura.

SECCIÓN 12

Matriz de cobertura de requisitos

La matriz relaciona cada requisito del enunciado con las secciones y figuras del documento donde se aborda y con las decisiones que lo sustentan.

Requisito	Dónde se aborda	Decisiones
Consulta del histórico de movimientos con baja carga sobre el Core	6.3 y 6.3.1, Figuras 5, 6 y 11, 8.5	D17, D18, D32
Transferencias entre cuentas del mismo banco	6.1 y 7.2, Figuras 3 y 12	D14, D15, D16, D20, D21
Transferencias interbancarias (SPI)	6.1, 7.3 y 7.4, Figuras 13 y 14	D14, D16, D35
Pagos (productos propios y terceros en otros bancos)	2, 6.1	D15, D34
Autenticación y autorización web y móvil	6.2, Figura 4	D5, D7, D8, D36
Confirmación reforzada de transferencias (app y web)	6.2, 7.2 y 7.5, Figuras 12 y 13	D8, D9
Onboarding con reconocimiento facial	6.4 y 7.5, Figuras 7 y 15	D10
Notificaciones	6.5, Figura 8	D26
Auditoría inmutable	6.5, Figura 8	D13, D19
Aplicación web (SPA)	6.6, Figura 9	D12, D30, D37
Aplicación móvil	6.7, Figura 10	D9, D11, D37
Baja latencia	6.3.1, 8.5	D2, D17, D32
Alta disponibilidad	8.2, 8.3	D22, D29
Recuperación ante desastres	8.4, Figura 16	D22, D31
Conectividad con el Core y el SPI	8.6	D2, D22
Monitoreo, operación y auto-healing	9	D22, D39

Requisito	Dónde se aborda	Decisiones
Seguridad y cumplimiento normativo	11, 8.6 y Anexo E	D7, D39
Costos	10	D1, D4, D18
Diagramas C4 (C1, C2, C3) y de secuencia	4, 5, 6, 7	—
Decisiones con al menos dos justificaciones y alternativas	13 y Anexos C y D	D1 a D39
Persistencia y caché de clientes frecuentes, basadas en patrones	5.3, 6.3.1, Figura 6	D17, D18, D32
Capa de integración con API Gateway y los servicios de negocio	5, 6.2	D6, D28
Recomendación del flujo OAuth	6.2, Figura 4	D8
Herramientas de la industria para el onboarding	6.4	D10
Al menos dos canales de notificación	6.5, Figura 8	D26
Tres opciones de frameworks multiplataforma y su elección	6.6, 6.7	D11, D12
Arquitectura desacoplada y reutilizable	3, 6	D3, D5, D13
Excelencia operativa	9	D24, D25

SECCIÓN 13

Cuadro de decisiones arquitectónicas

Este capítulo resume las 39 decisiones de arquitectura. La tabla 13.2 presenta las 21 decisiones estructurales con sus dos justificaciones y las alternativas descartadas; el registro completo de cada una, con el compromiso aceptado y el supuesto de diseño, está en el Anexo C. Las 18 decisiones complementarias, también con dos justificaciones, están en el Anexo E.

Cuando una decisión depende de capacidades de sistemas existentes que no se conocen en detalle, como el Core o el SPI, el ADR lo declara como supuesto de diseño.

13.1 Resumen de decisiones

ID	Decisión	Tipo	Se aplica en
D1	Selección de plataforma en la nube	ADR	Secciones 5, 10
D2	Selección de la región de Azure	ADR	Secciones 5, 8
D3	Arquitectura basada en microservicios	ADR	Sección 5
D4	Plataforma de ejecución de servicios	ADR	Secciones 5, 10
D5	Separación de BFF para web y aplicación móvil	ADR	Sección 6.2
D6	Gestión centralizada de APIs	Complementaria	Sección 5
D7	Gestión de identidad digital	ADR	Sección 6.2
D8	Protocolo de autenticación para web y móvil	ADR	Secciones 6.2, 7.5
D9	Autenticación biométrica y vinculación del dispositivo	ADR	Secciones 6.2, 6.7, 7.2 y 7.5
D10	Validación de identidad durante el onboarding	ADR	Secciones 6.4, 7.5
D11	Framework para aplicación móvil	ADR	Sección 6.7
D12	Framework para aplicación web	ADR	Sección 6.6
D13	Plataforma de mensajería y eventos	ADR	Secciones 5, 6.5
D14	Orquestación de transferencias interbancarias	ADR	Secciones 6.1, 7.3
D15	Atomicidad de transferencias internas	ADR	Secciones 6.1, 7.2
D16	Idempotencia y Transactional Outbox	ADR	Secciones 6.1, 7.2, 7.3
D17	Consulta de históricos mediante CQRS y sincronización de datos	ADR	Secciones 6.3, 7.1
D18	Estrategia de caché para consultas	ADR	Secciones 6.3, 7.1, 10

ID	Decisión	Tipo	Se aplica en
D19	Auditoría inmutable y consultas de auditoría	ADR	Sección 6.5
D20	Integración con el servicio antifraude	Complementaria	Secciones 6.1, 7.2, 7.3
D21	Resiliencia de comunicaciones y manejo de fallos	ADR	Secciones 6.1, 7.2, 7.3
D22	Alta disponibilidad y recuperación ante desastres	ADR	Sección 8
D23	Seguridad de red y comunicación entre componentes	ADR	Transversal (se aplica a toda la plataforma)
D24	Observabilidad y monitoreo	Complementaria	Transversal (se aplica a toda la plataforma)
D25	CI/CD e infraestructura como código	Complementaria	Transversal (se aplica a toda la plataforma)
D26	Plataforma de notificaciones	Complementaria	Sección 6.5
D27	Lenguaje y plataforma para backend	Complementaria	Transversal (se aplica a toda la plataforma)
D28	Protocolos de comunicación e integración	Complementaria	Transversal (se aplica a toda la plataforma)
D29	Protección perimetral y distribución de tráfico	Complementaria	Sección 8
D30	Publicación de la aplicación web	Complementaria	Sección 6.6
D31	Base de datos transaccional	Complementaria	Sección 8
D32	Servicio de caché administrada	Complementaria	Secciones 6.3, 7.1
D33	Servicio de límites transaccionales	Complementaria	Sección 6.1
D34	Servicio de Transferencias y Pagos	Complementaria	Sección 6.1
D35	Persistencia y coordinación de la Saga	Complementaria	Sección 6.1
D36	Gestión de sesión en el BFF web	Complementaria	Sección 6.2
D37	Organización de frontend y gestión de estado	Complementaria	Secciones 6.6, 6.7
D38	Identidad de cargas de trabajo y administración de secretos	Complementaria	Transversal (se aplica a toda la plataforma)
D39	Detección y respuesta de seguridad	Complementaria	Transversal (se aplica a toda la plataforma)

13.2 Decisiones estructurales: justificaciones y alternativas

Cada decisión estructural con sus dos justificaciones y las alternativas que se descartaron. El compromiso aceptado y los supuestos de diseño de cada una están en el Anexo C; las 18 decisiones complementarias, en el Anexo D.

ID	Decisión adoptada	Justificación 1	Justificación 2	Alternativas descartadas
D1	**Utilizar Microsoft Azure como plataforma única de infraestructura y servicios administrados.**	Integración de servicios (Azure Well-Architected Framework): Azure ofrece administrados todos los servicios que exige el diseño (AKS, API Management, Front Door, Service Bus, Azure SQL, Entra External ID, Key Vault).	Continuidad y cumplimiento (Cloud Adoption Framework de Microsoft): Azure dispone de regiones con zonas de disponibilidad cercanas a Ecuador y de regiones pareadas para recuperación ante desastres, lo que permite cumplir RTO de una hora y RPO de cinco minutos sin construir un segundo centro de datos.	AWS y Google Cloud; Infraestructura local o híbrida.
D2	**Utilizar Brazil South como región primaria y South Central US como región secundaria de recuperación ante desastres.**	Alta disponibilidad dentro de la región (Azure Well-Architected Framework, pilar de confiabilidad): Brazil South tiene tres zonas de disponibilidad, por lo que la pérdida de un centro de datos se absorbe dentro de la región, sin activar la secundaria.	Recuperación geográfica con menor diseño propio (Documentación de Azure sobre regiones emparejadas): Brazil South está emparejada con South Central US.	Mexico Central y Chile Central; South Central US con North Central US (contingencia).
D3	**Construir la plataforma con microservicios por dominio funcional, cada uno con su propia base de datos.**	Escalamiento independiente (Newman, Building Microservices): La plataforma combina lecturas muy frecuentes (históricos) con escrituras críticas (transferencias) y envíos masivos (notificaciones).	Aislamiento de fallos y de cambios (Fowler y Lewis, Microservices; ley de Conway): Una falla en Notificaciones no debe detener Transferencias, y los equipos pueden desplegar un servicio sin coordinar la salida de todos los demás.	Monolito; Monolito modular.
D4	**Ejecutar los servicios backend y los BFF en Azure Kubernetes Service (AKS).**	Control de red y de nodos (Guía de arquitectura de AKS de Microsoft): La plataforma exige red privada, políticas de red, distribución multizona y control de los nodos.	Estándar y portabilidad (CNCF, Kubernetes): Kubernetes es un estándar abierto con escalamiento horizontal (HPA), despliegue declarativo y GitOps, lo que reduce la dependencia de un servicio propietario de Azure.	Azure Container Apps; Azure App Service; Máquinas virtuales.
D5	**Implementar un Backend for Frontend (BFF) para la aplicación web y otro para la aplicación móvil.**	Necesidades distintas por canal (Newman, patrón Backend for Frontend): La web mantiene la sesión con una cookie HttpOnly y actúa como cliente confidencial.	Seguridad y evolución independiente (RFC 9700 (OAuth 2.0 Security BCP)): Los tokens de la web quedan en el servidor y nunca llegan al navegador.	Un backend compartido por todos los clientes; Un único BFF para web y móvil.
D7	**Utilizar Microsoft Entra External ID como servicio de identidad de los clientes.**	No reinventar la autenticación (OWASP ASVS; NIST SP 800-63B): Gestionar credenciales, MFA y recuperación de acceso es una función de alto riesgo.	Integración con estándares (OpenID Connect Core 1.0; OAuth 2.0): Entra External ID emite tokens estándar que API Management y los BFF validan sin código propio, lo que simplifica la integración con el resto de la plataforma.	Proveedor de identidad propio; Soluciones comerciales de identidad; Azure AD B2C.

ID	Decisión adoptada	Justificación 1	Justificación 2	Alternativas descartadas
D8	**Utilizar OAuth 2.0 Authorization Code Flow con PKCE y OpenID Connect para ambos canales.**	Práctica vigente de seguridad (RFC 9700 (OAuth 2.0 Security BCP)): La guía vigente desaconseja el Implicit Flow y recomienda Authorization Code con PKCE para todo tipo de cliente.	Protección en apps móviles (RFC 7636 (PKCE); RFC 8252 (OAuth para apps nativas)): PKCE evita que se use un código de autorización interceptado.	Implicit Flow y flujos heredados; Autenticación propia.
D9	**Vincular el dispositivo móvil con una llave desbloqueada por biometría y exigir un segundo factor por transacción en la web.**	Privacidad de la biometría (W3C WebAuthn y FIDO2): la huella o el rostro no salen del dispositivo; el servidor verifica una firma, no un dato biométrico.	Resistencia al robo de tokens (RFC 9449 como referencia; OWASP MASVS): sin la llave registrada no se puede operar aunque se robe un token.	Solo usuario y contraseña; OTP como único segundo factor en la app; biometría que solo desbloquea el refresh token local.
D10	**Separar la validación documental, la comparación facial y la prueba de vida en adaptadores independientes, con un proveedor comercial para la prueba de vida.**	Responsabilidad única (Patrón Strategy; Hohpe y Woolf, Enterprise Integration Patterns): Cada validación cambia a su propio ritmo y proviene de un proveedor distinto.	Resistencia a la suplantación (ISO/IEC 30107-3 (detección de ataques de presentación)): El Registro Civil compara el rostro, pero no detecta una foto, un video o una máscara.	Validación manual; Un proveedor único e integral.
D11	**Desarrollar la aplicación móvil con Flutter, con una única base de código para Android e iOS.**	Una base de código (Documentación de Flutter; costo total de propiedad): Flutter comparte interfaz y lógica entre Android e iOS con un solo equipo y un solo ciclo de pruebas, lo que reduce el costo de mantenimiento de una app financiera que debe mantenerse al día con ambos sistemas operativos.	Seguridad del dispositivo (OWASP MASVS): La app necesita biometría, almacenamiento seguro (Keychain y Keystore) y detección de root o jailbreak.	React Native; Kotlin Multiplatform; Desarrollo nativo; .NET MAUI.
D12	**Desarrollar la SPA con Angular y TypeScript.**	Estructura para una aplicación grande (Guía de arquitectura de Angular): Angular ofrece inyección de dependencias, módulos, formularios reactivos y herramientas de pruebas en un solo marco.	Contratos explícitos (TypeScript; OWASP ASVS): TypeScript mantiene tipos explícitos entre la SPA y el BFF, lo que reduce errores de integración, y Angular protege por defecto contra la inyección de scripts al escapar el contenido que se muestra.	React; Vue.js; Renderizado en servidor.
D13	**Utilizar Azure Service Bus Premium para la comunicación asíncrona entre servicios.**	Entrega garantizada (Hohpe y Woolf, Guaranteed Delivery): Las colas persisten el mensaje, reintentan y envían a una Dead-Letter Queue lo que no se puede procesar.	Desacople en el tiempo (Richardson, Microservices Patterns): Si un consumidor cae, los mensajes esperan en la cola.	REST síncrono entre servicios; Azure Event Hubs; Broker autogestionado.

ID	Decisión adoptada	Justificación 1	Justificación 2	Alternativas descartadas
D14	**Gestionar las transferencias interbancarias con una Saga orquestada y compensaciones.**	Sin transacción distribuida (Garcia-Molina y Salem, Sagas (1987); Richardson, Microservices Patterns): La operación toca el Core y el SPI, que no pueden participar en una misma transacción.	Visibilidad y control del estado (Richardson, Saga orquestada): Un orquestador centraliza el estado de cada operación.	Flujo síncrono de extremo a extremo; Coreografía por eventos.
D15	**Delegar en el Core la transferencia interna como una única operación atómica.**	Transacción local (Kleppmann, Designing Data-Intensive Applications (ACID)): El débito y el crédito ocurren en el mismo sistema, por lo que pueden confirmarse en una transacción local.	Integridad contable (Principio de una única fuente de verdad): El Core es el dueño del libro contable. La plataforma no replica reglas contables y reduce el riesgo de que los saldos diverjan.	Débito y crédito independientes coordinados por la plataforma; Saga con compensaciones.
D16	**Exigir una clave de idempotencia en cada solicitud financiera y publicar los eventos mediante Transactional Outbox.**	Los reintentos son inevitables (Hohpe y Woolf, Idempotent Receiver): Los tiempos de espera y los resultados inciertos obligan a reintentar.	Doble escritura (Richardson, Transactional Outbox): Guardar el dato y el evento en la misma transacción local evita el caso en que el dato se guarda y el evento se pierde.	Reintentos sin control de duplicados; Control de duplicados en memoria; Publicar a Service Bus después del commit.
D17	**Separar las lecturas de históricos de la escritura financiera con un modelo de consulta propio, sincronizado con el Core por el Sincronizador.**	Proteger el core (Fowler, CQRS): Las lecturas de históricos son mucho más frecuentes que las escrituras y compiten con las operaciones del Core.	Consistencia adecuada a cada dato (Kleppmann, Designing Data-Intensive Applications; Abadi, PACELC): El histórico tolera un retraso de segundos (objetivo de 60 segundos, sección 9.2); el saldo con el que se autoriza una operación no, y se consulta al Core.	Consultar siempre el Core; Réplica provista por el Core.
D18	**Utilizar Azure Managed Redis con el patrón Cache-Aside para las consultas de los clientes frecuentes.**	Latencia (Patrón Cache-Aside (Azure Architecture Center)): Las consultas repetidas de los clientes frecuentes se responden desde memoria y ayudan a cumplir un p95 menor a 300 ms.	La caché no es fuente de verdad (Kleppmann, Designing Data-Intensive Applications): Si Redis falla, los servicios leen la base de lectura y la caché se reconstruye.	Sin caché; Caché local por instancia.
D19	**Conservar la evidencia en Azure Storage con inmutabilidad (WORM) y consultarla en Azure Data Explorer.**	Evidencia no modificable (Azure Immutable Blob Storage (WORM)): La política de inmutabilidad impide modificar o borrar un registro durante el período de retención, lo que respalda la reconstrucción de las operaciones ante un auditor o un incidente.	Separar escritura y consulta (Principio de mínimo privilegio): Data Explorer atiende las consultas de auditores y de seguridad sin tocar el almacén inmutable, y se reconstruye desde Storage si es necesario.	Logs operativos convencionales; Base de datos relacional de auditoría.
D21	**Aplicar tiempos de espera, reintentos con espera exponencial, Circuit Breaker y aislamiento de recursos en toda llamada a un sistema externo.**	Evitar fallas en cascada (Nygard, Release It!): Sin límites, un proveedor lento agota los hilos y arrastra al resto.	Política única y observable (Biblioteca Polly): Una biblioteca estándar con parámetros por dependencia y métricas evita una lógica distinta en cada servicio.	Reintentos sin política; Gestión de errores propia de cada servicio.

ID	Decisión adoptada	Justificación 1	Justificación 2	Alternativas descartadas
D22	**Desplegar los componentes críticos con zonas de disponibilidad en la región primaria y una región secundaria en warm standby, con RTO de hasta una hora y RPO de hasta cinco minutos.**	Objetivos que exigen otra región (NIST SP 800-34; Azure Well-Architected Framework): Las zonas de disponibilidad cubren la falla de una zona, no la de una región.	Costo frente a beneficio (Azure Well-Architected Framework, pilar de confiabilidad): Un modelo activo-activo duplica el costo y la complejidad de la consistencia, y un arranque en frío no cumple el RTO.	Una sola región; Solo alta disponibilidad dentro de la región; Activo-activo en dos regiones.
D23	**Aplicar segmentación de red, Private Endpoints para los servicios de datos, salida controlada por Azure Firewall y mTLS hacia los sistemas del banco.**	Zero trust (NIST SP 800-207): Ningún componente es de confianza por el solo hecho de estar dentro de la red.	Reducir la superficie de ataque (CIS Controls; Azure Well-Architected Framework, pilar de seguridad): Los servicios de datos no tienen acceso público y la salida solo llega a una lista de nombres permitidos (Registro Civil, proveedor de prueba de vida, ACS, Firebase y APNs).	Servicios expuestos a Internet; Solo redes virtuales con reglas de acceso.

ANEXO A

Glosario

Este glosario define los términos, siglas y patrones que se utilizan en el documento.

Término	Significado
AKS	Azure Kubernetes Service. Servicio administrado de Azure para ejecutar aplicaciones en contenedores mediante Kubernetes.
AMQP	Advanced Message Queuing Protocol. Protocolo abierto de mensajería; Azure Service Bus utiliza su versión 1.0.
Anti-Corruption Layer (capa anticorrupción)	Capa que traduce el modelo de un sistema externo al modelo propio, para que los cambios de ese sistema no afecten al dominio de la plataforma.
API	Interfaz de programación de aplicaciones. Contrato mediante el cual un sistema expone funciones a otros sistemas.
Auto-healing	Capacidad de la plataforma de detectar una falla y corregirla sin intervención humana.
Azure API Management (APIM)	Servicio de Azure que actúa como puerta de entrada de las APIs: valida tokens, aplica límites de consumo, versiona y publica los servicios.
Azure Data Explorer	Servicio de análisis de Azure para consultar grandes volúmenes de datos, como los eventos de auditoría.
Azure Front Door	Servicio global de entrega de aplicaciones de Azure, con balanceo de carga, terminación TLS y protección mediante WAF.
Azure Key Vault	Servicio de Azure para custodiar secretos, certificados y llaves criptográficas con control de acceso y registro de uso.
Azure Service Bus	Servicio de mensajería empresarial de Azure, con colas y tópicos, que permite la comunicación asíncrona entre servicios.
Azure Static Web Apps	Servicio de Azure para publicar los recursos estáticos de una aplicación web, como una SPA.
BCE	Banco Central del Ecuador. Opera el Sistema de Pagos Interbancarios (SPI).
BFF (Backend for Frontend)	Servicio de backend diseñado para un tipo de cliente, web o móvil, que adapta y agrega las respuestas de los servicios de negocio.
Cache-Aside	Patrón de caché en el que la aplicación consulta primero la caché y, si no encuentra el dato, lo obtiene de la fuente y lo almacena temporalmente.
CDC (Change Data Capture)	Técnica que captura los cambios de una base de datos para propagarlos a otros sistemas.
Circuit Breaker	Patrón que interrumpe temporalmente las llamadas a una dependencia que falla, para evitar que el fallo se propague a otros componentes.
COMF	Código Orgánico Monetario y Financiero del Ecuador.
Core bancario	Sistema central de la entidad donde residen las cuentas, los saldos y los movimientos. Es la fuente autorizada de la información financiera.

Término	Significado
CQRS	Command Query Responsibility Segregation. Separación del modelo de lectura y del modelo de escritura de un sistema.
CSP	Content Security Policy. Política del navegador que limita los orígenes desde los que una página puede cargar recursos y reduce el riesgo de XSS.
CSRF	Cross-Site Request Forgery. Ataque que induce al navegador de un usuario autenticado a enviar una solicitud no deseada.
Dead-Letter Queue (DLQ)	Cola donde se conservan los mensajes que no pudieron procesarse, para su análisis y reproceso.
DR (recuperación ante desastres)	Conjunto de medidas para restablecer la operación tras una interrupción grave, como la pérdida de una región.
Entra External ID	Servicio de identidad de Microsoft para clientes y usuarios externos, basado en estándares como OAuth 2.0 y OpenID Connect.
ExpressRoute	Servicio de Azure para conectar una red local con Azure mediante un enlace privado que no pasa por Internet.
Fallback	Alternativa que se utiliza cuando falla el mecanismo principal.
FAPI (Financial-grade API)	Perfil de seguridad de la OpenID Foundation para APIs del sector financiero.
FIDO2 y WebAuthn	Estándares de autenticación basados en credenciales criptográficas del usuario, sin contraseñas compartidas.
Idempotencia (clave de idempotencia)	Propiedad de una operación que, repetida con la misma clave, produce el mismo resultado sin duplicar sus efectos.
Inmutabilidad (WORM)	Modelo de almacenamiento Write Once, Read Many, que impide modificar o eliminar los datos durante un período definido.
ISO/IEC 27001	Norma internacional para los sistemas de gestión de seguridad de la información.
JWT	JSON Web Token. Token firmado que transporta información (claims) sobre el usuario y sus permisos.
KYC	Conozca a su cliente: proceso de identificación y debida diligencia del cliente antes de abrir una cuenta.
LOPDP	Ley Orgánica de Protección de Datos Personales del Ecuador.
Managed Identity	Identidad administrada de Azure que permite a un servicio autenticarse ante otros servicios sin almacenar credenciales.
MFA	Autenticación multifactor. Exige más de un factor de verificación para validar al usuario.
mTLS	TLS mutuo. Ambos extremos de la comunicación se autentican con certificados.
NIST CSF	Marco de ciberseguridad del NIST, organizado en funciones de gobierno, identificación, protección, detección, respuesta y recuperación.
OAuth 2.0	Estándar de autorización que permite a una aplicación obtener acceso limitado a recursos mediante tokens.

Término	Significado
Onboarding	Proceso de alta digital de un cliente nuevo.
OpenID Connect (OIDC)	Capa de identidad sobre OAuth 2.0 que permite verificar la identidad del usuario.
OWASP ASVS y MASVS	Estándares de verificación de seguridad de aplicaciones web (ASVS) y móviles (MASVS) del proyecto OWASP.
PAD	Detección de ataques de presentación: pruebas de que una biometría no se suplanta con fotos, videos o máscaras (ISO/IEC 30107-3).
PCI DSS	Estándar de seguridad de datos de la industria de tarjetas de pago.
PEP	Persona expuesta políticamente: persona que ocupa o ocupó un cargo público relevante y requiere diligencia reforzada.
PKCE	Proof Key for Code Exchange. Extensión de OAuth 2.0 que protege el código de autorización frente a su interceptación.
Private Endpoint	Interfaz de red privada que expone un servicio de Azure dentro de una red virtual, sin acceso público.
Private Link	Servicio de Azure que permite acceder a servicios mediante direcciones IP privadas dentro de una red virtual.
Prueba de vida (liveness)	Verificación de que la persona que se registra está presente y es real, y no una fotografía o un video.
Publish-Subscribe	Patrón en el que un productor publica eventos y varios consumidores independientes los reciben.
RPO	Recovery Point Objective. Pérdida máxima de datos tolerada ante una interrupción, medida en tiempo.
RTO	Recovery Time Objective. Tiempo máximo aceptable para restablecer el servicio tras una interrupción.
Saga	Patrón que coordina una operación distribuida mediante pasos locales y acciones de compensación, sin una transacción única.
SIEM y SOC	Plataforma de gestión de eventos de seguridad (SIEM) y centro de operaciones de seguridad (SOC).
SKU	Nivel o variante de un producto de Azure, con capacidades y precio definidos.
SLI / SLO	Indicador de nivel de servicio y objetivo de nivel de servicio que se mide sobre ese indicador.
SPA	Single Page Application. Aplicación web que se carga una vez y actualiza su contenido sin recargar la página.
SPDP	Superintendencia de Protección de Datos Personales del Ecuador.
SPI	Sistema de Pagos Interbancarios del Banco Central del Ecuador, utilizado para las transferencias entre entidades financieras.
Strategy	Patrón de diseño que permite elegir un algoritmo o comportamiento según el caso, a través de una interfaz común.

Término	Significado
TLS	Transport Layer Security. Protocolo que cifra y autentica las comunicaciones.
TTL	Time To Live. Tiempo que un dato permanece en caché antes de expirar.
UAFE	Unidad de Análisis Financiero y Económico del Ecuador.
WAF	Web Application Firewall. Filtro que protege las aplicaciones web de ataques comunes.
XSS	Cross-Site Scripting. Ataque que inyecta scripts maliciosos en una página web.

ANEXO B

Referencias consultadas

Este anexo reúne las fuentes normativas, los estándares y la documentación técnica que sustentan el diseño. Los enlaces se verificaron en octubre de 2026.

B.1 Marco legal y regulatorio de Ecuador

- Ley Orgánica de Protección de Datos Personales (LOPDP). Registro Oficial Suplemento No. 459, 26 de mayo de 2021.
- Reglamento General a la Ley Orgánica de Protección de Datos Personales. Decreto Ejecutivo No. 904, 6 de noviembre de 2023, publicado en el Registro Oficial Suplemento No. 435 el 13 de noviembre de 2023.
- EY Ecuador. Alerta legal: Reglamento a la Ley Orgánica de Protección de Datos Personales: https://www.ey.com/content/dam/ey-unified-site/ey-com/es-ec/technical/tax/documents/ey-legal-alert-nov1-reglamento-lopdp.pdf
- Código Orgánico Monetario y Financiero (COMF), Ecuador.
- Superintendencia de Bancos del Ecuador. Codificación de las Normas de la Superintendencia de Bancos, Libro I, Título IX, Capítulo V: Norma de control para la gestión del riesgo operativo.
- Superintendencia de Bancos. Circular SB-INRE-2022-0021, revisión y análisis de la seguridad de la información para las actividades financieras en canales electrónicos: https://asobanca.org.ec/wp-content/uploads/2022/10/Circular-SB-INRE-2022-0021.-Revision-y-analisis-de-la-seguirad-de-la-informacion-para-las-actividades-financieras-en-canales-electronicos.pdf
- Superintendencia de Bancos. Circular SB-IG-2026-0021-C: https://asobanca.org.ec/wp-content/uploads/2026/07/SB-IG-2026-0021-C.pdf
- Superintendencia de Bancos. Resolución SB-2026-2068: https://asobanca.org.ec/wp-content/uploads/2026/07/resolucion_SB-2026-2068.pdf
- Banco Central del Ecuador. Circular BCE-SGSERV-2024-008-C, cambio de horario del tercer corte del SPI: https://asobanca.org.ec/wp-content/uploads/2024/03/Circular-No.-BCE-SGSERV-2024-008-C-Cambio-de-horario-del-Tercer-Corte-del-SPI.pdf
- Banco Central del Ecuador. Circular de inicio de operaciones del SPI en la nueva plataforma, 10 de octubre de 2023: https://asobanca.org.ec/wp-content/uploads/2023/10/Circular-inicio-operaciones-SPI_10octubre2023-signed.pdf

B.2 Estándares y especificaciones técnicas

- IETF. RFC 6749, The OAuth 2.0 Authorization Framework: https://www.rfc-editor.org/rfc/rfc6749
- IETF. RFC 7636, Proof Key for Code Exchange by OAuth Public Clients (PKCE): https://www.rfc-editor.org/rfc/rfc7636
- IETF. RFC 8252, OAuth 2.0 for Native Apps: https://www.rfc-editor.org/rfc/rfc8252
- IETF. RFC 9700, Best Current Practice for OAuth 2.0 Security: https://www.rfc-editor.org/rfc/rfc9700
- IETF. OAuth 2.0 for Browser-Based Applications (borrador de trabajo): https://datatracker.ietf.org/doc/draft-ietf-oauth-browser-based-apps/
- OpenID Foundation. OpenID Connect Core 1.0: https://openid.net/specs/openid-connect-core-1_0.html
- W3C. Web Authentication: An API for accessing Public Key Credentials (WebAuthn): https://www.w3.org/TR/webauthn-2/
- OWASP. Application Security Verification Standard (ASVS): https://owasp.org/www-project-application-security-verification-standard/
- OWASP. Mobile Application Security Verification Standard (MASVS): https://mas.owasp.org/MASVS/
- NIST. Cybersecurity Framework (CSF) 2.0: https://www.nist.gov/cyberframework
- ISO/IEC 27001. Information security management systems: https://www.iso.org/standard/27001

B.3 Documentación de Azure y arquitectura en la nube

- Microsoft. Azure Well-Architected Framework: https://learn.microsoft.com/azure/well-architected/
- Microsoft. Azure Architecture Center, Cloud design patterns: https://learn.microsoft.com/azure/architecture/patterns/
- Microsoft. Azure regions and availability zones: https://learn.microsoft.com/azure/reliability/regions-list
- Azure Speed Test. Azure regions: https://www.azurespeed.com/Information/AzureRegions
- Microsoft. Azure AD B2C, preguntas frecuentes: https://learn.microsoft.com/azure/active-directory-b2c/faq
- Microsoft. Microsoft Entra External ID: https://learn.microsoft.com/entra/external-id/
- Microsoft. Azure Kubernetes Service (AKS): https://learn.microsoft.com/azure/aks/
- Microsoft. Azure API Management: https://learn.microsoft.com/azure/api-management/
- Microsoft. Azure Front Door: https://learn.microsoft.com/azure/frontdoor/
- Microsoft. Azure Static Web Apps: https://learn.microsoft.com/azure/static-web-apps/
- Microsoft. Azure Service Bus, Geo-Disaster Recovery: https://learn.microsoft.com/azure/service-bus-messaging/service-bus-geo-dr
- Microsoft. Azure Service Bus, Geo-Replication: https://learn.microsoft.com/azure/service-bus-messaging/service-bus-geo-replication
- Microsoft. Azure Storage, immutable storage for blob data: https://learn.microsoft.com/azure/storage/blobs/immutable-storage-overview
- Microsoft. Azure Data Explorer: https://learn.microsoft.com/azure/data-explorer/
- Microsoft. Azure Key Vault: https://learn.microsoft.com/azure/key-vault/
- Microsoft. Managed identities for Azure resources: https://learn.microsoft.com/entra/identity/managed-identities-azure-resources/overview
- Microsoft. Azure Monitor: https://learn.microsoft.com/azure/azure-monitor/
- Polly. Biblioteca de resiliencia para .NET: https://www.pollydocs.org/

B.4 Libros y artículos sobre patrones de arquitectura

- Garcia-Molina, H. y Salem, K. (1987). Sagas. ACM SIGMOD Record, 16(3).
- Hohpe, G. y Woolf, B. (2003). Enterprise Integration Patterns. Addison-Wesley.
- Evans, E. (2003). Domain-Driven Design. Addison-Wesley.
- Gamma, E., Helm, R., Johnson, R. y Vlissides, J. (1994). Design Patterns: Elements of Reusable Object-Oriented Software. Addison-Wesley.
- Richardson, C. (2018). Microservices Patterns. Manning.
- Newman, S. (2021). Building Microservices, 2.ª ed. O'Reilly Media.
- Kleppmann, M. (2017). Designing Data-Intensive Applications. O'Reilly Media.
- Nygard, M. (2018). Release It!, 2.ª ed. Pragmatic Bookshelf.
- Fowler, M. CQRS: https://martinfowler.com/bliki/CQRS.html
- Newman, S. Pattern: Backends For Frontends: https://samnewman.io/patterns/architectural/bff/
- Richardson, C. Microservices patterns (Saga, Transactional outbox): https://microservices.io/patterns/

B.5 Referencias adicionales de las decisiones

- Fowler, M. y Lewis, J. (2014). Microservices: https://martinfowler.com/articles/microservices.html
- Abadi, D. (2012). Consistency Tradeoffs in Modern Distributed Database System Design (PACELC). IEEE Computer, 45(2).

- NIST SP 800-207, Zero Trust Architecture (2020); NIST SP 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems; NIST SP 800-63B, Digital Identity Guidelines: Authentication and Lifecycle Management.
- ISO/IEC 30107-3, Biometric presentation attack detection: Testing and reporting.
- Center for Internet Security. CIS Critical Security Controls.
- Microsoft. Cloud Adoption Framework for Azure; patrón Cache-Aside (Azure Architecture Center); almacenamiento inmutable para Azure Blob Storage (WORM).

ANEXO C

Registro de decisiones (ADR)

Registro completo de las 21 decisiones estructurales: la decisión, el requisito que atiende, dos justificaciones con su fundamento, las alternativas descartadas, el compromiso aceptado y, cuando aplica, el supuesto de diseño. La sección 13 las resume.

D1 Selección de plataforma en la nube

DECISIÓN: utilizar Microsoft Azure como plataforma única de infraestructura y servicios administrados.

REQUISITO QUE ATIENDE: Arquitectura en la nube con servicios administrados (secciones 5 y 8).

JUSTIFICACIÓN 1, INTEGRACIÓN DE SERVICIOS (AZURE WELL-ARCHITECTED FRAMEWORK): Azure ofrece administrados todos los servicios que exige el diseño (AKS, API Management, Front Door, Service Bus, Azure SQL, Entra External ID, Key Vault). Usar un solo proveedor evita ensamblar y operar piezas de distintos fabricantes y reduce la carga operativa del equipo.

JUSTIFICACIÓN 2, CONTINUIDAD Y CUMPLIMIENTO (CLOUD ADOPTION FRAMEWORK DE MICROSOFT): Azure dispone de regiones con zonas de disponibilidad cercanas a Ecuador y de regiones pareadas para recuperación ante desastres, lo que permite cumplir RTO de una hora y RPO de cinco minutos sin construir un segundo centro de datos.

ALTERNATIVAS DESCARTADAS:

- **AWS y Google Cloud:** ofrecen capacidades equivalentes, pero obligarían a reemplazar Entra External ID, API Management y Azure DevOps sin una ventaja que lo compense.
- **Infraestructura local o híbrida:** no ofrece elasticidad ni recuperación regional sin invertir en un segundo centro de datos.

COMPROMISO ACEPTADO: dependencia del proveedor (vendor lock-in) y costo de salida de datos. Se mitiga con estándares abiertos (Kubernetes, AMQP, OAuth y OpenID Connect, SQL) que permiten migrar un componente sin rediseñar el resto.

D2 Selección de la región de Azure

DECISIÓN: utilizar Brazil South como región primaria y South Central US como región secundaria de recuperación ante desastres.

REQUISITO QUE ATIENDE: Baja latencia, alta disponibilidad y recuperación ante desastres (sección 8).

Criterio	Brazil South	Mexico Central	Chile Central	South Central US
Zonas de disponibilidad	3	3	3	3
Región emparejada	South Central US (en un solo sentido)	No tiene	No tiene	North Central US (pareja simétrica)

Criterio	Brazil South	Mexico Central	Chile Central	South Central US
Storage GZRS hacia la secundaria	Sí, de forma nativa	No disponible en regiones sin pareja; requeriría replicación propia de la auditoría	No disponible en regiones sin pareja; requeriría replicación propia de la auditoría	Sí, de forma nativa
Azure SQL y Service Bus entre regiones	Failover Group y Geo-Replication	Igual	Igual	Igual
Costo mensual de referencia	Estimado en la sección 10.3	Se estima antes de contratar	Se estima antes de contratar	Menor que Brazil South en SQL, Redis y nodos de AKS (precios de octubre de 2026)

Nota: Antes de contratar se verifican para cada región la latencia desde Quito y Guayaquil (del cliente a Front Door y de la región al Core por ExpressRoute), la disponibilidad de servicios y SKU, y la ubicación de los datos. Todas las candidatas están fuera de Ecuador. Las zonas y las parejas se basan en la documentación pública de Azure.

JUSTIFICACIÓN 1, ALTA DISPONIBILIDAD DENTRO DE LA REGIÓN (AZURE WELL-ARCHITECTED FRAMEWORK, PILAR DE CONFIABILIDAD): Brazil South tiene tres zonas de disponibilidad, por lo que la pérdida de un centro de datos se absorbe dentro de la región, sin activar la secundaria. Las cuatro candidatas cumplen este criterio, así que no las diferencia: es una condición mínima.

JUSTIFICACIÓN 2, RECUPERACIÓN GEOGRÁFICA CON MENOR DISEÑO PROPIO (DOCUMENTACIÓN DE AZURE SOBRE REGIONES EMPAREJADAS): Brazil South está emparejada con South Central US. Eso permite usar Storage GZRS para la evidencia de auditoría inmutable sin construir un mecanismo de replicación propio. Azure SQL y Service Bus no dependen de la pareja: se configuran entre las regiones elegidas, y su disponibilidad en cada región se verifica servicio por servicio. Como la pareja es de un solo sentido, no se cuenta con las actualizaciones escalonadas de una pareja simétrica.

ALTERNATIVAS DESCARTADAS:

- **Mexico Central y Chile Central:** tienen tres zonas y pueden usar los mecanismos de Azure SQL y Service Bus hacia otra región. Se descartan porque la evidencia de auditoría necesitaría una replicación propia hacia la secundaria, con su costo de construcción, prueba y operación. Se reconsideran si las mediciones muestran una latencia claramente menor que la de Brazil South.

ALTERNATIVA DE CONTINGENCIA:

- **South Central US con North Central US:** tiene una pareja simétrica, un catálogo amplio de servicios y un costo de referencia menor. Pasa a ser la opción principal si la latencia medida hacia el cliente o hacia el Core, o el costo total, resultan más favorables que en Brazil South.

COMPROMISO ACEPTADO: Brazil South suele tener precios más altos que las regiones de EE. UU. y su latencia desde Ecuador todavía no está medida. Se acepta por la replicación nativa de la auditoría y se revisa con las mediciones de latencia y la estimación de costos.

SUPUESTO DE DISEÑO: la región cumple los objetivos de latencia (consultas p95 menor a 300 ms y transferencias internas p95 menor a 800 ms), también operando desde la secundaria, ofrece los servicios y SKU requeridos y es aceptable para el banco en cuanto a la ubicación de los datos. Se confirma antes de contratar con mediciones de latencia desde Quito y Guayaquil, con las ubicaciones de ExpressRoute disponibles con los proveedo-

res de conectividad del banco y con la aprobación de Legal, Cumplimiento y Protección de Datos. Si cambia la región, el diseño lógico se mantiene; se ajustan la replicación de la auditoría, los circuitos de ExpressRoute, el análisis de transferencia internacional de datos y la estimación de costos.

D3 Arquitectura basada en microservicios

DECISIÓN: construir la plataforma con microservicios por dominio funcional, cada uno con su propia base de datos.

REQUISITO QUE ATIENDE: Arquitectura desacoplada y reutilizable (sección 3).

JUSTIFICACIÓN 1, ESCALAMIENTO INDEPENDIENTE (NEWMAN, BUILDING MICROSERVICES): La plataforma combina lecturas muy frecuentes (históricos) con escrituras críticas (transferencias) y envíos masivos (notificaciones). Separarlos permite escalar cada carga por su cuenta en lugar de dimensionar todo para el pico más alto.

JUSTIFICACIÓN 2, AISLAMIENTO DE FALLOS Y DE CAMBIOS (FOWLER Y LEWIS, MICROSERVICES; LEY DE CONWAY): Una falla en Notificaciones no debe detener Transferencias, y los equipos pueden desplegar un servicio sin coordinar la salida de todos los demás.

ALTERNATIVAS DESCARTADAS:

- **Monolito:** acopla el escalamiento y los despliegues de dominios con perfiles de carga muy distintos.
- **Monolito modular:** es razonable para un equipo pequeño, pero comparte procesos y base de datos y no aísla las fallas.

COMPROMISO ACEPTADO: mayor complejidad operativa, consistencia eventual entre servicios y necesidad de observabilidad distribuida. Se mitiga con AKS (D4), Transactional Outbox (D16) y las trazas descritas en la sección 9.

D4 Plataforma de ejecución de servicios

DECISIÓN: ejecutar los servicios backend y los BFF en Azure Kubernetes Service (AKS).

REQUISITO QUE ATIENDE: Ejecución escalable y segura de los servicios (secciones 5 y 8).

JUSTIFICACIÓN 1, CONTROL DE RED Y DE NODOS (GUÍA DE ARQUITECTURA DE AKS DE MICROSOFT): La plataforma exige red privada, políticas de red, distribución multizona y control de los nodos. AKS ofrece ese nivel de control para cerca de diez servicios con políticas de despliegue y escalamiento diferenciadas.

JUSTIFICACIÓN 2, ESTÁNDAR Y PORTABILIDAD (CNCF, KUBERNETES): Kubernetes es un estándar abierto con escalamiento horizontal (HPA), despliegue declarativo y GitOps, lo que reduce la dependencia de un servicio propietario de Azure.

ALTERNATIVAS DESCARTADAS:

- **Azure Container Apps:** simplifica la operación pero ofrece menos control sobre la red y los nodos; sería la opción si esos requisitos no existieran.
- **Azure App Service:** funciona por aplicación y no cubre bien una flota de servicios con políticas diferenciadas.
- **Máquinas virtuales:** trasladan al equipo la operación del sistema operativo, el escalamiento y las actualizaciones.

COMPROMISO ACEPTADO: la operación de Kubernetes requiere conocimientos de redes, seguridad y observabilidad. Se acepta y se reduce con despliegue automatizado (GitOps) y un equipo de plataforma.

D5 Separación de BFF para web y aplicación móvil

DECISIÓN: implementar un Backend for Frontend (BFF) para la aplicación web y otro para la aplicación móvil.

REQUISITO QUE ATIENDE: Integración con los canales web y móvil (sección 6.2).

JUSTIFICACIÓN 1, NECESIDADES DISTINTAS POR CANAL (NEWMAN, PATRÓN BACKEND FOR FRONTEND): La web mantiene la sesión con una cookie HttpOnly y actúa como cliente confidencial. La app móvil usa PKCE y necesita respuestas ligeras. Cada BFF adapta las respuestas a su canal sin condicionales por tipo de cliente.

JUSTIFICACIÓN 2, SEGURIDAD Y EVOLUCIÓN INDEPENDIENTE (RFC 9700 (OAUTH 2.0 SECURITY BCP)): Los tokens de la web quedan en el servidor y nunca llegan al navegador. Cada BFF evoluciona sin riesgo de romper al otro canal.

ALTERNATIVAS DESCARTADAS:

- **Un backend compartido por todos los clientes:** acumula lógica condicional por canal y acopla sus lanzamientos.
- **Un único BFF para web y móvil:** mezcla dos modelos de sesión y de seguridad distintos.

COMPROMISO ACEPTADO: hay dos componentes que mantener y cierta duplicación de código. Se limita con una biblioteca común de agregación, resiliencia y auditoría.

D7 Gestión de identidad digital

DECISIÓN: utilizar Microsoft Entra External ID como servicio de identidad de los clientes.

REQUISITO QUE ATIENDE: Autenticación de clientes con MFA (sección 6.2).

JUSTIFICACIÓN 1, NO REINVENTAR LA AUTENTICACIÓN (OWASP ASVS; NIST SP 800-63B): Gestionar credenciales, MFA y recuperación de acceso es una función de alto riesgo. Un servicio administrado concentra esa responsabilidad y se mantiene frente a nuevas amenazas.

JUSTIFICACIÓN 2, INTEGRACIÓN CON ESTÁNDARES (OPENID CONNECT CORE 1.0; OAUTH 2.0): Entra External ID emite tokens estándar que API Management y los BFF validan sin código propio, lo que simplifica la integración con el resto de la plataforma.

ALTERNATIVAS DESCARTADAS:

- **Proveedor de identidad propio:** obliga a construir y operar autenticación, MFA y recuperación de acceso, con alto riesgo y costo.
- **Soluciones comerciales de identidad:** ofrecen capacidades comparables, pero añaden otro proveedor y un costo por usuario sin una ventaja clara frente a Entra.
- **Azure AD B2C:** dejó de estar disponible para nuevos clientes desde el 1 de mayo de 2025.

COMPROMISO ACEPTADO: algunas funciones de B2C no existen de forma equivalente y el costo es por usuario activo. Cada flujo de usuario se diseña de forma explícita y el costo se incluye en la estimación (sección 10.3).

SUPUESTO DE DISEÑO: Entra External ID cubre los flujos requeridos para los clientes, incluidos MFA y recuperación de acceso.

D8 Protocolo de autenticación para web y móvil

DECISIÓN: utilizar OAuth 2.0 Authorization Code Flow con PKCE y OpenID Connect para ambos canales.

REQUISITO QUE ATIENDE: Recomendación del flujo OAuth (sección 6.2).

JUSTIFICACIÓN 1, PRÁCTICA VIGENTE DE SEGURIDAD (RFC 9700 (OAUTH 2.0 SECURITY BCP)): La guía vigente desaconseja el Implicit Flow y recomienda Authorization Code con PKCE para todo tipo de cliente.

JUSTIFICACIÓN 2, PROTECCIÓN EN APPS MÓVILES (RFC 7636 (PKCE); RFC 8252 (OAUTH PARA APPS NATIVAS)): PKCE evita que se use un código de autorización interceptado. La app móvil abre el navegador del sistema y no una vista web embebida, de modo que la app nunca ve las credenciales.

ALTERNATIVAS DESCARTADAS:

- **Implicit Flow y flujos heredados:** exponen tokens en el navegador o entregan las credenciales a la aplicación.
- **Autenticación propia:** reinventa un protocolo que Entra External ID ya resuelve (D7).

COMPROMISO ACEPTADO: más redirecciones y gestión del refresh token con rotación. Se acepta a cambio de no exponer credenciales ni tokens.

D9 Autenticación biométrica y vinculación del dispositivo

DECISIÓN: vincular cada dispositivo móvil con una llave criptográfica no exportable, desbloqueada con la biometría local, cuya clave pública se registra en la BD Dispositivos. La llave firma un desafío en cada ingreso y en cada transferencia, y una prueba de posesión al estilo de DPoP en cada solicitud, que verifica el BFF Móvil. En la web, que no tiene llave, cada transferencia exige un segundo factor por transacción: un step-up de MFA en Entra External ID o la aprobación desde la app vinculada.

REQUISITO QUE ATIENDE: Autenticación con biometría y confirmación reforzada de las transferencias en la app y en la web (secciones 6.2, 7.2 y 7.5).

JUSTIFICACIÓN 1, PRIVACIDAD DE LA BIOMETRÍA (W3C WEBAUTHN Y FIDO2): la huella o el rostro no salen del dispositivo; solo autorizan el uso local de la llave, y el servidor verifica una firma, no un dato biométrico. Así se reduce el tratamiento de datos biométricos, que la LOPDP considera sensibles.

JUSTIFICACIÓN 2, RESISTENCIA AL ROBO DE TOKENS (RFC 9449 COMO REFERENCIA; OWASP MASVS): sin la llave registrada no se puede operar ni consultar aunque se robe un access token o un refresh token, porque el BFF exige la firma en cada solicitud. Entra External ID emite tokens normales; la verificación la hace el BFF contra la clave registrada, sin depender de que el emisor ligue el token.

ALTERNATIVAS DESCARTADAS:

- **Solo usuario y contraseña:** no ofrece la autenticación reforzada por transacción que se espera en un canal electrónico financiero.
- **OTP como único segundo factor también en la app:** depende de un canal externo (SMS o correo) más expuesto a interceptación; en la app la llave del dispositivo es más fuerte, y el OTP queda para la web y la recuperación.

- **Biometría que solo desbloquea el refresh token local:** el servidor no recibe ninguna prueba del dispositivo, así que un token robado sigue siendo útil.

COMPROMISO ACEPTADO: cambiar de teléfono exige volver a enrolar el dispositivo con contraseña y MFA, y repetir la prueba de vida para montos altos; si se pierde el teléfono, el cliente lo revoca desde la web o el centro de contacto y la llave queda inválida en la BD Dispositivos.

D10 Validación de identidad durante el onboarding

DECISIÓN: separar la validación documental, la comparación facial y la prueba de vida en adaptadores independientes, con un proveedor comercial para la prueba de vida.

REQUISITO QUE ATIENDE: Onboarding con reconocimiento facial (sección 6.4).

JUSTIFICACIÓN 1, RESPONSABILIDAD ÚNICA (PATRÓN STRATEGY; HOHPE Y WOOLF, ENTERPRISE INTEGRATION PATTERNS): Cada validación cambia a su propio ritmo y proviene de un proveedor distinto. Con un adaptador por validación se reemplaza uno sin alterar el flujo.

JUSTIFICACIÓN 2, RESISTENCIA A LA SUPLANTACIÓN (ISO/IEC 30107-3 (DETECCIÓN DE ATAQUES DE PRESENTACIÓN)): El Registro Civil compara el rostro, pero no detecta una foto, un video o una máscara. La prueba de vida requiere un proveedor cuya detección de ataques de presentación haya sido evaluada de forma independiente.

ALTERNATIVAS DESCARTADAS:

- **Validación manual:** no escala y deja el control a la revisión humana.
- **Un proveedor único e integral:** acopla las tres validaciones y prescinde de la fuente oficial de identidad.

COMPROMISO ACEPTADO: costo por verificación y dependencia de un proveedor. Se controlan con el contrato y con el adaptador que permite sustituirlo.

SUPUESTO DE DISEÑO: el banco dispone de una integración autorizada con el Registro Civil y de un proveedor comercial de prueba de vida con SDK para Flutter.

D11 Framework para aplicación móvil

DECISIÓN: desarrollar la aplicación móvil con Flutter, con una única base de código para Android e iOS.

REQUISITO QUE ATIENDE: Aplicación móvil multiplataforma (sección 6.7).

JUSTIFICACIÓN 1, UNA BASE DE CÓDIGO (DOCUMENTACIÓN DE FLUTTER; COSTO TOTAL DE PROPIEDAD): Flutter comparte interfaz y lógica entre Android e iOS con un solo equipo y un solo ciclo de pruebas, lo que reduce el costo de mantenimiento de una app financiera que debe mantenerse al día con ambos sistemas operativos.

JUSTIFICACIÓN 2, SEGURIDAD DEL DISPOSITIVO (OWASP MASVS): La app necesita biometría, almacenamiento seguro (Keychain y Keystore) y detección de root o jailbreak. Flutter lo cubre con complementos mantenidos y con canales de plataforma para lo que estos no resuelvan, sin renunciar a los controles del estándar.

ALTERNATIVAS DESCARTADAS:

- **React Native:** es una opción válida y con ecosistema amplio. Se elige Flutter por tener una sola base de código y por el soporte de los SDK de los proveedores de prueba de vida que se consideran, criterio que se confirma con el proveedor elegido.

- **Kotlin Multiplatform:** comparte la lógica pero mantiene dos interfaces nativas, con mayor costo de desarrollo.
- **Desarrollo nativo:** ofrece el acceso más directo a las APIs del sistema, pero duplica el equipo y el esfuerzo de pruebas.
- **.NET MAUI:** tiene un ecosistema de bibliotecas de seguridad móvil menos maduro.

COMPROMISO ACEPTADO: la app depende de los complementos de Flutter para biometría y almacenamiento seguro. Se mitiga fijando versiones, auditando los complementos y manteniendo código de plataforma propio para esos controles.

D12 Framework para aplicación web

DECISIÓN: desarrollar la SPA con Angular y TypeScript.

REQUISITO QUE ATIENDE: Aplicación web (sección 6.6).

JUSTIFICACIÓN 1, ESTRUCTURA PARA UNA APLICACIÓN GRANDE (GUÍA DE ARQUITECTURA DE ANGULAR): Angular ofrece inyección de dependencias, módulos, formularios reactivos y herramientas de pruebas en un solo marco. Esa estructura uniforme facilita que varios equipos trabajen sobre una aplicación bancaria extensa sin definir sus propias convenciones.

JUSTIFICACIÓN 2, CONTRATOS EXPLÍCITOS (TYPESCRIPT; OWASP ASVS): TypeScript mantiene tipos explícitos entre la SPA y el BFF, lo que reduce errores de integración, y Angular protege por defecto contra la inyección de scripts al escapar el contenido que se muestra.

ALTERNATIVAS DESCARTADAS:

- **React:** es flexible y con gran ecosistema, pero deja al equipo las decisiones de estructura, enrutamiento y formularios, con más variación entre equipos.
- **Vue.js:** ofrece un marco más ligero, pero deja más decisiones de estructura al equipo que Angular.
- **Renderizado en servidor:** no se justifica en una aplicación autenticada que no depende del posicionamiento en buscadores.

COMPROMISO ACEPTADO: Angular tiene una curva de aprendizaje mayor y actualizaciones mayores frecuentes. Se acepta y se gestiona con un calendario de actualización.

D13 Plataforma de mensajería y eventos

DECISIÓN: utilizar Azure Service Bus Premium para la comunicación asíncrona entre servicios.

REQUISITO QUE ATIENDE: Mensajería asíncrona y auditoría (secciones 5 y 6.5).

JUSTIFICACIÓN 1, ENTREGA GARANTIZADA (HOHPE Y WOOLF, GUARANTEED DELIVERY): Las colas persisten el mensaje, reintentan y envían a una Dead-Letter Queue lo que no se puede procesar. El nivel Premium aísla la capacidad y admite zonas de disponibilidad y Geo-Replication.

JUSTIFICACIÓN 2, DESACOPLE EN EL TIEMPO (RICHARDSON, MICROSERVICES PATTERNS): Si un consumidor cae, los mensajes esperan en la cola. La auditoría y las notificaciones se procesan fuera del camino de la transacción y absorben los picos sin afectarla.

ALTERNATIVAS DESCARTADAS:

- **REST síncrono entre servicios:** ata la disponibilidad de un servicio a la del otro y pierde los eventos cuando un destino no responde.
- **Azure Event Hubs:** está pensado para flujos de eventos de gran volumen y no ofrece la semántica de colas con reintentos y Dead-Letter por mensaje.
- **Broker autogestionado:** traslada al equipo la operación y la alta disponibilidad del broker.

COMPROMISO ACEPTADO: la entrega es al menos una vez, así que los consumidores deben ser idempotentes (D16). La capacidad Premium reservada tiene un costo fijo (sección 10.3).

D14 Orquestación de transferencias interbancarias

DECISIÓN: gestionar las transferencias interbancarias con una Saga orquestada y compensaciones.

REQUISITO QUE ATIENDE: Transferencias interbancarias (secciones 6.1 y 7.3).

JUSTIFICACIÓN 1, SIN TRANSACCIÓN DISTRIBUIDA (GARCIA-MOLINA Y SALEM, SAGAS (1987); RICHARDSON, MICROSERVICES PATTERNS): La operación toca el Core y el SPI, que no pueden participar en una misma transacción. La Saga divide el proceso en pasos locales con una compensación para cada uno que pueda revertirse.

JUSTIFICACIÓN 2, VISIBILIDAD Y CONTROL DEL ESTADO (RICHARDSON, SAGA ORQUESTADA): Un orquestador centraliza el estado de cada operación. Esto facilita la conciliación y el tratamiento de los resultados inciertos (sección 7.4), que en una coreografía quedarían repartidos entre servicios.

ALTERNATIVAS DESCARTADAS:

- **Flujo síncrono de extremo a extremo:** mantiene recursos ocupados mientras el SPI procesa por cortes y no tolera una caída intermedia.
- **Coreografía por eventos:** dispersa el flujo y dificulta seguirlo, depurarlo y auditarlo.

COMPROMISO ACEPTADO: el orquestador es un componente crítico y no todo paso es reversible: el débito puede reversarse, pero una instrucción ya enviada al SPI no. Su estado se persiste en Azure SQL (D35) y se concilia con el SPI.

D15 Atomicidad de transferencias internas

DECISIÓN: delegar en el Core la transferencia interna como una única operación atómica.

REQUISITO QUE ATIENDE: Transferencias entre cuentas del mismo banco (secciones 6.1 y 7.2).

JUSTIFICACIÓN 1, TRANSACCIÓN LOCAL (KLEPPMANN, DESIGNING DATA-INTENSIVE APPLICATIONS (ACID)): El débito y el crédito ocurren en el mismo sistema, por lo que pueden confirmarse en una transacción local. Coordinarlos desde fuera crearía una ventana de inconsistencia sin necesidad.

JUSTIFICACIÓN 2, INTEGRIDAD CONTABLE (PRINCIPIO DE UNA ÚNICA FUENTE DE VERDAD): El Core es el dueño del libro contable. La plataforma no replica reglas contables y reduce el riesgo de que los saldos diverjan.

ALTERNATIVAS DESCARTADAS:

- **Débito y crédito independientes coordinados por la plataforma:** dejan una ventana en la que el dinero salió de una cuenta y no llegó a la otra.

- **Saga con compensaciones:** añade complejidad cuando el Core ya garantiza atomicidad.

COMPROMISO ACEPTADO: la plataforma depende de esa capacidad del Core. Si no existiera, se aplicaría la Saga de D14.

SUPUESTO DE DISEÑO: el Core ofrece la transferencia interna como una operación atómica y admite claves de idempotencia o un mecanismo equivalente. También permite anular una clave de idempotencia para cancelar una operación cuyo resultado era incierto (sección 7.4).

D16 Idempotencia y Transactional Outbox

DECISIÓN: exigir una clave de idempotencia en cada solicitud financiera y publicar los eventos mediante Transactional Outbox.

REQUISITO QUE ATIENDE: Operaciones financieras sin duplicados (secciones 6.1, 7.3 y 7.4).

JUSTIFICACIÓN 1, LOS REINTENTOS SON INEVITABLES (HOHPE Y WOOLF, IDEMPOTENT RECEIVER): Los tiempos de espera y los resultados inciertos obligan a reintentar. Sin una clave de idempotencia persistente, un reintento puede duplicar un débito.

JUSTIFICACIÓN 2, DOBLE ESCRITURA (RICHARDSON, TRANSACTIONAL OUTBOX): Guardar el dato y el evento en la misma transacción local evita el caso en que el dato se guarda y el evento se pierde. Un proceso publicador envía después los eventos pendientes a Service Bus.

ALTERNATIVAS DESCARTADAS:

- **Reintentos sin control de duplicados:** repiten operaciones financieras.
- **Control de duplicados en memoria:** se pierde al reiniciar y no funciona con varias instancias.
- **Publicar a Service Bus después del commit:** puede perder el evento si el proceso cae entre ambos pasos.

COMPROMISO ACEPTADO: una tabla de Outbox y un publicador adicionales, con entrega al menos una vez. Los consumidores son idempotentes y los eventos de una misma cuenta se publican en orden.

D17 Consulta de históricos mediante CQRS y sincronización de datos

DECISIÓN: separar las lecturas de históricos de la escritura financiera con un modelo de consulta propio, sincronizado con el Core por el Sincronizador.

REQUISITO QUE ATIENDE: Consulta del histórico sin sobrecargar el Core (sección 6.3).

JUSTIFICACIÓN 1, PROTEGER EL CORE (FOWLER, CQRS): Las lecturas de históricos son mucho más frecuentes que las escrituras y compiten con las operaciones del Core. Un modelo de lectura dedicado evita que las consultas aumenten la carga transaccional.

JUSTIFICACIÓN 2, CONSISTENCIA ADECUADA A CADA DATO (KLEPPMANN, DESIGNING DATA-INTENSIVE APPLICATIONS; ABADI, PACELC): El histórico tolera un retraso de segundos (objetivo de 60 segundos, sección 9.2); el saldo con el que se autoriza una operación no, y se consulta al Core.

ALTERNATIVAS DESCARTADAS:

- **Consultar siempre el Core:** ata la latencia y la disponibilidad de las consultas a las del Core y aumenta su carga.
- **Réplica provista por el Core:** deja el formato y la retención en manos de un sistema que no controlamos.

COMPROMISO ACEPTADO: el histórico es eventualmente consistente. Se mide con un indicador de frescura (sección 9.2) y se informa al cliente la fecha de corte.

SUPUESTO DE DISEÑO: el Core permite obtener sus cambios mediante eventos, API, CDC o procesos por lotes, y la latencia de sincronización se documenta con la alternativa disponible.

D18 Estrategia de caché para consultas

DECISIÓN: utilizar Azure Managed Redis con el patrón Cache-Aside para las consultas de los clientes frecuentes.

REQUISITO QUE ATIENDE: Persistencia y caché de clientes frecuentes (secciones 5.3 y 6.3).

JUSTIFICACIÓN 1, LATENCIA (PATRÓN CACHE-ASIDE (AZURE ARCHITECTURE CENTER)): Las consultas repetidas de los clientes frecuentes se responden desde memoria y ayudan a cumplir un p95 menor a 300 ms.

JUSTIFICACIÓN 2, LA CACHÉ NO ES FUENTE DE VERDAD (KLEPPMANN, DESIGNING DATA-INTENSIVE APPLICATIONS): Si Redis falla, los servicios leen la base de lectura y la caché se reconstruye. La precarga y la invalidación se describen en la sección 5.3. Los movimientos se guardan por páginas con claves por cursor (ancladas a un movimiento o a una fecha), de modo que una transacción nueva solo invalida la primera página.

ALTERNATIVAS DESCARTADAS:

- **Sin caché:** mantiene toda la carga de consulta sobre la base de lectura.
- **Caché local por instancia:** cada instancia guarda datos distintos, es difícil de invalidar y se pierde al escalar.

COMPROMISO ACEPTADO: el dato puede estar desactualizado hasta que se invalide o venza su TTL (5 minutos para saldos y 15 para el perfil). Se reduce con la invalidación del Sincronizador.

D19 Auditoría inmutable y consultas de auditoría

DECISIÓN: conservar la evidencia en Azure Storage con inmutabilidad (WORM) y consultarla en Azure Data Explorer.

REQUISITO QUE ATIENDE: Auditoría de todas las acciones (sección 6.5).

JUSTIFICACIÓN 1, EVIDENCIA NO MODIFICABLE (AZURE IMMUTABLE BLOB STORAGE (WORM)): La política de inmutabilidad impide modificar o borrar un registro durante el período de retención, lo que respalda la reconstrucción de las operaciones ante un auditor o un incidente.

JUSTIFICACIÓN 2, SEPARAR ESCRITURA Y CONSULTA (PRINCIPIO DE MÍNIMO PRIVILEGIO): Data Explorer atiende las consultas de auditores y de seguridad sin tocar el almacén inmutable, y se reconstruye desde Storage si es necesario.

ALTERNATIVAS DESCARTADAS:

- **Logs operativos convencionales:** pueden modificarse y su retención es corta.
- **Base de datos relacional de auditoría:** un administrador puede alterarla y resulta costosa con grandes volúmenes.

COMPROMISO ACEPTADO: la retención prolongada tiene costo, que se reduce con ciclo de vida a niveles fríos compatibles con la inmutabilidad. Los datos personales en la evidencia se minimizan según la LOPDP.

D21 Resiliencia de comunicaciones y manejo de fallos

DECISIÓN: aplicar tiempos de espera, reintentos con espera exponencial, Circuit Breaker y aislamiento de recursos en toda llamada a un sistema externo.

REQUISITO QUE ATIENDE: Tolerancia a fallos de sistemas externos (secciones 6.1, 8.2 y 9.4).

JUSTIFICACIÓN 1, EVITAR FALLAS EN CASCADA (NYGARD, RELEASE IT!): Sin límites, un proveedor lento agota los hilos y arrastra al resto. El Circuit Breaker abre el circuito ante errores repetidos y el tiempo de espera acota la espera.

JUSTIFICACIÓN 2, POLÍTICA ÚNICA Y OBSERVABLE (BIBLIOTECA POLLY): Una biblioteca estándar con parámetros por dependencia y métricas evita una lógica distinta en cada servicio. Solo se reintentan operaciones idempotentes (D16).

ALTERNATIVAS DESCARTADAS:

- **Reintentos sin política:** generan una tormenta de reintentos sobre un servicio ya degradado.
- **Gestión de errores propia de cada servicio:** produce comportamientos inconsistentes y difíciles de monitorear.

COMPROMISO ACEPTADO: un umbral mal calibrado abre el circuito sin necesidad o tarda en abrirlo. Se calibra con pruebas de carga y se monitorea en la sección 9.

D22 Alta disponibilidad y recuperación ante desastres

DECISIÓN: desplegar los componentes críticos con zonas de disponibilidad en la región primaria y una región secundaria en warm standby, con RTO de hasta una hora y RPO de hasta cinco minutos.

REQUISITO QUE ATIENDE: Alta disponibilidad y recuperación ante desastres (sección 8).

JUSTIFICACIÓN 1, OBJETIVOS QUE EXIGEN OTRA REGIÓN (NIST SP 800-34; AZURE WELL-ARCHITECTED FRAMEWORK): Las zonas de disponibilidad cubren la falla de una zona, no la de una región. Cumplir un RTO de una hora ante una falla regional requiere una segunda región ya desplegada.

JUSTIFICACIÓN 2, COSTO FRENTE A BENEFICIO (AZURE WELL-ARCHITECTED FRAMEWORK, PILAR DE CONFIABILIDAD): Un modelo activo-activo duplica el costo y la complejidad de la consistencia, y un arranque en frío no cumple el RTO. El warm standby con capacidad reducida cuesta cerca de un tercio del total (sección 10.3).

ALTERNATIVAS DESCARTADAS:

- **Una sola región:** no tiene respuesta ante una falla regional.
- **Solo alta disponibilidad dentro de la región:** no cubre una interrupción regional.
- **Activo-activo en dos regiones:** duplica el costo y exige resolver la consistencia entre regiones.

COMPROMISO ACEPTADO: la replicación entre regiones es asíncrona y el RPO depende de cada componente (sección 8.4). Se verifica con simulacros semestrales que miden el RTO y el RPO reales.

SUPUESTO DE DISEÑO: los objetivos de RTO de una hora y RPO de cinco minutos son los requeridos por el negocio y se alcanzan con la arquitectura de recuperación descrita.

D23 Seguridad de red y comunicación entre componentes

DECISIÓN: aplicar segmentación de red, Private Endpoints para los servicios de datos, salida controlada por Azure Firewall y mTLS hacia los sistemas del banco.

REQUISITO QUE ATIENDE: Seguridad y cumplimiento normativo (secciones 8.6 y 11).

JUSTIFICACIÓN 1, ZERO TRUST (NIST SP 800-207): Ningún componente es de confianza por el solo hecho de estar dentro de la red. Cada comunicación se autentica y se autoriza, y el acceso a los datos es privado.

JUSTIFICACIÓN 2, REDUCIR LA SUPERFICIE DE ATAQUE (CIS CONTROLS; AZURE WELL-ARCHITECTED FRAMEWORK, PILAR DE SEGURIDAD): Los servicios de datos no tienen acceso público y la salida solo llega a una lista de nombres permitidos (Registro Civil, proveedor de prueba de vida, ACS, Firebase y APNs).

ALTERNATIVAS DESCARTADAS:

- **Servicios expuestos a Internet:** amplían la superficie de ataque sin necesidad.
- **Solo redes virtuales con reglas de acceso:** no dan acceso privado a los servicios administrados como Azure SQL o Service Bus.

COMPROMISO ACEPTADO: mayor complejidad de red y de DNS privado, y el costo de Azure Firewall Premium (cerca de 1 300 dólares al mes por región, sección 10.3).

ANEXO D

Decisiones complementarias

Estas decisiones de implementación no cambian la estructura de la solución. Cada una se justifica con dos razones y la alternativa que se descartó. Cada una conserva su identificador para la trazabilidad con las secciones del documento.

ID	Decisión adoptada	Justificación 1	Justificación 2	Alternativa descartada
D6	**Utilizar Azure API Management como punto único de acceso a las APIs.**	Centraliza la validación de tokens, las cuotas, el versionado y la observabilidad.	Da gobierno del ciclo de vida de cada API (versiones, cuotas y observabilidad por API) en un solo punto, sin repetirlo en los BFF.	Exponer los servicios directamente; construir un gateway a medida.
D20	**Evaluación antifraude síncrona, con tiempo de espera y contingencia definidos por Riesgos.**	El resultado debe conocerse antes de autorizar la operación; el análisis posterior solo complementa.	Un control posterior no evita el fraude ya consumado; el previo sí.	Evaluación solo posterior mediante eventos.
D24	**Azure Monitor y Application Insights con instrumentación OpenTelemetry.**	Permite correlacionar una solicitud entre el canal, los servicios, la mensajería y los sistemas externos (sección 9).	Un estándar abierto permite cambiar de herramienta de análisis sin reinstrumentar los servicios.	Logs independientes por aplicación; herramientas autogestionadas.
D25	**Azure DevOps para repositorios y pipelines, con infraestructura como código.**	Despliegues repetibles, con pruebas y análisis de seguridad, y trazabilidad de los cambios.	Los despliegues automatizados dejan evidencia auditable de quién cambió qué.	Despliegues manuales; GitHub Actions.
D26	**Servicio de notificaciones desacoplado, con Azure Communication Services (correo y SMS) y Firebase y APNs (push).**	Gestiona plantillas, preferencias, reintentos y trazabilidad sin acoplarlos a las operaciones financieras; los adaptadores permiten cambiar de proveedor.	Los adaptadores por canal permiten cumplir el mínimo de dos canales y sumar otros sin tocar el negocio.	Envío directo desde los servicios de negocio.
D27	**C# y .NET para los servicios backend.**	Soporte maduro para APIs, programación asíncrona, pruebas e integración con Azure; coherente con la experiencia del equipo.	Un solo lenguaje permite una biblioteca común de resiliencia y auditoría; se asume un equipo con experiencia en .NET (supuesto de diseño).	Java con Spring Boot, Node.js y Python.
D28	**REST sobre HTTPS con JSON para las APIs y AMQP 1.0 para Service Bus.**	Contratos ampliamente adoptados y soporte nativo de Service Bus.	Los contratos REST se prueban y documentan con herramientas estándar y los equipos los conocen.	gRPC (podrá usarse entre servicios internos si una medición lo justifica).
D29	**Azure Front Door con WAF como entrada pública.**	Distribución global, terminación TLS y protección contra amenazas web comunes en un solo punto.	Sus sondas de salud retiran el origen que falla y conmutan el tráfico hacia la región secundaria, que es su papel en la recuperación ante desastres.	Balanceadores regionales; publicación directa.

ID	Decisión adoptada	Justificación 1	Justificación 2	Alternativa descartada
D30	**Azure Static Web Apps para alojar la SPA, detrás de Azure Front Door.**	Una SPA compilada se publica como recursos estáticos sin servidor dedicado, y el frontend se despliega por separado del backend.	El contenido estático se sirve desde el borde de Front Door, con menor latencia.	Azure Storage Static Website; contenedores.
D31	**Azure SQL Database para los datos relacionales.**	Servicio administrado con respaldo, redundancia de zona y grupo de conmutación por error.	Las transacciones ACID de Azure SQL sostienen la idempotencia y el Outbox.	SQL Managed Instance; PostgreSQL administrado; base autogestionada.
D32	**Azure Managed Redis para la caché administrada.**	Azure Cache for Redis está en proceso de retiro; Managed Redis es el servicio vigente.	Se dimensiona por niveles de memoria y rendimiento según la carga medida, y su alta disponibilidad se verifica en la región elegida.	Sin caché; caché local por instancia.
D33	**Servicio de Límites independiente, que reserva el cupo de forma atómica, lo confirma al completarse el débito, lo libera si la operación se rechaza o se reversa, y lo vence a los 15 minutos si nadie lo confirma.**	Aplica criterios consistentes por cliente, cuenta, canal y período, con cambios trazables. En la consulta en paralelo solo responde si hay cupo.	La reserva es una actualización condicional atómica: dos operaciones simultáneas no pueden superar el cupo y un rechazo del Core devuelve el cupo.	Duplicar las reglas en cada servicio; ubicarlas dentro de Transferencias.
D34	**Servicio de Transferencias y Pagos con una estrategia por tipo de operación.**	Comparte las validaciones comunes y mantiene separado el comportamiento de cada tipo, sin duplicar código.	Cada tipo de operación evoluciona sin afectar a los demás; la estrategia de pago a productos de otras entidades se agregaría aquí sin cambiar el resto.	Un servicio por tipo de transferencia; un único servicio con condicionales.
D35	**Orquestador de Saga propio, con su estado persistido en Azure SQL Database.**	Registra cada etapa, error y acción de recuperación, y facilita la conciliación con el SPI.	El estado persistido permite retomar una operación tras una conmutación regional.	Orquestación dentro del servicio de negocio; coreografía por eventos; framework de orquestación.
D36	**Sesión web gestionada por el BFF con cookie HttpOnly, Secure y SameSite.**	Los tokens permanecen en el servidor y JavaScript no puede leer la cookie.	El servidor controla la renovación del token y puede revocar la sesión sin depender del navegador.	Guardar tokens en el navegador; autenticación directa de la SPA.
D37	**Frontends por capas, con estado centralizado solo donde el flujo lo requiere (NgRx en Angular, BLoC en Flutter).**	Separa presentación, acceso a datos y lógica, lo que facilita pruebas y mantenimiento.	Los flujos complejos mantienen un único estado en vez de estados repartidos entre pantallas.	Estado local en todos los componentes; estado compartido mediante servicios.
D38	**Managed Identity de Azure y Key Vault para identidades de servicio y secretos.**	Ningún servicio guarda credenciales y el acceso a secretos queda controlado y auditado.	Se rota un secreto en Key Vault sin volver a desplegar la aplicación.	Secretos en variables de entorno o archivos; usuarios de servicio con contraseña.

ID	Decisión adoptada	Justificación 1	Justificación 2	Alternativa descartada
D39	**Microsoft Defender for Cloud y Microsoft Sentinel.**	Detección, correlación y respuesta integradas con los servicios de Azure; se integran con el SIEM o el SOC del banco sin reemplazarlos.	Los registros de seguridad quedan separados de quienes operan la plataforma.	Alertas básicas; Splunk o Elastic Security; SOC tercerizado.

ANEXO E

Estándares técnicos y evidencias de cumplimiento

E.1 Estándares internacionales de apoyo

Los siguientes estándares y especificaciones se utilizarán como referencias técnicas para diseñar, implementar y verificar los controles de seguridad. Su adopción no sustituye las obligaciones regulatorias ecuatorianas ni implica una certificación automática de la plataforma.

Estándar o especificación	Aplicación en el diseño
ISO/IEC 27001 e ISO/IEC 27002	Referencia para la gestión de seguridad de la información, la evaluación de riesgos y la selección e implementación de controles de seguridad.
NIST Cybersecurity Framework (CSF) 2.0	Estructurar la gestión de riesgos de ciberseguridad mediante las funciones Govern, Identify, Protect, Detect, Respond y Recover.
OAuth 2.0 Security Best Current Practice (RFC 9700), PKCE (RFC 7636) y OAuth para aplicaciones nativas (RFC 8252)	Fundamentar los flujos de autenticación y autorización. Utilizar Authorization Code con PKCE para aplicaciones móviles y evitar flujos desaconsejados, como Implicit y Resource Owner Password Credentials.
OpenID Connect (OIDC)	Proporcionar una capa de identidad sobre OAuth 2.0 para la autenticación de usuarios y el intercambio de información de identidad.
Financial-grade API (FAPI)	Referencia opcional para evaluar controles reforzados en APIs financieras. Su adopción dependerá de los requisitos de seguridad, las capacidades de los participantes y el perfil de integración elegido.
FIDO2 y WebAuthn	Referencia para mecanismos de autenticación basados en credenciales criptográficas y autenticadores del usuario. La biometría local puede autorizar el uso de una credencial, sin que necesariamente se transmitan los datos biométricos al servidor.
OWASP Application Security Verification Standard (ASVS)	Definir y verificar requisitos de seguridad para la aplicación web y los servicios asociados. Se establecerá una versión y un nivel de verificación acordes con el riesgo de la plataforma.
OWASP Mobile Application Security Verification Standard (MASVS)	Definir controles de seguridad y pruebas para la aplicación móvil, considerando almacenamiento local, autenticación, comunicaciones, protección de datos y resistencia frente a amenazas.
PCI DSS	Aplicable cuando el alcance de la solución incluya el almacenamiento, procesamiento o transmisión de datos de tarjetas de pago, o afecte al entorno de datos de titulares de tarjetas. Su aplicabilidad deberá confirmarse según el alcance real.
Azure Well-Architected Framework	Orientar las decisiones de arquitectura mediante sus cinco pilares: excelencia operativa, seguridad, confiabilidad, eficiencia de rendimiento y optimización de costos.

E.2 Evidencias de cumplimiento y validación

Antes de la salida a producción, se deberá mantener un registro de requisitos y evidencias que permita demostrar la aplicación de los controles pertinentes.

Como mínimo, se considerarán los siguientes elementos:

1. **Matriz de cumplimiento:** relacionar cada obligación aplicable con el control de arquitectura, el responsable y la evidencia correspondiente.
2. **Seguridad de aplicaciones:** documentar las pruebas de seguridad, análisis de vulnerabilidades y acciones correctivas.
3. **Protección de datos:** documentar las finalidades, bases de legitimación, períodos de conservación, transferencias y medidas de protección aplicables.
4. **Continuidad del negocio:** conservar los resultados de las pruebas de recuperación, las mediciones de RTO y RPO y los planes de acción.
5. **Operaciones financieras:** mantener trazabilidad de las transacciones, controles de autorización, conciliación y gestión de operaciones pendientes o fallidas.
6. **Aprobación de salida a producción:** obtener la validación de las áreas responsables del cumplimiento normativo, seguridad, continuidad operativa y protección de datos.

La matriz de cumplimiento deberá actualizarse cuando cambien la normativa aplicable, las interfaces de integración, los proveedores, los tratamientos de datos o los componentes relevantes de la arquitectura.